

ĐẠI HỌC CÔNG NGHIỆP HÀ NỘI
TRƯỜNG CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG



BÁO CÁO THỰC TẬP CƠ SỞ NGÀNH

Mã lớp độc lập: IT6046.1 (20252IT6046001)

ĐỀ TÀI:

XÂY DỰNG HỆ THỐNG QUẢN LÝ NGÂN HÀNG

MB BANK

GVHD: Ths. Chu Thị Quyên

Nhóm: 8

Sinh viên thực hiện:

Nguyễn Minh Đức	2024605324	KHMT01	K19
Quách Gia Hiếu	2024606067	KHMT01	K19
Chu Quang Hưng	2024604669	KHMT01	K19
Nguyễn Mạnh Hùng	2024601533	KHMT01	K19

Hà Nội - 2026

ĐẠI HỌC CÔNG NGHIỆP HÀ NỘI
TRƯỜNG CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG



BÁO CÁO THỰC TẬP CƠ SỞ NGÀNH

Mã lớp độc lập: IT6046.1 (20252IT6046001)

ĐỀ TÀI:

XÂY DỰNG HỆ THỐNG QUẢN LÝ NGÂN HÀNG

MB BANK

GVHD: Ths. Chu Thị Quyên

Nhóm: 8

Sinh viên thực hiện:

Nguyễn Minh Đức	2024605324	KHMT01	K19
Quách Gia Hiếu	2024606067	KHMT01	K19
Chu Quang Hưng	2024604669	KHMT01	K19
Nguyễn Mạnh Hùng	2024601533	KHMT01	K19

Hà Nội - 2026

LỜI CẢM ƠN

Trong suốt quá trình thực hiện đề tài "**Xây dựng hệ thống quản lý ngân hàng MB Bank**", nhóm đã nhận được sự hỗ trợ và định hướng quý báu từ giảng viên hướng dẫn.

Trước tiên và trên hết, nhóm xin gửi lời cảm ơn chân thành đến cô Chu Thị Quyên đã trực tiếp hướng dẫn, góp ý và theo sát tiến độ thực hiện trong suốt học kỳ. Những nhận xét thực chất của cô đã giúp nhóm nhìn ra những điểm còn thiếu sót, điều chỉnh hướng tiếp cận kịp thời và hoàn thiện báo cáo một cách có hệ thống hơn. Sự tận tâm và nghiêm túc trong từng buổi nhận xét là động lực lớn để nhóm nỗ lực hoàn thành đề tài đúng yêu cầu đặt ra.

Ngoài ra, các thành viên trong nhóm cũng xin ghi nhận tinh thần phối hợp của nhau trong quá trình phân chia công việc. Dù còn những hạn chế nhất định, đây là trải nghiệm thực hành có giá trị để nhóm tiếp tục học hỏi trong các học phần chuyên ngành tiếp theo.

Hà Nội, tháng 5 năm 2026

Nhóm 8

MỤC LỤC

LỜI CẢM ƠN	i
MỤC LỤC.....	ii
DANH MỤC CÁC THUẬT NGỮ KÍ HIỆU VÀ CÁC CHỮ VIẾT TẮT....	viii
DANH MỤC HÌNH VẼ.....	xii
DANH MỤC BẢNG BIỂU	xiv
MỞ ĐẦU	1
1. Lý do chọn đề tài.....	1
2. Mục tiêu nghiên cứu.....	1
3. Đối tượng nghiên cứu	2
4. Phạm vi nghiên cứu.....	2
5. Phương pháp nghiên cứu.....	3
6. Kết quả mong muốn của đề tài.....	3
7. Cấu trúc báo cáo.....	4
CHƯƠNG 1: TỔNG QUAN VỀ NGÂN HÀNG MB BANK VÀ HỆ THỐNG QUẢN LÝ NGÂN HÀNG.....	5
1.1 Giới thiệu tổng quan về MBBank.....	5
1.1.1 Quá trình hình thành và phát triển	5
1.1.2 Cơ cấu tổ chức của ngân hàng	6
1.2 Các dịch vụ chính của ngân hàng.....	7
1.2.1 Quản lý tài khoản khách hàng.....	7
1.2.2 Dịch vụ gửi tiền và rút tiền	7
1.2.3 Dịch vụ chuyển khoản.....	8
1.2.4 Dịch vụ cho vay	9

1.2.5 Dịch vụ ngân hàng điện tử	9
1.3 Tổng quan về hệ thống quản lý ngân hàng	10
1.3.1 Khái niệm hệ thống quản lý ngân hàng	10
1.3.2 Vai trò của hệ thống quản lý trong ngân hàng	11
1.3.3 Các chức năng chính của hệ thống ngân hàng	11
1.3.4 Các công nghệ sử dụng trong hệ thống ngân hàng hiện đại	13
1.4 Các hệ thống ngân hàng điện tử hiện nay	14
1.4.1 Internet Banking	14
1.4.2 Mobile Banking	14
1.4.3 Core Banking	15
1.4.4 Công nghệ bảo mật ngân hàng	15
CHƯƠNG 2: KHẢO SÁT, PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG QUẢN LÝ NGÂN HÀNG MB BANK	16
2.1 Khảo sát hệ thống	16
2.1.1 Mục tiêu khảo sát	16
2.1.2 Phương pháp khảo sát	16
2.1.3 Kết quả khảo sát	17
2.2 Phân tích yêu cầu hệ thống	18
2.2.1 Đối tượng sử dụng hệ thống	18
2.2.2 Yêu cầu chức năng của hệ thống	19
2.2.3 Yêu cầu phi chức năng	21
2.3 Mô hình nghiệp vụ của hệ thống	22
2.3.1 Quy trình mở tài khoản	22
2.3.2 Quy trình giao dịch tiền gửi và rút	22

2.3.3. Quy trình chuyển tiền.....	24
2.3.4 Quy trình quản lý ngân hàng.....	24
2.4 Phân tích hệ thống bằng UML	26
2.4.1 Sơ đồ Use Case	26
2.4.1.1 Sơ đồ Use Case tổng thể	26
2.4.1.2 Use Case quản lý khách hàng	27
2.4.1.3 Use Case quản lý tài khoản.....	28
2.4.1.4 Use Case giao dịch ngân hàng	30
2.4.1.5 Use Case quản lý nhân viên	31
2.4.2 Sơ đồ Activity	33
2.4.2.1 Activity Diagram đăng nhập và xác thực	33
2.4.2.2 Activity Diagram mở tài khoản	34
2.4.2.3 Activity diagram giao dịch tiền.....	35
2.4.2.4 Activity Diagram chuyển khoản	36
2.4.3 Sơ đồ Sequence	37
2.4.3.1 Sequence đăng ký và duyệt tài khoản.....	37
2.4.3.2 Sequence nạp, rút tiền	38
2.4.3.3 Sequence chuyển khoản.....	39
2.4.4 Sơ đồ Class.....	41
2.5 Thiết kế hệ thống.....	43
2.5.1 Kiến trúc tổng thể hệ thống.....	43
2.5.2 Thiết kế cơ sở dữ liệu.....	44
2.5.2.1 Xác định các thực thể.....	44

2.5.2.2 Xác định các thuộc tính.....	45
2.5.2.3 Xác định mối quan hệ giữa các thực thể.....	46
2.5.2.4 Sơ đồ ERD	47
2.5.2.5 Thiết kế cơ sở dữ liệu vật lý cho hệ thống.....	48
2.6.3 Thiết kế giao diện người dùng	53
2.6.3.1 Giao diện của khách hàng	53
2.6.3.2 Giao diện của nhân viên ngân hàng	57
2.6.3.3 Giao diện của quản trị hệ thống	60
CHƯƠNG 3: XÂY DỰNG VÀ KIỂM THỬ HỆ THỐNG.....	64
3.1 Công nghệ và công cụ sử dụng	64
3.1.1 Ngôn ngữ lập trình và Framework.....	64
3.1.2 Công cụ phát triển và Quản lý	66
3.2 Xây dựng hệ thống quản lý ngân hàng	66
3.2.1 Cấu trúc mã nguồn	67
3.2.2 Cài đặt chức năng Quản lý mở tài khoản trực tuyến	68
3.2.3 Cài đặt chức năng Giao dịch tài chính	71
3.2.3.1 Nạp tiền và rút tiền tại quầy	71
3.2.3.2 Chuyển khoản trực tuyến	73
3.2.3.3 Danh bạ người nhận thông minh.....	75
3.2.4 Cài đặt chức năng Bảo mật và Phân quyền.....	75
3.2.4.1 Xác thực người dùng.....	75
3.2.4.2 Phân quyền truy cập.....	76
3.2.4.3 Kiểm soát truy cập tăng dữ liệu	77

3.2.4.4 Quản lý trạng thái tài khoản.....	78
3.2.5 Thiết kế và cài đặt hệ thống bảo mật	78
3.2.5.1 Mã hóa mật khẩu bằng thuật toán BCrypt	78
3.2.5.2 Xác thực không trạng thái bằng JWT	80
3.2.5.3 Phân quyền truy cập theo vai trò.....	81
3.2.6 Thiết kế mã giao dịch tự động	83
3.2.6.1 Quy tắc sinh mã giao dịch.....	83
3.2.6.2 Vai trò của mã giao dịch trong kiểm soát nghiệp vụ	84
3.2.7 Thiết kế RESTful API.....	84
3.2.7.1 Nguyên tắc thiết kế API	85
3.2.7.2 Cơ chế phân quyền.....	85
3.2.7.3 Cấu trúc các nhóm API	85
3.2.7.4 Danh sách API Endpoints	86
3.3 Kiểm thử hệ thống.....	92
3.3.1 Kế hoạch kiểm thử	92
3.3.1.1 Phạm vi kiểm thử	92
3.3.1.2 Phương pháp kiểm thử	93
3.3.2 Kịch bản kiểm thử.....	94
3.3.2.1. Phân hệ Khách hàng.....	94
3.3.2.2. Phân hệ Nhân viên ngân hàng.....	104
3.3.2.3. Phân hệ Quản trị hệ thống.....	116
3.3.2.4. Kiểm thử tính nhất quán dữ liệu và mã giao dịch.....	122
3.3.3 Kết quả kiểm thử	126

3.4 Đánh giá hệ thống	127
3.4.1 Ưu điểm của hệ thống	127
3.4.2 Hạn chế của hệ thống	127
3.5 Hướng phát triển	129
3.5.1 Tăng cường bảo mật giao dịch.....	129
3.5.2 Mở rộng nghiệp vụ tài chính.....	129
3.5.3 Phát triển ứng dụng di động.....	129
3.5.4 Nâng cấp kiến trúc và hiệu năng hệ thống.....	130
3.5.5 Tích hợp trí tuệ nhân tạo và phân tích dữ liệu	130
KẾT LUẬN	131
TÀI LIỆU THAM KHẢO.....	132

DANH MỤC CÁC THUẬT NGỮ KÍ HIỆU VÀ CÁC CHỮ VIẾT TẮT

Chữ viết tắt / Ký hiệu	Giải thích / Nội dung đầy đủ
MB Bank	Military Bank – Ngân hàng Thương mại Cổ phần Quân đội Việt Nam
TMCP	Thương mại Cổ phần
HĐQT	Hội đồng Quản trị
CEO	Chief Executive Officer – Tổng Giám đốc điều hành
HR	Human Resources – Quản lý Nhân sự
KYC	Know Your Customer – Xác minh danh tính khách hàng
ATM	Automated Teller Machine – Máy rút tiền tự động
OTP	One-Time Password – Mật khẩu dùng một lần
STK	Số Tài Khoản
CCCD	Căn Cước Công Dân
QR	Quick Response – Mã phản hồi nhanh (mã QR)
UML	Unified Modeling Language – Ngôn ngữ mô hình hóa thống nhất
MVC	Model – View – Controller: mô hình kiến trúc phần mềm 3 lớp

API	Application Programming Interface – Giao diện lập trình ứng dụng
HTTP	HyperText Transfer Protocol – Giao thức truyền tải siêu văn bản
REST	Representational State Transfer – Kiểu kiến trúc API phổ biến
JSON	JavaScript Object Notation – Định dạng trao đổi dữ liệu nhẹ
JVM	Java Virtual Machine – Máy ảo Java
JPA	Jakarta Persistence API (trước là Java Persistence API) – API quản lý dữ liệu quan hệ trong Java
DTO	Data Transfer Object – Đối tượng truyền dữ liệu giữa các tầng
ORM	Object-Relational Mapping – Ánh xạ đối tượng – quan hệ
UI	User Interface – Giao diện người dùng
PHP	PHP: Hypertext Preprocessor – Ngôn ngữ lập trình phía máy chủ
SQL	Structured Query Language – Ngôn ngữ truy vấn có cấu trúc
MySQL	Hệ quản trị cơ sở dữ liệu quan hệ mã nguồn mở (InnoDB engine)
ACID	Atomicity, Consistency, Isolation, Durability – Tính nguyên tử, Nhất quán, Độc lập, Bền vững của giao dịch CSDL
PK	Primary Key – Khóa chính trong cơ sở dữ liệu
FK	Foreign Key – Khóa ngoại trong cơ sở dữ liệu

InnoDB	Storage engine mặc định của MySQL, hỗ trợ ACID và khóa ngoại
JWT	JSON Web Token – Chuẩn xác thực không trạng thái dạng token
RBAC	Role-Based Access Control – Kiểm soát truy cập dựa trên vai trò
MFA	Multi-Factor Authentication – Xác thực đa yếu tố
SSL	Secure Sockets Layer – Giao thức mã hóa kết nối mạng (cũ)
TLS	Transport Layer Security – Giao thức bảo mật tầng truyền tải (thay thế SSL)
BCrypt	Thuật toán băm mật khẩu một chiều, được sử dụng để mã hóa mật khẩu người dùng
XSS	Cross-Site Scripting – Tấn công chèn mã độc vào trang web
NFC	Near Field Communication – Giao tiếp không dây tầm ngắn (dùng trong thanh toán không chạm)
SMS	Short Message Service – Dịch vụ tin nhắn ngắn
AI	Artificial Intelligence – Trí tuệ nhân tạo
Spring Boot	Framework Java mã nguồn mở để xây dựng ứng dụng web/dịch vụ RESTful
Thymeleaf	Template Engine phía máy chủ, tích hợp với Spring Boot để render giao diện web động

Bootstrap	Framework CSS mã nguồn mở hỗ trợ Responsive Design
PENDING	Trạng thái chờ xử lý (hồ sơ đăng ký tài khoản chưa được duyệt)
APPROVED	Trạng thái đã được chấp thuận / duyệt
REJECTED	Trạng thái bị từ chối

DANH MỤC HÌNH VẼ

Hình 2.1: Use Case tổng thể Hệ thống quản lý ngân hàng MB Bank	26
Hình 2.2: Use Case chức năng quản lý khách hàng.....	28
Hình 2.3: Use Case chức năng quản lý tài khoản	29
Hình 2.4: Use case giao dịch ngân hàng	31
Hình 2.5: Use case quản lý nhân viên.....	32
Hình 2.6: Activity Diagram Đăng nhập và xác thực	33
Hình 2.7: Activity Diagram mở tài khoản	34
Hình 2.8: Activity giao dịch tiền.....	35
Hình 2.9: Activity Diagram chuyển khoản	36
Hình 2.10: Sequence mở tài khoản	37
Hình 2.11: Sequence giao dịch tiền tại quầy.....	39
Hình 2.12: Sequence chuyển khoản.....	40
Hình 2.13: Sơ đồ class.....	41
Hình 2.14: Sơ đồ ERD hệ thống MBBank.....	47
Hình 2.15: Màn hình đăng nhập dành cho khách hàng	54
Hình 2.16: Màn hình trang chủ dành cho khách hàng	55
Hình 2.17: Màn hình chuyển khoản trực tuyến	56
Hình 2.18: Màn hình lịch sử giao dịch của khách hàng.....	56
Hình 2.19: Màn hình đăng nhập dành cho nhân viên ngân hàng.....	58
Hình 2.20: Màn hình giao dịch nạp/rút tiền tại quầy	59
Hình 2.21: Màn hình quản lý tài khoản khách hàng	60
Hình 2.22: Màn hình quản lý và duyệt hồ sơ khách hàng	60

Hình 2.23: Màn hình Dashboard tổng quan quản trị hệ thống	61
Hình 2.24: Màn hình quản lý thông tin và phân quyền nhân viên.....	62
Hình 2.25: Màn hình đăng nhập dành cho quản trị hệ thống.....	62

DANH MỤC BẢNG BIỂU

Bảng 2.1: Bảng các thực thể	45
Bảng 2.2: Bảng mối quan hệ giữa các thực thể	47
Bảng 2.3: Bảng USERS	48
Bảng 2.4: Bảng BRANCHES	49
Bảng 2.5: Bảng CUSTOMERS.....	49
Bảng 2.6: Bảng EMPLOYEES	50
Bảng 2.7: Bảng ACCOUNTS	50
Bảng 2.8: Bảng TRANSACTIONS	51
Bảng 2.9: Bảng ACCOUNT_REGISTRATION_REQUESTS.....	52
Bảng 2.10: Bảng SAVED_RECIPIENTS.....	53
Bảng 2.11: Tổng hợp các màn hình trong phân hệ nhân viên	57
Bảng 2.12: Tổng hợp nguyên tắc thiết kế giao diện người dùng.....	63
Bảng 3.1: Cấu trúc package mã nguồn hệ thống	67
Bảng 3.2: Phân quyền truy cập trong hệ thống.....	77
Bảng 3.3: Phân quyền truy cập theo vai trò trong hệ thống.....	82
Bảng 3.4: Quy tắc tiền tố mã giao dịch.....	84
Bảng 3.5: API Endpoints AuthController	87
Bảng 3.6: API Endpoints AccountController	87
Bảng 3.7: API Endpoints TransactionController	88
Bảng 3.8: API Endpoints CustomerController	89
Bảng 3.9: API Endpoints EmployeeController.....	90
Bảng 3.10: API Endpoints BranchController	91

Bảng 3.11: API Endpoints RegistrationRequestController	91
Bảng 3.12: API Endpoints SavedRecipientController.....	92
Bảng 3.13: Phạm vi kiểm thử theo phân hệ	93
Bảng 3.14: Các loại kiểm thử áp dụng.....	93
Bảng 3.15: Kiểm thử Module Đăng ký và Đăng nhập (Khách hàng)	97
Bảng 3.16: Kiểm thử Module Thông tin tài khoản và Số dư.....	99
Bảng 3.17: Kiểm thử Module Chuyển khoản	101
Bảng 3.18: Kiểm thử Module Danh bạ người nhận.....	103
Bảng 3.19: Kiểm thử Module Bảo mật (Khách hàng).....	104
Bảng 3.20: Kiểm thử Module Đăng nhập và Phân quyền (Nhân viên)	107
Bảng 3.21: Kiểm thử Module Xét duyệt hồ sơ	109
Bảng 3.22: Kiểm thử Module Nạp tiền.....	111
Bảng 3.23: Kiểm thử Module Rút tiền.....	113
Bảng 3.24: Kiểm thử Module Quản lý Khách hàng	115
Bảng 3.25: Kiểm thử Module Bảo mật (Nhân viên).....	116
Bảng 3.26: Kiểm thử Module Đăng nhập (Admin)	117
Bảng 3.27: Kiểm thử Module Dashboard	119
Bảng 3.28: Kiểm thử Module Quản lý Nhân viên	122
Bảng 3.29: Kiểm thử Module Ràng buộc cơ sở dữ liệu	124
Bảng 3.30: Kiểm thử Module Định dạng mã giao dịch.....	126

MỞ ĐẦU

1. Lý do chọn đề tài

Trong bối cảnh chuyển đổi số đang diễn ra mạnh mẽ, lĩnh vực ngân hàng là một trong những ngành đi đầu trong việc ứng dụng công nghệ thông tin nhằm nâng cao chất lượng dịch vụ và tối ưu hóa hoạt động quản lý. Các hệ thống quản lý ngân hàng hiện đại không chỉ giúp tự động hóa quy trình nghiệp vụ mà còn đảm bảo tính chính xác, bảo mật và hiệu quả trong xử lý dữ liệu.

Ngân hàng MB Bank là một trong những ngân hàng thương mại có tốc độ phát triển nhanh tại Việt Nam, với nhu cầu quản lý dữ liệu khách hàng, tài khoản, giao dịch ngày càng lớn. Vì vậy, việc xây dựng một hệ thống quản lý ngân hàng mô phỏng theo mô hình của MB Bank là cần thiết, giúp sinh viên hiểu rõ hơn về cách vận hành của hệ thống thực tế cũng như áp dụng kiến thức đã học vào thực tiễn.

Xuất phát từ những lý do trên, nhóm quyết định chọn đề tài: **“Xây dựng hệ thống quản lý ngân hàng MB Bank”**.

2. Mục tiêu nghiên cứu

Thiết kế và xây dựng một hệ thống quản lý ngân hàng hoàn chỉnh, mô phỏng theo mô hình hoạt động thực tế của MB Bank, nhằm giúp người thực hiện hiểu sâu về cách vận hành của hệ thống tài chính - ngân hàng và rèn luyện kỹ năng phát triển phần mềm theo quy trình chuyên nghiệp.

Mục tiêu cụ thể:

- Phân tích, mô hình hóa và xây dựng các chức năng nghiệp vụ cốt lõi của hệ thống ngân hàng, bao gồm: quản lý thông tin khách hàng, quản lý tài khoản, thực hiện giao dịch gửi tiền, rút tiền và chuyển khoản.

- Xây dựng hệ thống phân quyền theo vai trò (khách hàng, nhân viên ngân hàng, quản trị viên), đảm bảo bảo mật và kiểm soát truy cập chặt chẽ.

- Áp dụng kiến thức về phân tích thiết kế hệ thống thông tin (UML, mô hình hóa cơ sở dữ liệu) vào bài toán thực tế.

- Kiểm thử hệ thống đầy đủ theo từng module chức năng, đảm bảo tính ổn định và nhất quán dữ liệu.

- Nâng cao kỹ năng lập trình, tư duy giải quyết vấn đề và khả năng làm việc nhóm theo quy trình phát triển phần mềm thực tế.

3. Đối tượng nghiên cứu

Đối tượng nghiên cứu của đề tài là các nghiệp vụ cơ bản trong hệ thống ngân hàng thương mại, bao gồm: quy trình quản lý thông tin khách hàng; quy trình quản lý tài khoản thanh toán; và quy trình xử lý giao dịch tài chính. Ngoài ra, đề tài còn nghiên cứu các mô hình thiết kế hệ thống phần mềm phù hợp với bài toán quản lý dữ liệu ngân hàng.

4. Phạm vi nghiên cứu

Hệ thống tập trung xây dựng ba phân hệ chức năng chính:

(1) Phân hệ dành cho khách hàng (đăng nhập, xem số dư, chuyển khoản trực tuyến, tra cứu lịch sử giao dịch);

(2) Phân hệ dành cho nhân viên ngân hàng (nạp/rút tiền tại quầy, xét duyệt hồ sơ, quản lý tài khoản khách hàng);

(3) Phân hệ quản trị hệ thống (dashboard tổng quan, quản lý nhân viên và phân quyền).

Các tính năng nâng cao như tích hợp thanh toán thẻ tín dụng, vay vốn hay giao dịch ngoại hối nằm ngoài phạm vi đề tài này.

5. Phương pháp nghiên cứu

Đề tài được thực hiện kết hợp nhiều phương pháp nghiên cứu, cụ thể:

- Nghiên cứu lý thuyết: Tổng hợp kiến thức từ tài liệu học thuật và tài liệu kỹ thuật liên quan đến thiết kế hệ thống ngân hàng, kiến trúc phần mềm và bảo mật dữ liệu. Phương pháp này cung cấp nền tảng lý luận để xác định yêu cầu và lựa chọn giải pháp kỹ thuật phù hợp.

- Phân tích và thiết kế hệ thống: Sử dụng ngôn ngữ mô hình hóa UML (Use Case, Activity, Sequence, Class Diagram) để đặc tả yêu cầu và thiết kế kiến trúc hệ thống trước khi bước vào lập trình. Phương pháp này giúp chuẩn hóa quá trình phát triển và giảm thiểu rủi ro thiếu sót chức năng.

- Lập trình thực nghiệm: Triển khai hệ thống theo phương pháp phát triển lặp (iterative), trong đó mỗi vòng lặp tập trung hoàn thiện một module chức năng. Cách tiếp cận này cho phép phát hiện và xử lý lỗi sớm, đồng thời dễ dàng điều chỉnh theo yêu cầu thực tế.

- Kiểm thử chương trình: Áp dụng kiểm thử theo module (unit testing) và kiểm thử tích hợp (integration testing) để đánh giá tính đúng đắn của từng chức năng. Kết quả kiểm thử được tổng hợp trong các bảng test case có ghi nhận đầu vào, đầu ra kỳ vọng và kết quả thực tế.

6. Kết quả mong muốn của đề tài

Đề tài hướng tới việc xây dựng một hệ thống quản lý ngân hàng cơ bản có thể đáp ứng các chức năng chính như quản lý khách hàng, quản lý tài khoản và thực hiện các giao dịch như gửi tiền, rút tiền, chuyển khoản.

Kết quả mong muốn là hệ thống có thể hoạt động ổn định, xử lý chính xác các nghiệp vụ cơ bản của ngân hàng và đảm bảo tính nhất quán của dữ liệu. Ngoài ra, hệ thống cần có giao diện đơn giản, dễ sử dụng, phù hợp với người dùng.

Bên cạnh đó, đề tài cũng hướng tới việc giúp người thực hiện nắm vững quy trình phân tích, thiết kế và xây dựng một hệ thống phần mềm, từ đó nâng cao kỹ năng lập trình, tư duy logic và khả năng làm việc nhóm.

7. Cấu trúc báo cáo

Báo cáo gồm ba chương chính như sau:

- **Chương 1:** Tổng quan về Ngân hàng MB Bank và hệ thống quản lý ngân hàng. Chương này giới thiệu lịch sử hình thành và phát triển của MB Bank, phân tích mô hình hoạt động và các dịch vụ chủ yếu của ngân hàng. Đồng thời, chương trình bày tổng quan về yêu cầu hệ thống phần mềm trong lĩnh vực ngân hàng, làm cơ sở cho các chương tiếp theo.

- **Chương 2:** Phân tích và thiết kế hệ thống quản lý Ngân hàng MB Bank. Chương này trình bày đầy đủ kết quả phân tích yêu cầu (use case, actor), thiết kế hành vi hệ thống (activity diagram, sequence diagram), thiết kế cấu trúc (class diagram, mô hình cơ sở dữ liệu) và thiết kế giao diện người dùng cho từng phân hệ.

- **Chương 3:** Xây dựng và kiểm thử hệ thống. Chương này mô tả quá trình lập trình, cấu trúc mã nguồn, kỹ thuật triển khai các chức năng chính và kết quả kiểm thử từng module. Qua đó đánh giá mức độ đáp ứng yêu cầu của hệ thống so với mục tiêu đề ra ban đầu.

CHƯƠNG 1: TỔNG QUAN VỀ NGÂN HÀNG MB BANK VÀ HỆ THỐNG QUẢN LÝ NGÂN HÀNG

1.1 Giới thiệu tổng quan về MBBank

Ngân hàng Thương mại Cổ phần Quân đội (MB Bank) là một trong những ngân hàng thương mại cổ phần hàng đầu tại Việt Nam, hoạt động trong lĩnh vực tài chính - ngân hàng với quy mô lớn và uy tín cao. Sau hơn 30 năm hình thành và phát triển, MB Bank đã khẳng định vị thế của mình trong hệ thống tài chính Việt Nam với mạng lưới chi nhánh rộng khắp cả nước và nhiều quốc gia.

1.1.1 Quá trình hình thành và phát triển

MB Bank được thành lập vào năm 1994, ban đầu phục vụ chủ yếu cho các đơn vị quân đội. Trải qua nhiều giai đoạn phát triển, ngân hàng đã từng bước mở rộng quy mô, đa dạng hóa dịch vụ và khẳng định vị thế trên thị trường tài chính. Dưới đây là các cột mốc quan trọng trong lịch sử phát triển của MB Bank:

- 04/11/1994: Thành lập Ngân hàng TMCP Quân đội với vốn điều lệ ban đầu khoảng 20 tỷ đồng, trụ sở chính đặt tại Hà Nội.

- 2004: Kỷ niệm 10 năm thành lập, MB phát hành cổ phần qua đấu giá công khai lần đầu tiên. Tổng tài sản tăng trưởng mạnh, đạt hàng nghìn tỷ đồng.

- 2008: Tái cơ cấu tổ chức theo mô hình tập đoàn tài chính; Tập đoàn Viettel chính thức trở thành cổ đông chiến lược.

- 2009: Ra mắt Trung tâm Dịch vụ Khách hàng hoạt động 24/7, đánh dấu bước tiến trong việc nâng cao chất lượng dịch vụ.

- 2011: MB niêm yết cổ phiếu trên Sở Giao dịch Chứng khoán TP. Hồ Chí Minh (HOSE) ngày 01/11/2011 và mở rộng ra thị trường quốc tế với chi nhánh tại Campuchia.

- 2015: Được Nhà nước trao tặng danh hiệu Anh hùng Lao động thời kỳ đổi mới.

- 2016: Thành lập công ty bảo hiểm nhân thọ MB Ageas Life và công ty tài chính tiêu dùng Mcredit, mở rộng hệ sinh thái tài chính.

- 2024: Kỷ niệm 30 năm thành lập; được trao tặng Huân chương Bảo vệ Tổ quốc hạng Nhất. Tổng tài sản vượt mốc 1 triệu tỷ đồng.

1.1.2 Cơ cấu tổ chức của ngân hàng

MB Bank tổ chức theo mô hình tập đoàn tài chính đa ngành. Ở cấp cao nhất là Hội đồng Quản trị (HĐQT) và Ban Kiểm soát; người đứng đầu quản lý điều hành là Tổng Giám đốc (CEO). Dưới Ban Lãnh đạo gồm nhiều khối/phòng ban chuyên môn, có thể chia thành hai nhóm chính:

- Khối kinh doanh: gồm các Ban/Khối Kinh doanh bán lẻ, Kinh doanh doanh nghiệp và Đối tác chiến lược, Ngân hàng quốc tế (MB Cambodia, OceanBank), Thanh toán và Dịch vụ thẻ, Ngân hàng số và Công nghệ thông tin. Các khối này chịu trách nhiệm phát triển sản phẩm và dịch vụ phục vụ khách hàng cá nhân và tổ chức.

- Khối chức năng: gồm các Ban/Khối Hỗ trợ (Tài chính – Kế toán, Nhân sự, Quản trị nguồn vốn, Pháp chế, Chiến lược, Marketing...), Ban Quản lý rủi ro & Tuân thủ, Ban Kiểm toán nội bộ, Ban Công nghệ và Hệ thống, v.v. Các đơn vị này đảm bảo hoạt động ngân hàng tuân thủ quy định, quản lý tài chính nội bộ và hỗ trợ vận hành hiệu quả.

1.2 Các dịch vụ chính của ngân hàng

1.2.1 Quản lý tài khoản khách hàng

Quản lý tài khoản khách hàng là nền tảng cốt lõi của mọi hệ thống ngân hàng. Dịch vụ này không chỉ đơn thuần lưu trữ thông tin cá nhân mà còn đóng vai trò là trung tâm liên kết tất cả các nghiệp vụ khác như giao dịch, vay vốn hay thanh toán.

Về mặt nghiệp vụ, khách hàng tự đăng ký tài khoản thông qua hệ thống trực tuyến và được duyệt bởi nhân viên ngân hàng chi nhánh. Mỗi khách hàng được định danh duy nhất thông qua mã CCCD. Hệ thống hiện tại sử dụng số điện thoại của khách hàng làm số tài khoản duy nhất (tài khoản thanh toán), giúp khách hàng dễ dàng nhớ và tiện lợi khi sử dụng.

Về mặt hệ thống, chức năng này cần đảm bảo:

- Tính toàn vẹn dữ liệu (không trùng lặp, không sai lệch thông tin)
- Khả năng tra cứu nhanh khi số lượng khách hàng lớn.
- Hỗ trợ cập nhật linh hoạt nhưng vẫn đảm bảo lịch sử thay đổi

Ngoài ra, hệ thống cũng cần quản lý trạng thái tài khoản (hoạt động, khóa, đóng) để phục vụ kiểm soát rủi ro.

1.2.2 Dịch vụ gửi tiền và rút tiền

Gửi tiền và rút tiền là nghiệp vụ cơ bản nhưng có tần suất sử dụng cao nhất trong hệ thống ngân hàng. Đây là các giao dịch trực tiếp làm thay đổi số dư tài khoản, do đó yêu cầu độ chính xác và an toàn rất cao.

Về bản chất, mỗi giao dịch gửi hoặc rút tiền đều là một thao tác cập nhật số dư tài khoản. Tuy nhiên, trong hệ thống thực tế, các thao tác này cần được xử lý theo cơ chế giao dịch (transaction) nhằm đảm bảo các tính chất như:

- Tính nguyên tử (Atomicity): Giao dịch phải thực hiện hoàn toàn hoặc không thực hiện.

- Tính nhất quán (Consistency): Số dư luôn đúng trước và sau giao dịch.

- Tính cô lập (Isolation): Các giao dịch đồng thời không gây xung đột.

- Tính bền vững (Durability): Dữ liệu không bị mất khi có sự cố.

Ngoài ra, hệ thống cần lưu lại lịch sử giao dịch để phục vụ kiểm tra và truy vết khi cần thiết.

1.2.3 Dịch vụ chuyển khoản

Chuyển khoản là một trong những dịch vụ quan trọng nhất, phản ánh mức độ hiện đại của hệ thống ngân hàng. Dịch vụ này cho phép chuyển tiền giữa các tài khoản trong cùng hệ thống hoặc liên ngân hàng.

Về mặt nghiệp vụ, chuyển khoản bao gồm hai thao tác đồng thời:

- Trừ tiền từ tài khoản nguồn
- Cộng tiền vào tài khoản đích

Điều này đòi hỏi hệ thống phải đảm bảo tính đồng bộ và chính xác tuyệt đối, tránh các trường hợp mất tiền hoặc sai lệch dữ liệu.

Đối với hệ thống quản lý, cần xử lý các vấn đề như:

- Kiểm tra số dư trước khi thực hiện giao dịch
- Xác thực thông tin người dùng (mật khẩu, OTP,...)
- Ghi nhận chi tiết giao dịch (thời gian, số tiền, nội dung)

Ngoài ra, đối với chuyển khoản liên ngân hàng, hệ thống còn cần tích hợp với các hệ thống trung gian, làm tăng độ phức tạp trong xử lý.

1.2.4 Dịch vụ cho vay

Dịch vụ cho vay là một trong những nguồn lợi nhuận chính của ngân hàng. Khác với các dịch vụ giao dịch thông thường, cho vay là một nghiệp vụ dài hạn và có mức độ rủi ro cao.

Về mặt nghiệp vụ, hệ thống cần quản lý các thông tin như:

- Số tiền vay
- Lãi suất
- Thời hạn vay
- Lịch trả nợ

Đặc biệt, hệ thống phải hỗ trợ tính toán lãi suất theo nhiều phương thức khác nhau (lãi đơn, lãi kép, dư nợ giảm dần). Điều này đòi hỏi các thuật toán tính toán chính xác và linh hoạt.

Ngoài ra, hệ thống cũng cần theo dõi trạng thái khoản vay (đang vay, quá hạn, đã tắt toán) để hỗ trợ quản lý rủi ro và nhắc nhở khách hàng.

1.2.5 Dịch vụ ngân hàng điện tử

Ngân hàng điện tử là xu hướng tất yếu trong thời đại số, cho phép khách hàng thực hiện giao dịch mà không cần đến trực tiếp ngân hàng.

Các dịch vụ phổ biến bao gồm Internet Banking và Mobile Banking, hỗ trợ các chức năng như kiểm tra số dư, chuyển khoản, thanh toán hóa đơn.

Về mặt hệ thống, đây là dịch vụ yêu cầu cao nhất về:

- Bảo mật: mã hóa dữ liệu, xác thực nhiều lớp (OTP, sinh trắc học)

- Hiệu năng: xử lý nhanh, đáp ứng lượng truy cập lớn
- Trải nghiệm người dùng: giao diện thân thiện, dễ sử dụng

Ngoài ra, hệ thống còn phải đảm bảo hoạt động liên tục 24/7 và có khả năng mở rộng khi số lượng người dùng tăng.

1.3 Tổng quan về hệ thống quản lý ngân hàng

Hệ thống quản lý ngân hàng là một trong những thành phần cốt lõi trong hoạt động của các tổ chức tài chính hiện đại. Với sự phát triển mạnh mẽ của công nghệ thông tin, các hệ thống này không chỉ giúp tự động hóa các nghiệp vụ truyền thống mà còn nâng cao hiệu quả quản lý, tăng cường bảo mật và cải thiện trải nghiệm khách hàng.

Trong bối cảnh chuyển đổi số, hệ thống quản lý ngân hàng đóng vai trò trung tâm trong việc kết nối các hoạt động nghiệp vụ như quản lý tài khoản, giao dịch, khách hàng và dữ liệu tài chính.

1.3.1 Khái niệm hệ thống quản lý ngân hàng

Hệ thống quản lý ngân hàng (Bank Management System) là một hệ thống phần mềm được xây dựng nhằm hỗ trợ và tự động hóa các hoạt động nghiệp vụ trong ngân hàng.

Hệ thống này cho phép quản lý toàn bộ thông tin liên quan đến:

- Khách hàng
- Tài khoản ngân hàng
- Giao dịch tài chính
- Nhân viên và hoạt động nội bộ

Thông qua hệ thống quản lý ngân hàng, các nghiệp vụ như mở tài khoản, gửi tiền, rút tiền, chuyển khoản và kiểm tra số dư được thực hiện một cách nhanh chóng và chính xác.

Ngoài ra, hệ thống còn hỗ trợ lưu trữ và xử lý dữ liệu lớn, đảm bảo tính toàn vẹn, chính xác và bảo mật của thông tin tài chính.

1.3.2 Vai trò của hệ thống quản lý trong ngân hàng

Hệ thống quản lý ngân hàng đóng vai trò cực kỳ quan trọng trong hoạt động của ngân hàng, cụ thể:

- **Tự động hóa quy trình nghiệp vụ:** Hệ thống giúp tự động hóa các quy trình như xử lý giao dịch, quản lý tài khoản, từ đó giảm thiểu sai sót do con người và tăng tốc độ xử lý.

- **Quản lý dữ liệu tập trung:** Tất cả thông tin khách hàng và giao dịch được lưu trữ tập trung, giúp dễ dàng truy xuất, quản lý và phân tích dữ liệu.

- **Nâng cao hiệu quả hoạt động:** Nhờ hệ thống phần mềm, ngân hàng có thể xử lý số lượng lớn giao dịch trong thời gian ngắn, tiết kiệm chi phí và nguồn lực.

- **Tăng cường bảo mật:** Hệ thống tích hợp các cơ chế bảo mật như xác thực người dùng, mã hóa dữ liệu, giúp bảo vệ thông tin khách hàng và tài sản ngân hàng.

- **Hỗ trợ ra quyết định:** Dữ liệu từ hệ thống giúp ban lãnh đạo phân tích và đưa ra các quyết định kinh doanh chính xác hơn.

1.3.3 Các chức năng chính của hệ thống ngân hàng

Một hệ thống quản lý ngân hàng thường bao gồm các chức năng chính sau:

- Quản lý khách hàng

- + Lưu trữ thông tin cá nhân khách hàng
- + Tìm kiếm và cập nhật thông tin
- + Phân loại khách hàng

- Quản lý tài khoản

- + Duyệt yêu cầu mở tài khoản trực tuyến
- + Đóng tài khoản
- + Theo dõi trạng thái tài khoản

- Quản lý giao dịch

- + Gửi tiền
- + Rút tiền
- + Chuyển khoản
- + Ghi nhận lịch sử giao dịch

- Quản lý nhân viên

- + Quản lý thông tin nhân viên
- + Phân quyền truy cập
- + Theo dõi hoạt động của nhân viên

- Báo cáo và thống kê

- + Báo cáo giao dịch
- + Báo cáo tài chính
- + Thống kê hoạt động hệ thống

1.3.4 Các công nghệ sử dụng trong hệ thống ngân hàng hiện đại

Trong các hệ thống ngân hàng hiện đại, nhiều công nghệ tiên tiến được áp dụng nhằm đảm bảo hiệu năng, bảo mật và khả năng mở rộng.

Core Banking System: Là hệ thống cốt lõi xử lý tất cả các giao dịch ngân hàng theo thời gian thực. Core Banking cho phép khách hàng thực hiện giao dịch tại bất kỳ chi nhánh nào.

Hệ quản trị cơ sở dữ liệu (Database Management System): Các hệ thống như MySQL, Oracle, SQL Server được sử dụng để lưu trữ và quản lý dữ liệu lớn của ngân hàng.

Công nghệ Web và Mobile:

- Web Application: cho phép truy cập qua trình duyệt
- Mobile Banking: ứng dụng trên điện thoại

Công nghệ bảo mật:

- Mã hóa dữ liệu (Encryption)
- Xác thực đa yếu tố (MFA)
- SSL/TLS bảo mật truyền dữ liệu

Điện toán đám mây (Cloud Computing): Giúp hệ thống linh hoạt, dễ mở rộng và tiết kiệm chi phí hạ tầng.

Trí tuệ nhân tạo (AI) và Big Data:

- Phân tích hành vi khách hàng
- Phát hiện gian lận
- Tối ưu dịch vụ

1.4 Các hệ thống ngân hàng điện tử hiện nay

1.4.1 Internet Banking

Internet Banking là dịch vụ ngân hàng trực tuyến được cung cấp qua nền tảng web, cho phép khách hàng thực hiện các giao dịch tài chính mà không cần đến trực tiếp chi nhánh. Khách hàng có thể truy cập dịch vụ thông qua bất kỳ thiết bị nào có kết nối Internet như máy tính, laptop hay máy tính bảng.

Các chức năng phổ biến của Internet Banking bao gồm: kiểm tra số dư và lịch sử giao dịch, chuyển khoản nội bộ và liên ngân hàng, thanh toán hóa đơn (điện, nước, viễn thông), mua sắm trực tuyến, gửi tiết kiệm và theo dõi khoản vay. Về bảo mật, Internet Banking thường áp dụng xác thực hai lớp với mật khẩu đăng nhập kết hợp mã OTP qua SMS hoặc ứng dụng xác thực.

1.4.2 Mobile Banking

Mobile Banking là ứng dụng ngân hàng chuyên biệt được thiết kế và tối ưu hóa cho thiết bị di động (điện thoại thông minh, máy tính bảng). Ví dụ điển hình là ứng dụng MB Bank hiện đang phục vụ hàng chục triệu khách hàng tại Việt Nam.

So với Internet Banking, Mobile Banking có ưu điểm vượt trội nhờ tích hợp các công nghệ di động hiện đại như:

- Quét mã QR để thanh toán nhanh chóng tại điểm bán hàng.
- Thanh toán không chạm (NFC) qua ví điện tử tích hợp.
- Xác thực sinh trắc học bằng vân tay (Touch ID) hoặc nhận diện khuôn mặt (Face ID), tăng bảo mật mà vẫn tiện lợi.
- Nhận thông báo đẩy (push notification) tức thì khi có biến động tài khoản.
- Hoạt động 24/7, kể cả ngoài giờ làm việc của ngân hàng.

1.4.3 Core Banking

Core Banking (Hệ thống ngân hàng lõi) là hệ thống phần mềm trung tâm xử lý, ghi nhận và lưu trữ toàn bộ dữ liệu nghiệp vụ của ngân hàng theo thời gian thực. Core Banking là nền tảng kết nối mọi kênh giao dịch từ quầy giao dịch tại chi nhánh, ATM, Internet Banking đến Mobile Banking thành một hệ sinh thái thống nhất.

Các đặc điểm cốt lõi của Core Banking bao gồm:

- Xử lý giao dịch theo thời gian thực (real-time processing): số dư và thông tin tài khoản được cập nhật tức thì sau mỗi giao dịch.
- Tính sẵn sàng cao (high availability): hệ thống hoạt động liên tục 24/7/365 với thời gian dừng (downtime) gần như bằng 0.
- Khả năng mở rộng (scalability): đáp ứng được khối lượng giao dịch lớn khi số lượng khách hàng tăng trưởng.
- Đồng bộ hóa dữ liệu: đảm bảo dữ liệu nhất quán trên toàn bộ mạng lưới chi nhánh và kênh giao dịch điện tử.

1.4.4 Công nghệ bảo mật ngân hàng

Là hệ thống các giải pháp kỹ thuật nhằm bảo vệ dữ liệu và phòng chống gian lận. Các công nghệ cốt lõi bao gồm:

- Mã hóa dữ liệu đường truyền (SSL/TLS).
- Xác thực đa yếu tố và xác thực giao dịch (OTP, Smart OTP).
- Hệ thống tường lửa (Firewall) và chống xâm nhập.
- Ứng dụng AI để theo dõi, phát hiện và ngăn chặn các giao dịch bất thường.

CHƯƠNG 2: KHẢO SÁT, PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG QUẢN LÝ NGÂN HÀNG MB BANK

2.1 Khảo sát hệ thống

2.1.1 Mục tiêu khảo sát

Trước khi tiến hành phân tích và thiết kế hệ thống, nhóm thực hiện giai đoạn khảo sát nhằm thu thập thông tin thực tế về nghiệp vụ ngân hàng, từ đó xác định rõ các yêu cầu cần đáp ứng và những vấn đề tồn tại trong quy trình quản lý hiện tại. Mục tiêu cụ thể của khảo sát bao gồm:

- Tìm hiểu quy trình nghiệp vụ thực tế tại ngân hàng MB Bank.
- Xác định các đối tượng người dùng và nhu cầu sử dụng hệ thống của từng đối tượng.
- Thu thập dữ liệu làm cơ sở xây dựng các yêu cầu chức năng và phi chức năng cho hệ thống.

2.1.2 Phương pháp khảo sát

Nhóm sử dụng kết hợp nhiều phương pháp khảo sát để đảm bảo tính đầy đủ và khách quan của thông tin thu thập được:

- Nghiên cứu tài liệu: Nhóm thu thập và nghiên cứu các tài liệu liên quan đến quy trình nghiệp vụ ngân hàng, bao gồm: quy trình mở tài khoản thanh toán, quy định về giao dịch tiền gửi và rút tiền, tài liệu hướng dẫn sử dụng ứng dụng MB Bank và các quy định của Ngân hàng Nhà nước về quản lý tài khoản khách hàng.
- Quan sát thực tế: Nhóm trực tiếp quan sát quy trình giao dịch tại quầy và trải nghiệm ứng dụng MB Bank để nắm bắt luồng nghiệp vụ thực tế, cách hệ thống hiển thị thông tin và các bước xác thực người dùng.

- Phân tích hệ thống tương đương: Nhóm tham khảo và phân tích các hệ thống quản lý ngân hàng tương tự như Vietcombank, Techcombank để đúc rút các đặc điểm chung.

2.1.3 Kết quả khảo sát

Quy trình nghiệp vụ hiện tại

Qua quá trình khảo sát, nhóm ghi nhận các đặc điểm chính trong quy trình vận hành nghiệp vụ của ngân hàng MB Bank như sau:

- Quy trình mở tài khoản: Khách hàng có thể đăng ký mở tài khoản trực tuyến thông qua ứng dụng MB Bank hoặc trực tiếp tại quầy giao dịch. Đối với đăng ký trực tuyến, hồ sơ của khách hàng được lưu ở trạng thái chờ duyệt (Pending) và chỉ được kích hoạt sau khi nhân viên ngân hàng tại chi nhánh xác minh danh tính (KYC). Số tài khoản thanh toán được gán tự động theo số điện thoại của khách hàng, giúp dễ nhớ và tiện lợi trong sử dụng.

- Quy trình giao dịch tại quầy: Các giao dịch nạp tiền và rút tiền được thực hiện trực tiếp thông qua nhân viên ngân hàng. Nhân viên tra cứu thông tin tài khoản, kiểm tra số dư, thực hiện giao dịch và in biên lai xác nhận cho khách hàng. Mỗi giao dịch được lưu lại đầy đủ trong hệ thống kèm theo thông tin nhân viên thực hiện.

- Quy trình chuyển khoản trực tuyến: Khách hàng tự thực hiện chuyển khoản thông qua Internet Banking hoặc Mobile Banking. Hệ thống yêu cầu xác thực danh tính trước khi xử lý, đồng thời kiểm tra số dư và tính hợp lệ của tài khoản đích trước khi thực hiện giao dịch.

- Phân quyền người dùng: Hệ thống hiện tại phân chia rõ ràng ba nhóm người dùng chính: Khách hàng, nhân viên ngân hàng và quản trị

hệ thống với quyền hạn và phạm vi truy cập khác nhau. Nhân viên chỉ được phép thao tác trên dữ liệu thuộc chi nhánh mình phụ trách.

2.2 Phân tích yêu cầu hệ thống

Dựa trên kết quả khảo sát ở mục 2.1, nhóm tiến hành phân tích yêu cầu hệ thống nhằm cụ thể hóa các nhu cầu đã thu thập thành các yêu cầu kỹ thuật rõ ràng.

2.2.1 Đối tượng sử dụng hệ thống

Hệ thống quản lý ngân hàng MB Bank được thiết kế phục vụ cho nhiều đối tượng khác nhau, mỗi đối tượng có vai trò và quyền hạn riêng trong hệ thống. Các đối tượng sử dụng chính bao gồm:

- **Nhân viên ngân hàng:** là người trực tiếp sử dụng hệ thống để thực hiện các nghiệp vụ hằng ngày. Các chức năng mà nhân viên ngân hàng có thể thực hiện bao gồm:

- + Quản lý thông tin khách hàng
- + Duyệt yêu cầu đăng ký mở tài khoản
- + Thực hiện giao dịch gửi tiền, rút tiền
- + Tra cứu thông tin khách hàng và tài khoản
- + Cập nhật thông tin khách hàng

- Nhân viên ngân hàng đóng vai trò quan trọng trong việc đảm bảo hệ thống hoạt động chính xác và phục vụ khách hàng hiệu quả.

- **Quản trị hệ thống:** là người chịu trách nhiệm quản lý toàn bộ hệ thống ngân hàng. Người quản trị có quyền cao nhất trong hệ thống và thực hiện các chức năng như:

- + Quản lý tài khoản nhân viên

- + Phân quyền người dùng
- + Quản lý dữ liệu hệ thống
- + Theo dõi hoạt động của hệ thống
- + Sao lưu và phục hồi dữ liệu
- Quản trị hệ thống đảm bảo hệ thống hoạt động ổn định và an toàn.

- **Khách hàng:** là đối tượng sử dụng dịch vụ ngân hàng. Khách hàng có thể thực hiện các chức năng như:

- + Xem thông tin tài khoản
- + Thực hiện giao dịch chuyển khoản
- + Gửi tiền và rút tiền
- + Xem lịch sử giao dịch
- + Sử dụng các dịch vụ ngân hàng điện tử
- Khách hàng là đối tượng trung tâm của hệ thống, do đó hệ thống cần đảm bảo dễ sử dụng và an toàn.

2.2.2 Yêu cầu chức năng của hệ thống

Yêu cầu chức năng mô tả các chức năng mà hệ thống cần thực hiện để đáp ứng nhu cầu của người sử dụng. Hệ thống quản lý ngân hàng MB Bank bao gồm các chức năng chính sau:

Chức năng quản lý khách hàng: Chức năng này cho phép lưu trữ và quản lý thông tin khách hàng. Các chức năng bao gồm:

- Thêm khách hàng mới
- Cập nhật thông tin khách hàng

- Khóa/ mở khóa khách hàng
- Tìm kiếm khách hàng
- Xem danh sách khách hàng

=> Chức năng này giúp ngân hàng quản lý thông tin khách hàng một cách hiệu quả.

Chức năng quản lý tài khoản: Cho phép ngân hàng quản lý các tài khoản của khách hàng. Các chức năng bao gồm:

- Cấp số tài khoản tự động (theo số điện thoại) khi duyệt đăng ký
- Đóng tài khoản
- Cập nhật thông tin tài khoản
- Xem thông tin tài khoản
- Tra cứu tài khoản

=> Chức năng này giúp kiểm soát các tài khoản và đảm bảo tính chính xác của dữ liệu.

Quản lý giao dịch: Chức năng quản lý giao dịch cho phép thực hiện các nghiệp vụ tài chính như:

- Gửi tiền
- Rút tiền
- Chuyển khoản
- Tra cứu lịch sử giao dịch

=> Hệ thống cần đảm bảo các giao dịch được thực hiện chính xác và an toàn.

Quản lý nhân viên: Giúp quản lý thông tin nhân viên ngân hàng. Các chức năng bao gồm:

- Thêm nhân viên mới
- Cập nhật thông tin nhân viên
- Khóa/ mở khóa tài khoản nhân viên
- Phân quyền nhân viên

=> Chức năng này giúp quản lý nhân viên và đảm bảo phân quyền hợp lý.

2.2.3 Yêu cầu phi chức năng

Ngoài các yêu cầu chức năng, hệ thống còn cần đáp ứng các yêu cầu phi chức năng để đảm bảo hoạt động hiệu quả.

Bảo mật dữ liệu: Hệ thống cần đảm bảo tính bảo mật thông tin khách hàng và dữ liệu giao dịch. Các biện pháp bảo mật bao gồm:

- Xác thực người dùng
- Phân quyền truy cập
- Mã hóa dữ liệu

Hiệu năng hệ thống: Hệ thống cần đảm bảo tốc độ xử lý nhanh và ổn định khi có nhiều người sử dụng. Ngoài ra, hệ thống phải đảm bảo hoạt động liên tục và hạn chế lỗi xảy ra.

Khả năng mở rộng: Hệ thống cần có khả năng mở rộng trong tương lai khi số lượng khách hàng tăng lên. Điều này giúp hệ thống có thể phát triển và nâng cấp dễ dàng.

2.3 Mô hình nghiệp vụ của hệ thống

2.3.1 Quy trình mở tài khoản

Quy trình mở tài khoản trong hệ thống ngân hàng được thực hiện theo các bước tuần tự như sau:

- Bước 1: Đăng ký trực tuyến

Khách hàng truy cập trang đăng ký và nhập thông tin (CCCD, họ tên, số điện thoại, chi nhánh...).

- Bước 2: Khởi tạo yêu cầu (Pending)

Hệ thống lưu trữ yêu cầu mở tài khoản ở trạng thái chờ duyệt.

- Bước 3: Nhân viên xét duyệt

Nhân viên ngân hàng xem xét hồ sơ yêu cầu của khách hàng theo chi nhánh quản lý.

- Bước 4: Duyệt và tạo tài khoản

Nhân viên thực hiện duyệt yêu cầu. Hệ thống tự động khởi tạo tài khoản, lấy số điện thoại làm số tài khoản.

- Bước 5: Thông báo kết quả

Hệ thống hiển thị kết quả cấp tài khoản thành công để khách hàng có thể đăng nhập.

2.3.2 Quy trình giao dịch tiền gửi và rút

Quy trình giao dịch tiền gửi và rút tiền là một trong những nghiệp vụ cơ bản và quan trọng của hệ thống quản lý ngân hàng. Quy trình này giúp đảm bảo các giao dịch được thực hiện chính xác, an toàn và cập nhật kịp thời vào hệ thống.

Quy trình gửi tiền:

- Bước 1: Khách hàng cung cấp thông tin tài khoản cần gửi tiền cho nhân viên ngân hàng hoặc thực hiện thông qua hệ thống ngân hàng điện tử.

- **Bước 2:** Nhân viên ngân hàng hoặc hệ thống kiểm tra thông tin tài khoản của khách hàng trong cơ sở dữ liệu.

- **Bước 3:** Khách hàng cung cấp số tiền cần gửi vào tài khoản.

- **Bước 4:** Hệ thống kiểm tra tính hợp lệ của giao dịch và tiến hành cập nhật số dư tài khoản.

- **Bước 5:** Hệ thống lưu lại thông tin giao dịch vào cơ sở dữ liệu, bao gồm thời gian, số tiền gửi và thông tin tài khoản.

- **Bước 6:** Hệ thống thông báo giao dịch thành công và in biên lai hoặc hiển thị thông báo cho khách hàng.

Quy trình rút tiền:

- **Bước 1:** Khách hàng cung cấp thông tin tài khoản và yêu cầu rút tiền.

- **Bước 2:** Hệ thống kiểm tra thông tin tài khoản và xác thực khách hàng.

- **Bước 3:** Hệ thống kiểm tra số dư tài khoản có đủ để thực hiện giao dịch hay không.

- **Bước 4:** Nếu số dư đủ, hệ thống tiến hành trừ số tiền rút khỏi tài khoản.

- **Bước 5:** Hệ thống lưu lại thông tin giao dịch vào cơ sở dữ liệu.

- **Bước 6:** Nhân viên ngân hàng hoặc hệ thống thực hiện giao tiền cho khách hàng và thông báo giao dịch thành công. Trong trường hợp số dư không đủ, hệ thống sẽ thông báo lỗi và không thực hiện giao dịch.

Để đảm bảo quy trình gửi tiền và rút tiền hoạt động hiệu quả, hệ thống cần đáp ứng các yêu cầu sau:

- Đảm bảo tính chính xác của số dư tài khoản

- Lưu trữ đầy đủ lịch sử giao dịch

- Đảm bảo tính bảo mật thông tin khách hàng

- Hệ thống hoạt động ổn định và nhanh chóng

Quy trình giao dịch gửi tiền và rút tiền là nền tảng cho các dịch vụ ngân hàng khác và đóng vai trò quan trọng trong hệ thống quản lý ngân hàng.

2.3.3. Quy trình chuyển tiền

Quy trình chuyển tiền trong hệ thống ngân hàng được mô tả như sau:

- **Bước 1:** Khởi tạo giao dịch. Khách hàng đăng nhập vào hệ thống và nhập các thông tin cần thiết như số tài khoản người nhận, số tiền chuyển và nội dung giao dịch.

- **Bước 2:** Kiểm tra thông tin. Hệ thống tiến hành kiểm tra tính hợp lệ của giao dịch, bao gồm:

- + Số dư tài khoản người gửi
- + Sự tồn tại của tài khoản người nhận
- + Hạn mức giao dịch

- **Bước 3:** Xác thực giao dịch. Khách hàng xác nhận giao dịch thông qua các phương thức bảo mật như mã OTP hoặc xác thực hai yếu tố.

- **Bước 4:** Xử lý giao dịch. Sau khi xác thực thành công, hệ thống thực hiện:

- + Trừ tiền từ tài khoản người gửi
- + Cộng tiền vào tài khoản người nhận

- **Bước 5:** Lưu trữ và thông báo. Hệ thống lưu lại thông tin giao dịch vào cơ sở dữ liệu và gửi thông báo xác nhận đến các bên liên quan.

2.3.4 Quy trình quản lý ngân hàng

Quy trình quản lý ngân hàng tập trung vào việc điều hành các hoạt động nội bộ, quản trị nhân sự và giám sát dữ liệu để đảm bảo hệ thống vận hành ổn định, minh bạch. Quy trình này bao gồm các bước chính sau:

- **Bước 1:** Quản lý và phân quyền nhân viên

- + Admin tiến hành cập nhật và lưu trữ thông tin hồ sơ của nhân viên ngân hàng vào hệ thống.

- + Hệ thống thực hiện phân quyền truy cập chi tiết cho từng nhân viên để đảm bảo bảo mật và đúng trách nhiệm nghiệp vụ.

- Bước 2: Giám sát hoạt động nghiệp vụ

- + Hệ thống tự động ghi lại toàn bộ nhật ký thao tác và hoạt động của nhân viên trong quá trình xử lý giao dịch cho khách hàng.

- + Quản trị viên theo dõi tiến độ và kiểm tra tính hợp lệ của các hoạt động nội bộ để kịp thời phát hiện các sai sót hoặc hành vi bất thường.

- Bước 3: Tổng hợp báo cáo và thống kê

- + Định kỳ hoặc theo yêu cầu, hệ thống sẽ kết xuất các báo cáo chi tiết về giao dịch, báo cáo tài chính và lưu lượng hoạt động của toàn hệ thống.

- + Các dữ liệu thống kê này giúp ban lãnh đạo đánh giá hiệu quả hoạt động và đưa ra các quyết định kinh doanh chính xác.

- Bước 4: Bảo trì và tối ưu hóa hệ thống

- + Dựa trên các báo cáo hiệu năng, bộ phận kỹ thuật tiến hành kiểm tra trạng thái hoạt động của hệ thống và cơ sở dữ liệu.

- + Thực hiện sao lưu dữ liệu và cập nhật các biện pháp bảo mật mới (như vá lỗi, nâng cấp tường lửa) để đảm bảo an toàn tài sản cho ngân hàng và khách hàng.

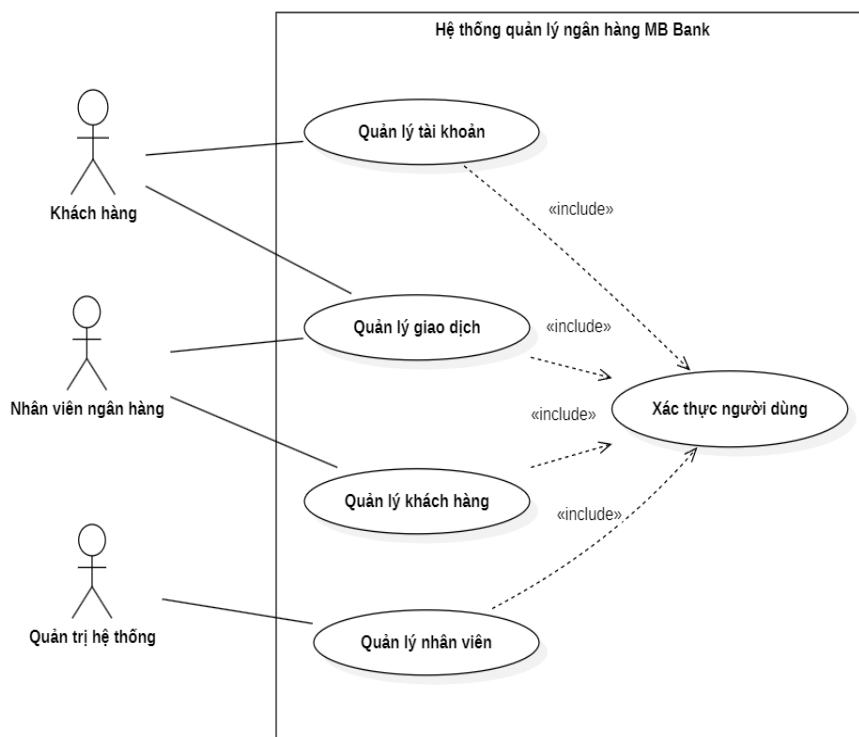
2.4 Phân tích hệ thống bằng UML

Việc sử dụng ngôn ngữ mô hình hóa thống nhất (UML) giúp chuyển đổi các yêu cầu nghiệp vụ thành các biểu đồ trực quan, giúp nắm bắt cấu trúc và hành vi của hệ thống quản lý ngân hàng một cách chính xác.

2.4.1 Sơ đồ Use Case

Sơ đồ Use Case xác định ranh giới hệ thống, các tác nhân (Actors) và các chức năng mà hệ thống cung cấp.

2.4.1.1 Sơ đồ Use Case tổng thể



Hình 2.1: Use Case tổng thể Hệ thống quản lý ngân hàng MB Bank

Sơ đồ Use Case tổng thể mô tả các nhóm chức năng chính mà hệ thống cần thực hiện để đáp ứng nhu cầu của người sử dụng. Hệ thống được chia thành 4 nhóm Use Case lớn:

- Quản lý khách hàng: Cho phép lưu trữ và quản lý thông tin khách hàng.

- Quản lý tài khoản: Cho phép ngân hàng quản lý các tài khoản của khách hàng để kiểm soát và đảm bảo tính chính xác của dữ liệu.

- Quản lý giao dịch: Cho phép thực hiện và quản lý các nghiệp vụ tài chính như gửi tiền, rút tiền, chuyển khoản.

- Quản lý nhân viên: Giúp quản lý thông tin nhân viên ngân hàng và phân quyền hợp lý.

Để đảm bảo tính bảo mật, tất cả các nhóm nghiệp vụ này đều có quan hệ <<include>> bắt buộc với chức năng Xác thực người dùng trước khi thực hiện.

2.4.1.2 Use Case quản lý khách hàng

Nhóm Use Case này giúp ngân hàng quản lý thông tin khách hàng một cách hiệu quả, do tác nhân là Nhân viên ngân hàng trực tiếp thao tác. Các chức năng chi tiết trong phân hệ này bao gồm:

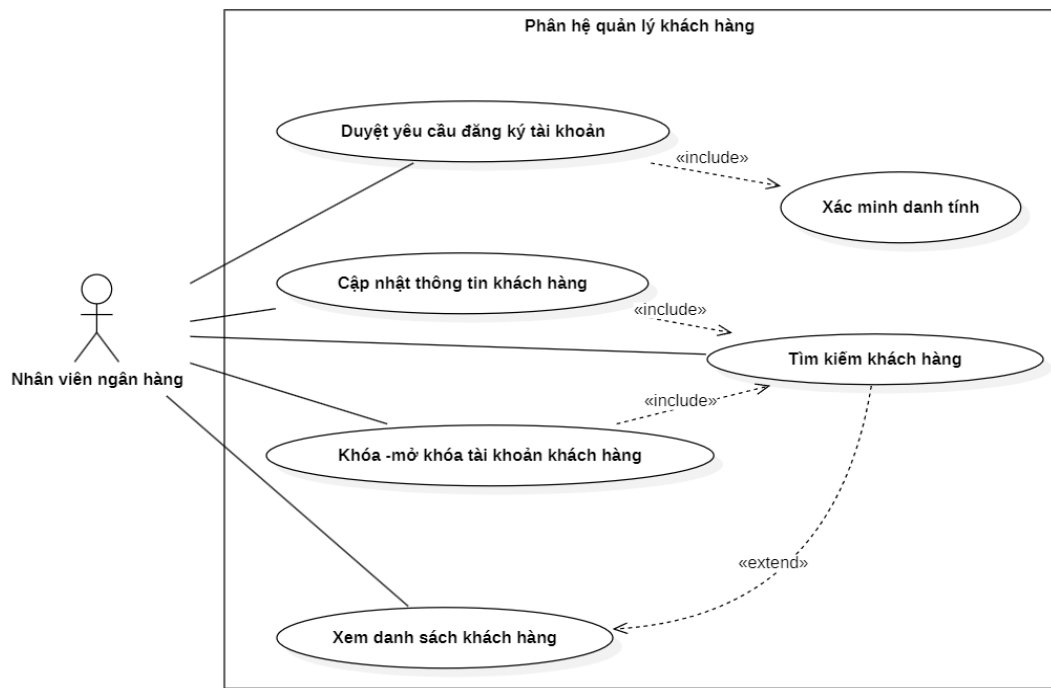
- Duyệt yêu cầu khách hàng: Nhân viên xem xét và đưa ra quyết định duyệt hoặc từ chối yêu cầu đăng ký.

- Cập nhật thông tin khách hàng: Chỉnh sửa và cập nhật các thay đổi liên quan đến thông tin cá nhân của khách hàng.

- Xóa khách hàng: Xóa bỏ dữ liệu của khách hàng khỏi hệ thống khi cần thiết.

- Tìm kiếm khách hàng: Tra cứu nhanh thông tin hồ sơ dựa trên các tiêu chí cụ thể.

- Xem danh sách khách hàng: Truy xuất và hiển thị danh sách toàn bộ khách hàng đang được quản lý.



Hình 2.2: Use Case chức năng quản lý khách hàng

Các quan hệ (Relationships):

- Duyệt yêu cầu đăng ký khách hàng <<include>> xác minh danh tính (KYC): Khi duyệt, nhân viên ngân hàng kiểm tra và xác thực tính hợp lệ của thông tin do khách hàng cung cấp.

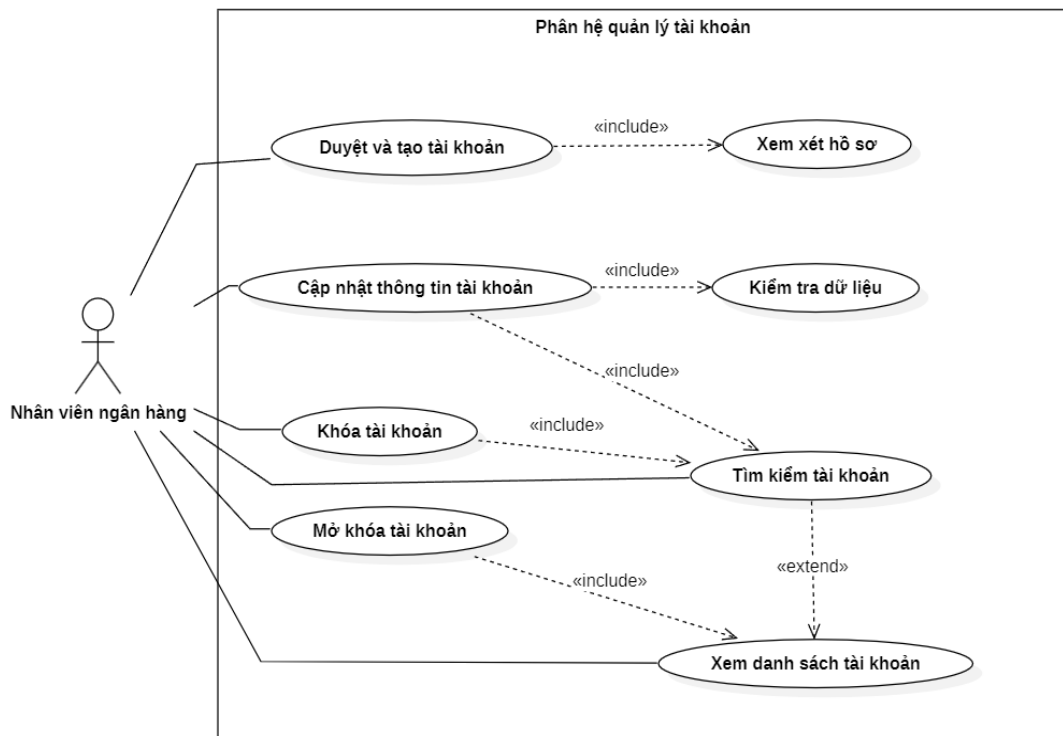
- Cập nhật thông tin khách hàng / Xóa khách hàng <<include>> Tìm kiếm khách hàng: Nhân viên bắt buộc phải tìm kiếm để xác định chính xác hồ sơ trước khi tiến hành cập nhật hoặc xóa.

- Tìm kiếm khách hàng <<extend>> Xem danh sách khách hàng: Trong quá trình xem danh sách tổng thể, nhân viên có thể sử dụng thêm tính năng tìm kiếm để lọc ra các khách hàng cụ thể nếu cần.

2.4.1.3 Use Case quản lý tài khoản

Chức năng quản lý tài khoản cho phép nhân viên ngân hàng quản lý các tài khoản của khách hàng trong hệ thống. Nhân viên có thể thực hiện các chức năng như:

- Duyệt và tạo tài khoản: Tài khoản được tạo tự động cho khách hàng khi yêu cầu đăng ký được nhân viên phê duyệt. Số điện thoại sẽ được dùng làm số tài khoản.
- Cập nhật thông tin tài khoản: Cho phép nhân viên chỉnh sửa và cập nhật các thông tin của tài khoản khi có thay đổi.
- Khóa tài khoản: Cho phép nhân viên khóa tài khoản trong trường hợp tài khoản có vấn đề hoặc theo yêu cầu của khách hàng.
- Mở khóa tài khoản: Cho phép nhân viên mở lại tài khoản đã bị khóa để khách hàng tiếp tục sử dụng.
- Tìm kiếm tài khoản: Cho phép nhân viên tìm kiếm tài khoản theo các thông tin như số tài khoản hoặc tên khách hàng.
- Xem danh sách tài khoản: Cho phép nhân viên xem toàn bộ danh sách tài khoản hiện có trong hệ thống.



Hình 2.3: Use Case chức năng quản lý tài khoản

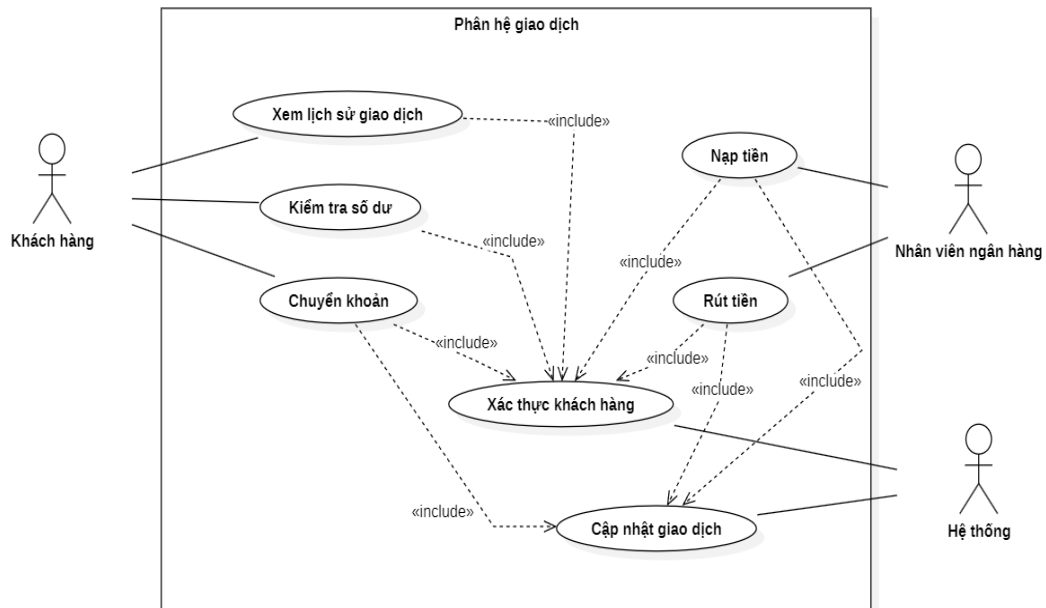
Các quan hệ (Relationships):

- Duyệt và tạo tài khoản <<include>> Xem xét hồ sơ: Nhân viên cần xem xét hồ sơ trước khi duyệt hoặc từ chối.
- Cập nhật thông tin / Khóa / Mở khóa tài khoản <<include>> Tìm kiếm tài khoản: Nhân viên bắt buộc phải tìm kiếm để xác định tài khoản trước khi thực hiện thao tác.
- Cập nhật thông tin tài khoản <<include>> Kiểm tra dữ liệu: Đảm bảo dữ liệu mới nhập vào là hợp lệ.
- Tìm kiếm tài khoản <<extend>> Xem danh sách tài khoản: Nhân viên có thể sử dụng tính năng tìm kiếm để lọc kết quả khi xem danh sách.

2.4.1.4 Use Case giao dịch ngân hàng

Nhóm Use Case này mô tả các chức năng quản lý giao dịch do người dùng thực hiện. Các chức năng chi tiết bao gồm:

- Kiểm tra số dư: Khách hàng xem số dư tài khoản hiện tại.
- Gửi tiền: Khách hàng nộp tiền vào tài khoản tại quầy.
- Rút tiền: Khách hàng rút tiền mặt từ tài khoản tại quầy.
- Chuyển khoản: Khách hàng thực hiện chuyển tiền sang tài khoản khác.
- Xem lịch sử giao dịch: Khách hàng tra cứu lại lịch sử biến động số dư.



Hình 2.4: Use case giao dịch ngân hàng

Các quan hệ (Relationships):

- Kiểm tra số dư / Gửi tiền / Rút tiền / Chuyển khoản <<include>>

Xác thực khách hàng: Mọi giao dịch đều yêu cầu xác thực người dùng hợp lệ.

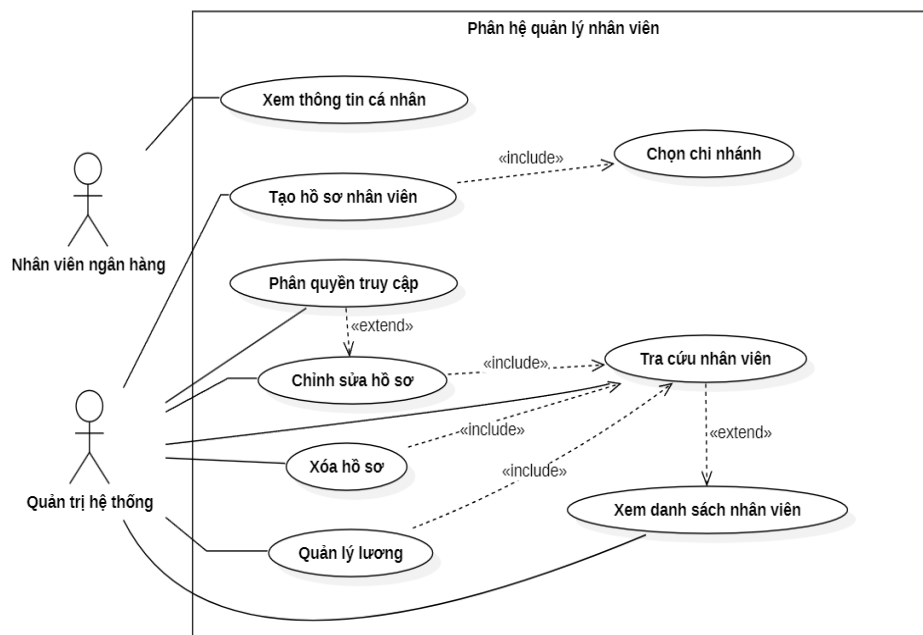
- Gửi tiền / Rút tiền / Chuyển khoản <<include>> Cập nhật giao dịch: Hệ thống phải lưu lại thông tin sau mỗi lần dòng tiền thay đổi.

2.4.1.5 Use Case quản lý nhân viên

Nhóm Use Case này giúp ngân hàng quản lý thông tin nhân viên một cách hiệu quả, với các tác nhân chính là Nhân viên HR và Admin trực tiếp thao tác. Các chức năng chi tiết trong phân hệ này bao gồm:

- Tạo hồ sơ nhân viên: Nhập và lưu trữ thông tin nhân viên mới vào hệ thống.
- Chỉnh sửa hồ sơ nhân viên: Cập nhật các thay đổi liên quan đến thông tin cá nhân hoặc công việc.
- Xóa hồ sơ nhân viên: Loại bỏ thông tin nhân viên khỏi hệ thống khi cần thiết.

- Tra cứu nhân viên: Tìm kiếm thông tin nhân viên theo các tiêu chí cụ thể.
- Xem danh sách nhân viên: Hiện thị toàn bộ danh sách nhân viên đang được quản lý.
- Quản lý lương nhân viên: Cập nhật và theo dõi thông tin lương.
- Quản lý hợp đồng lao động: Quản lý thông tin hợp đồng của nhân viên.
- Phân quyền truy cập: Gán và điều chỉnh quyền truy cập hệ thống.
- Chọn chi nhánh: Xác định chi nhánh làm việc cho nhân viên.
- Xem thông tin cá nhân: Nhân viên tự xem thông tin của mình.



Hình 2.5: Use case quản lý nhân viên

Các quan hệ (Relationships):

- Tạo hồ sơ nhân viên <<include>> Chọn chi nhánh: Khi tạo mới, hệ thống bắt buộc phải xác định chi nhánh làm việc của nhân viên.
- Chỉnh sửa hồ sơ / Xóa hồ sơ / Quản lý lương / Quản lý hợp đồng <<include>> Tra cứu nhân viên: Người dùng phải tra cứu để xác định đúng nhân viên trước khi thao tác.

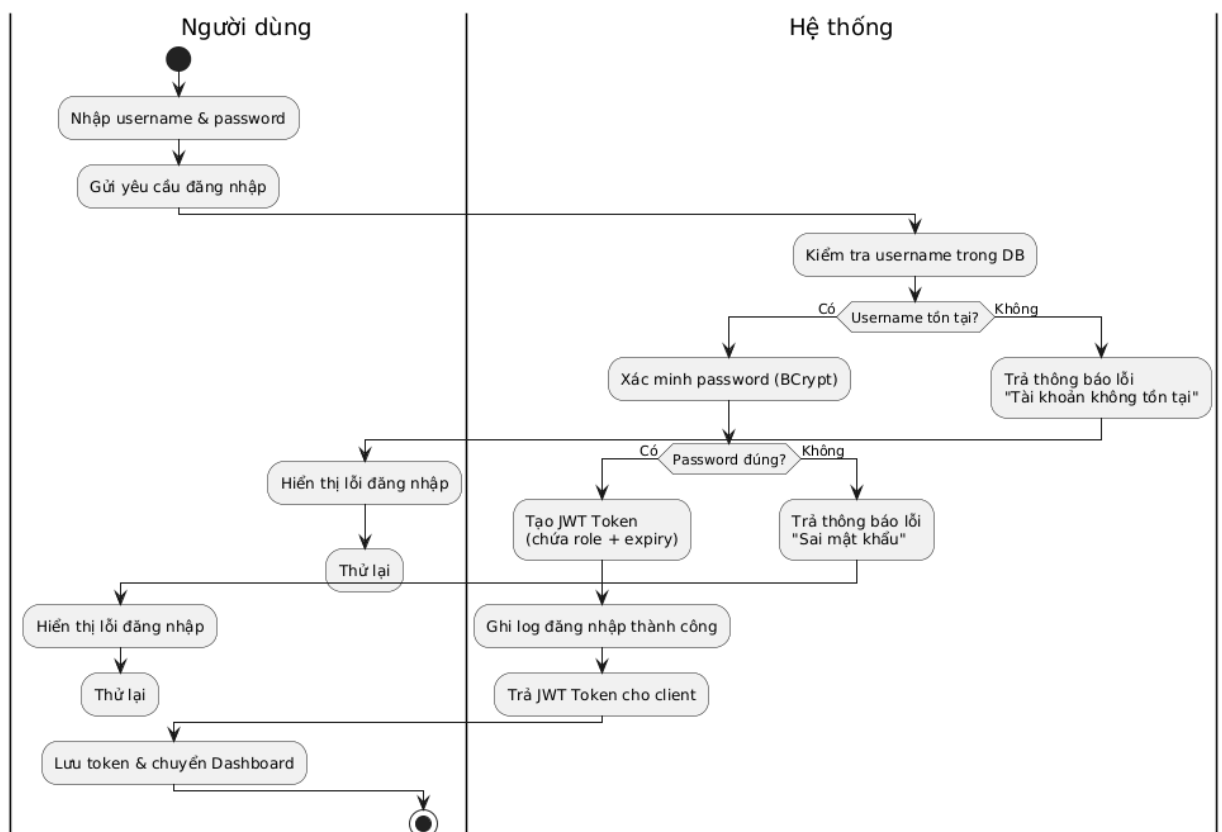
- Phân quyền truy cập <<extend>> Chỉnh sửa hồ sơ nhân viên:
Trong quá trình chỉnh sửa, có thể phát sinh nhu cầu thay đổi quyền truy cập.

- Xem danh sách nhân viên <<extend>> Tra cứu nhân viên: Khi xem danh sách, có thể sử dụng thêm chức năng tra cứu để lọc thông tin.

2.4.2 Sơ đồ Activity

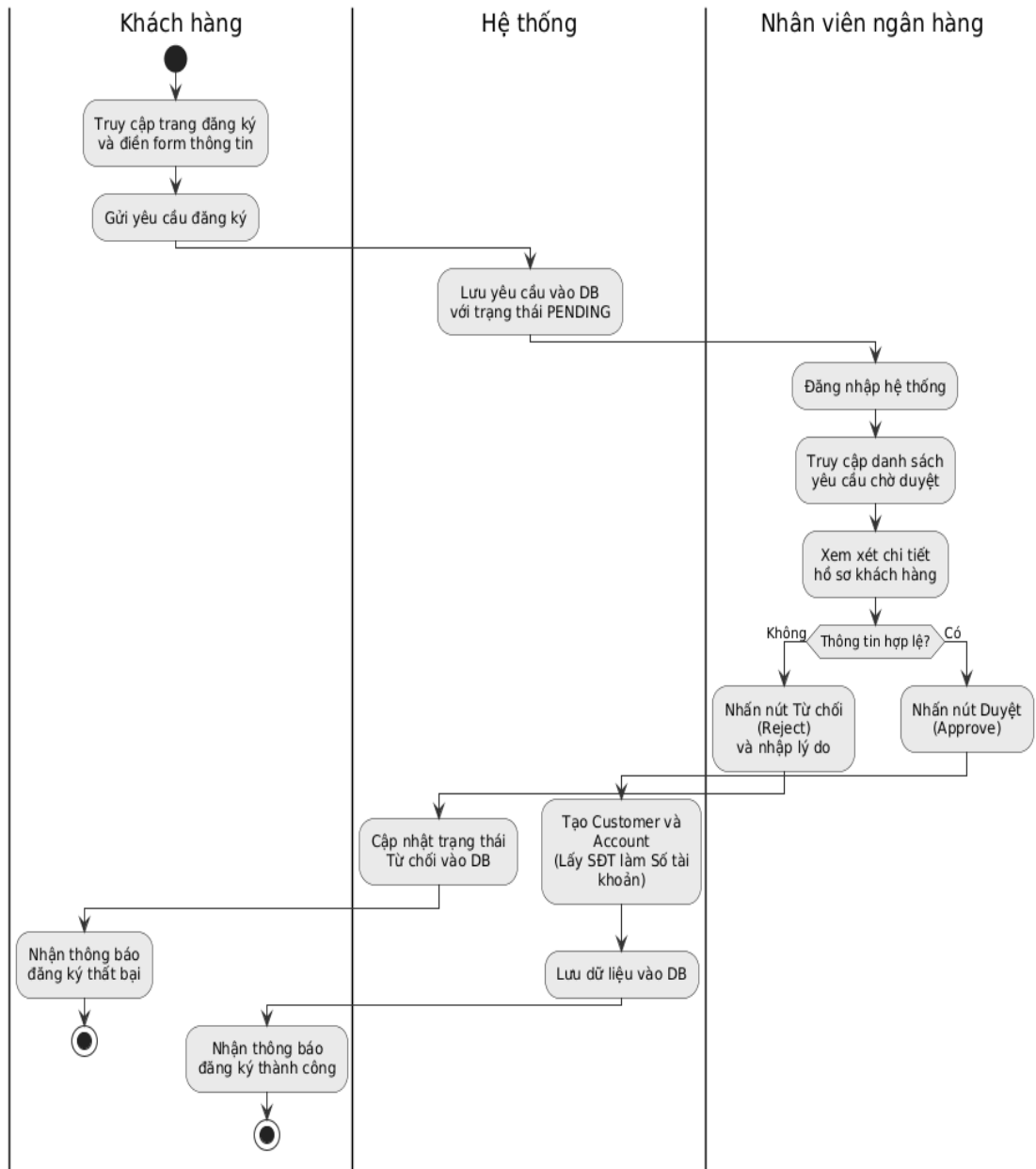
Sơ đồ hoạt động mô tả luồng điều khiển của các quy trình nghiệp vụ quan trọng, làm rõ các điểm rẽ nhánh và điều kiện xử lý.

2.4.2.1 Activity Diagram đăng nhập và xác thực



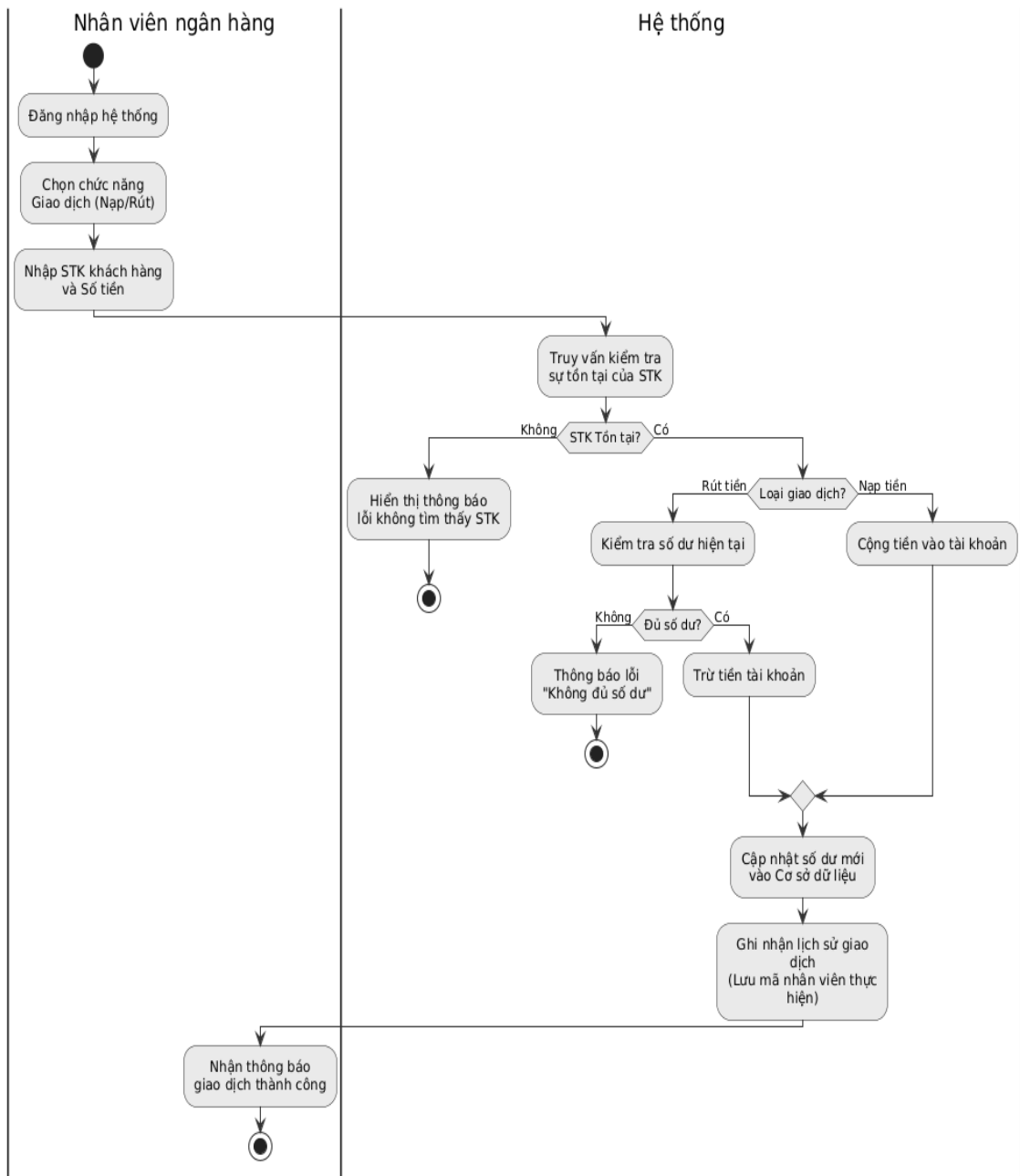
Hình 2.6: Activity Diagram Đăng nhập và xác thực

2.4.2.2 Activity Diagram mở tài khoản



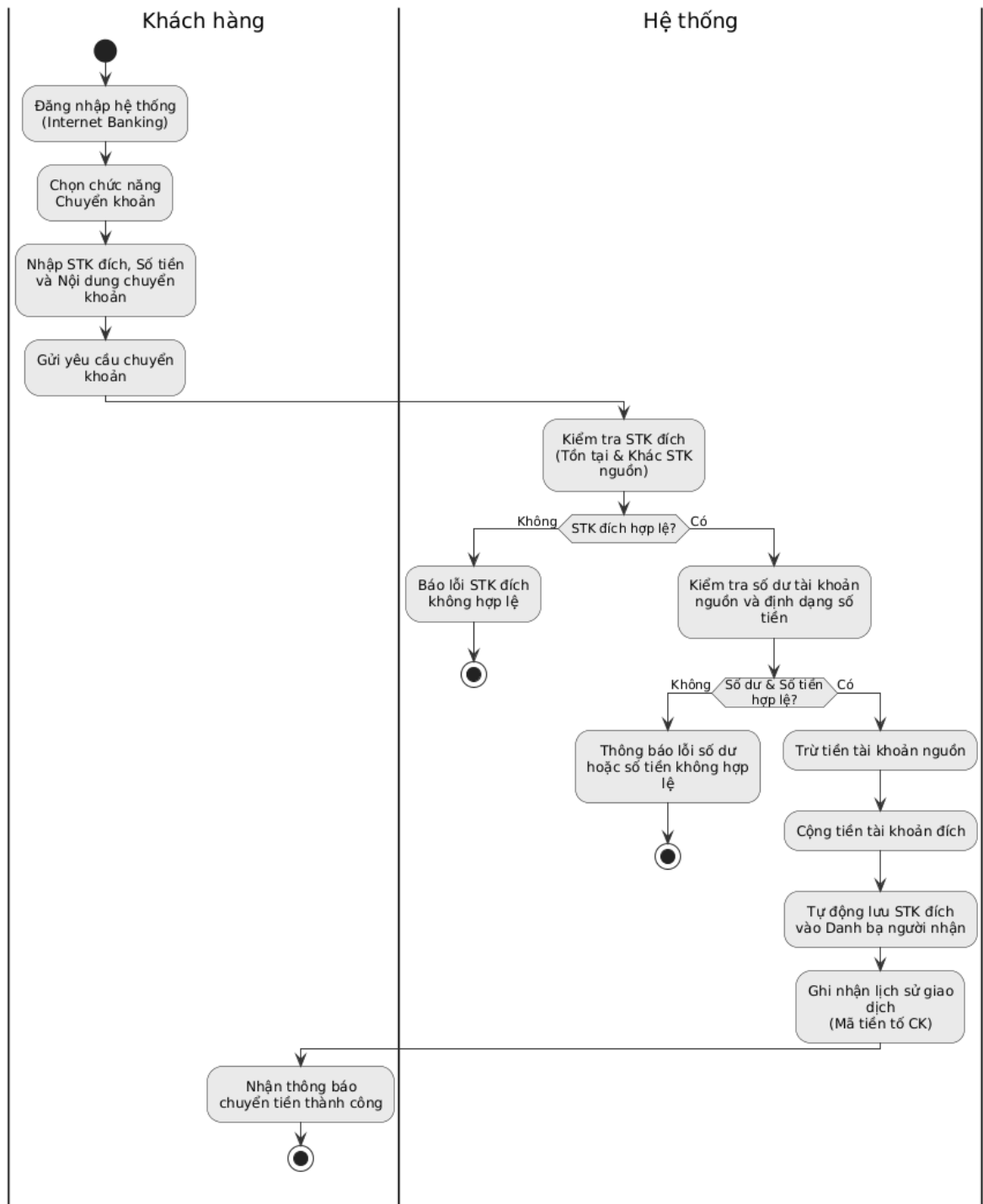
Hình 2.7: Activity Diagram mở tài khoản

2.4.2.3 Activity diagram giao dịch tiền.



Hình 2.8: Activity giao dịch tiền

2.4.2.4 Activity Diagram chuyển khoản

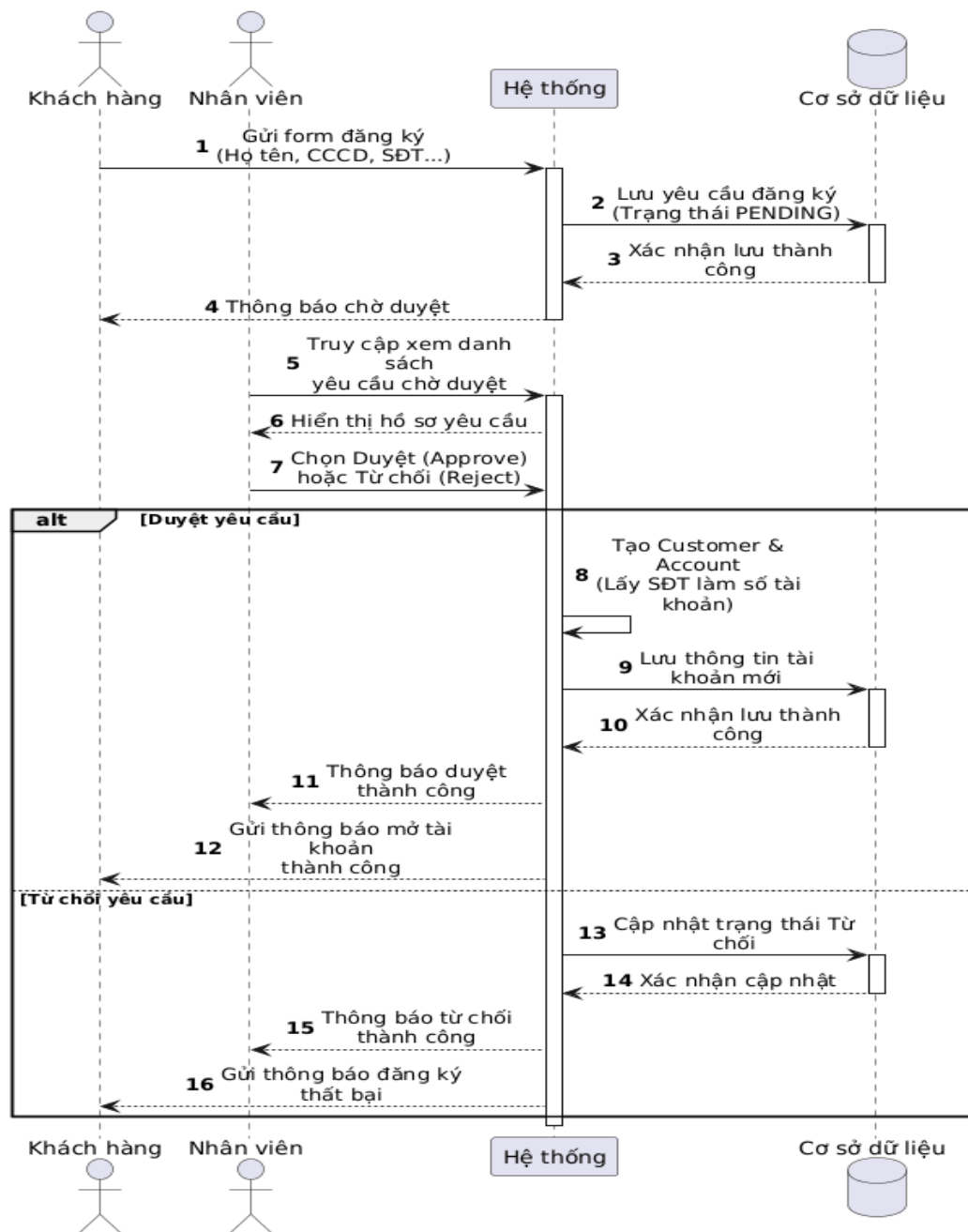


Hình 2.9: Activity Diagram chuyển khoản

2.4.3 Sơ đồ Sequence

Trong khi Activity Diagram tập trung mô tả luồng xử lý và điều kiện rẽ nhánh theo từng actor, Sequence Diagram tập trung làm rõ thứ tự trao đổi thông điệp giữa các đối tượng (Giao diện – Hệ thống – CSDL) theo trục thời gian.

2.4.3.1 Sequence đăng ký và duyệt tài khoản



Hình 2.10: Sequence mở tài khoản

Trình tự hoạt động:

- Luồng chính: Khách hàng gửi thông tin đăng ký lên Hệ thống. Hệ thống lưu trạng thái PENDING xuống Cơ sở dữ liệu. Nhân viên truy cập hệ thống để duyệt yêu cầu. Hệ thống khởi tạo tài khoản (lấy số điện thoại làm số tài khoản) và lưu vào Cơ sở dữ liệu, cuối cùng thông báo kết quả.

- Từ chối duyệt: Nếu thông tin không hợp lệ, Nhân viên chọn Từ chối. Hệ thống cập nhật trạng thái từ chối vào Cơ sở dữ liệu và thông báo cho Khách hàng, quy trình kết thúc mà không tạo tài khoản.

2.4.3.2 Sequence nạp, rút tiền

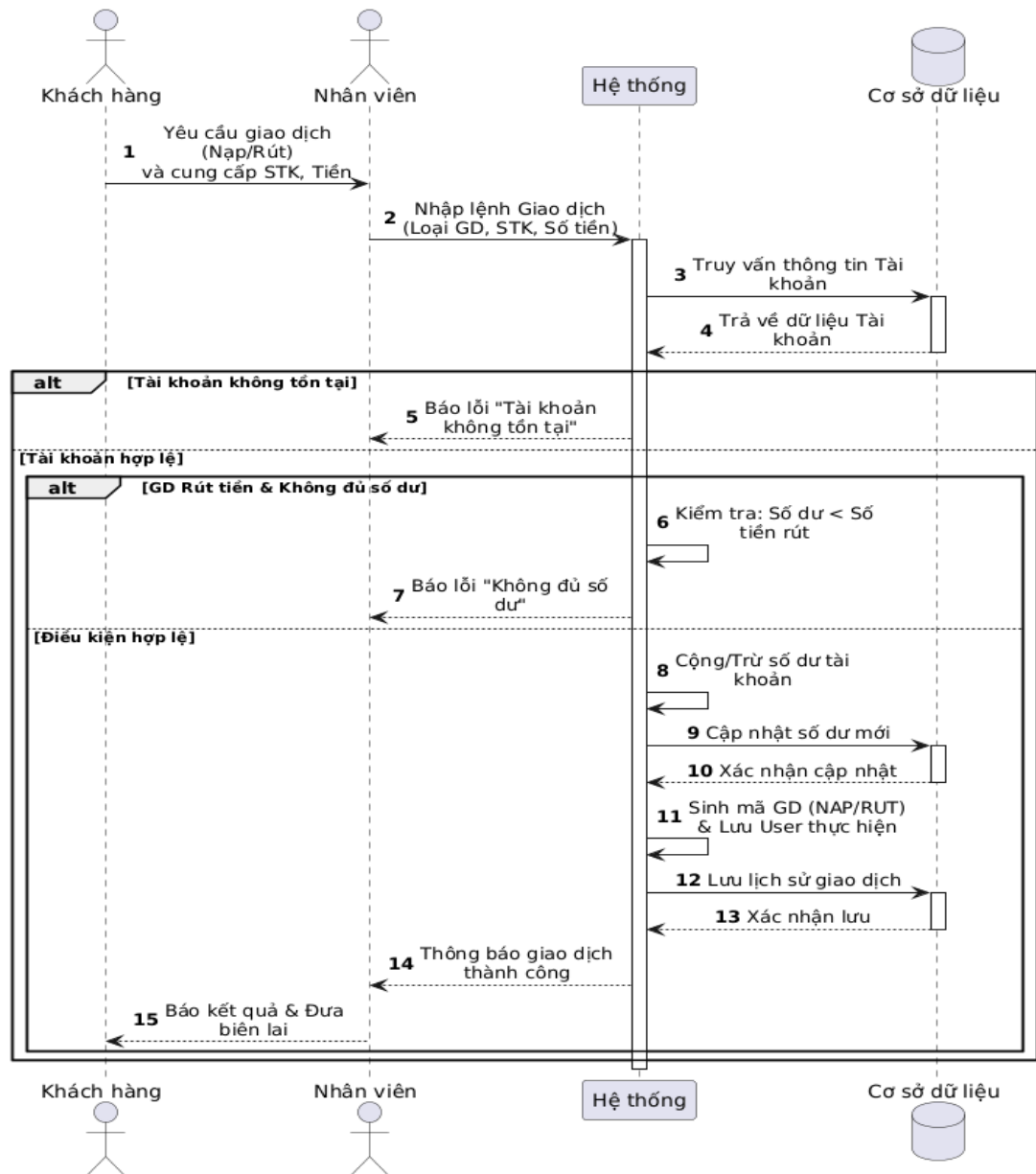
Trình tự hoạt động:

- Luồng chính: Nhân viên đăng nhập và gửi yêu cầu giao dịch (Nạp/Rút) kèm thông tin tài khoản và số tiền vào Hệ thống. Hệ thống truy vấn Cơ sở dữ liệu để kiểm tra tính hợp lệ của tài khoản và số dư (nếu rút). Khi thỏa mãn, Hệ thống tiến hành cộng/trừ số dư, ghi nhận lịch sử giao dịch kèm mã nhân viên, lưu vào Cơ sở dữ liệu và trả về kết quả thành công.

- Kịch bản thay thế:

- + Tài khoản không tồn tại: Hệ thống báo lỗi ngay sau khi truy vấn Cơ sở dữ liệu.

- + Số dư không đủ (khi rút tiền): Hệ thống từ chối giao dịch và báo lỗi "Không đủ số dư" cho Nhân viên.



Hình 2.11: Sequence giao dịch tiền tại quầy

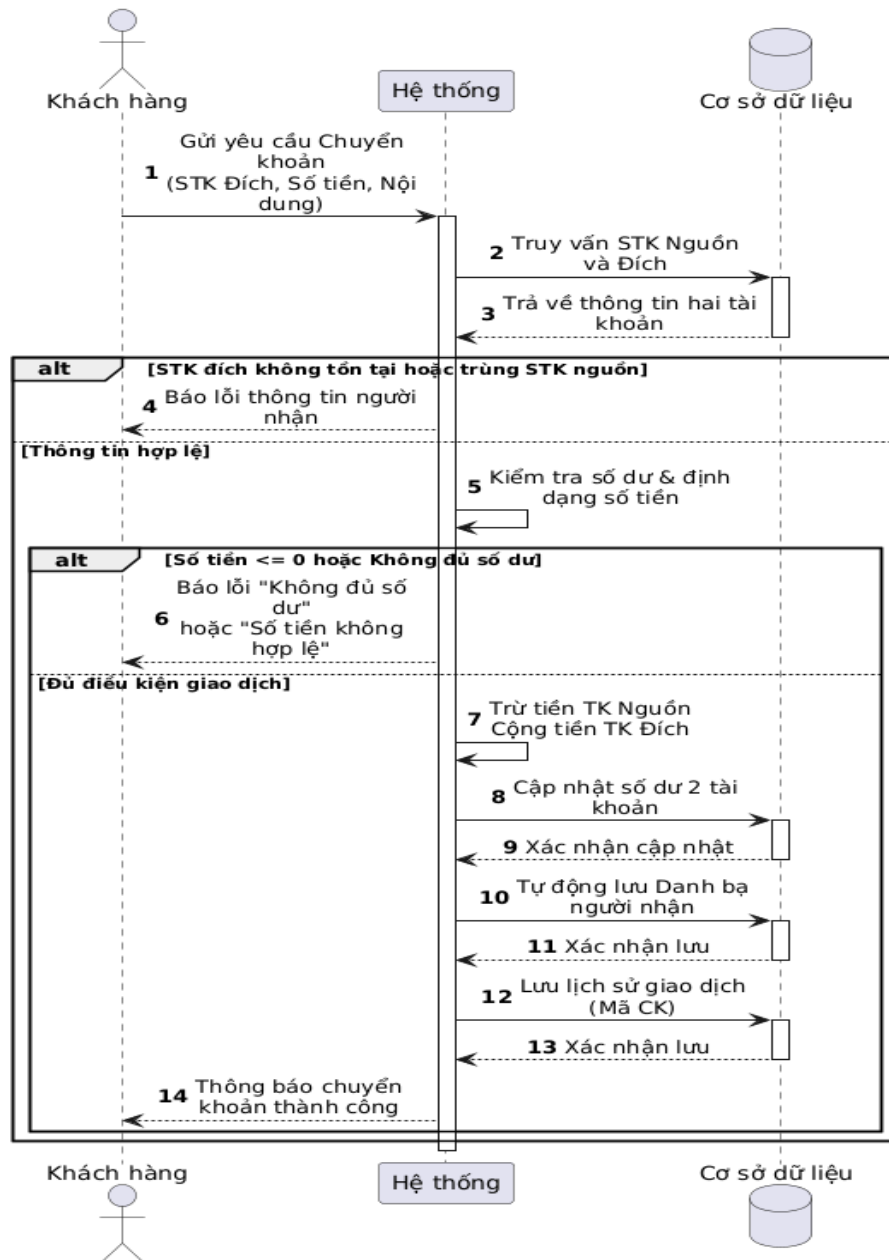
2.4.3.3 Sequence chuyển khoản

- Luồng chính: Khách hàng gửi yêu cầu Chuyển khoản (nhập STK đích, Số tiền, Nội dung). Hệ thống xác thực thông tin, kiểm tra số dư qua Cơ sở dữ liệu. Nếu hợp lệ, Hệ thống trừ tiền tài khoản gửi, cộng tiền tài khoản nhận, tự động lưu người nhận vào Danh bạ, lưu lịch sử giao dịch và trả về thông báo thành công.

- Kịch bản thay thế:

+ Tài khoản đích không tồn tại hoặc trùng tài khoản nguồn: Hệ thống báo lỗi.

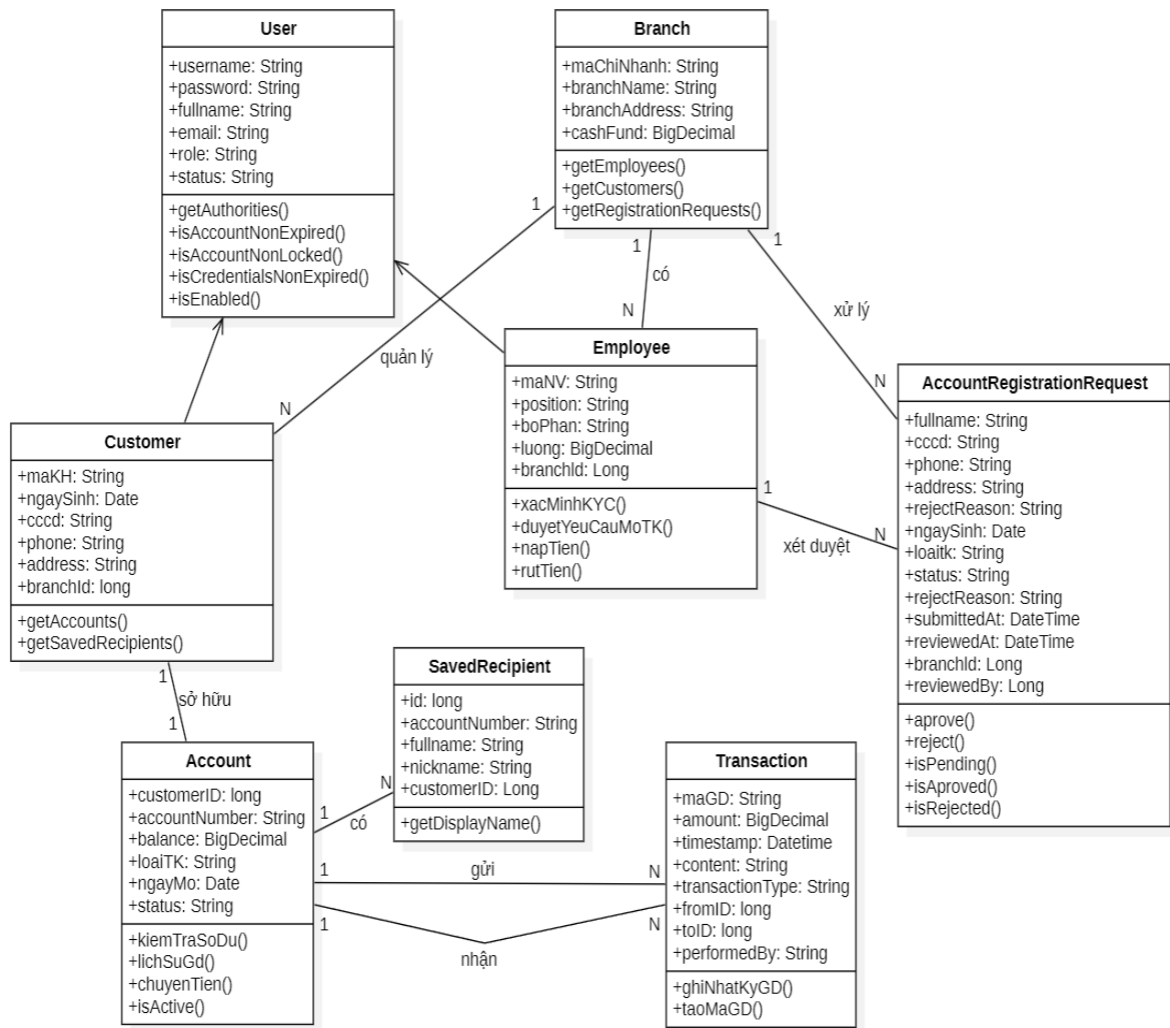
+ Số dư không đủ hoặc Số tiền không hợp lệ: Hệ thống từ chối giao dịch và trả về thông báo lỗi cho Khách hàng.



Hình 2.12: Sequence chuyển khoản

2.4.4 Sơ đồ Class

Sơ đồ lớp mô tả cấu trúc tĩnh của hệ thống, bao gồm các lớp (Class), thuộc tính (Attributes), phương thức (Methods) và mối quan hệ thực tế giữa các thực thể trong cơ sở dữ liệu.



Hình 2.13: Sơ đồ class

Các lớp chính:

- Lớp User (Lớp cơ sở): Chứa các thuộc tính định danh chung cho tất cả người dùng (username, password, fullName, email, role, status).

- Lớp Customer (Khách hàng): Kế thừa từ User, bổ sung thông tin định danh cá nhân (maKH, cccd, phone, address). Lớp này có quan hệ 1-1 với Account.

- Lớp Employee (Nhân viên): Kế thừa từ User, bổ sung thông tin nội bộ (maNV, position, boPhan, luong). Lớp này có phương thức xacMinhKYC() ứng với nghiệp vụ kiểm duyệt.

- Lớp Account (Tài khoản): Quản lý số dư (balance) và trạng thái. Phương thức kiemTraSoDu() là chốt chặn quan trọng trong mọi giao dịch tiền.

- Lớp Transaction (Giao dịch): Lưu trữ lịch sử biến động số dư. Phương thức ghiNhatKyGD() dùng để cập nhật dữ liệu tự động. Lưu kèm mã nhân viên thực hiện (performedBy) nếu là giao dịch tại quầy.

- Lớp Branch (Chi nhánh): Thực thể chi nhánh, quản lý trực tiếp danh sách Nhân viên, Khách hàng và các Yêu cầu mở tài khoản thuộc chi nhánh đó.

- Lớp AccountRegistrationRequest: Lưu trữ các form đăng ký trực tuyến của khách (trạng thái PENDING, APPROVED, REJECTED).

- Lớp SavedRecipient: Lưu trữ danh bạ người nhận để hỗ trợ khách hàng chuyển khoản nhanh.

Các mối quan hệ logic:

- Kế thừa: Khách hàng và Nhân viên đều kế thừa từ đối tượng người dùng chung (User) để tái sử dụng logic xác thực hệ thống.

- Một - Nhiều (1:N):

+ Một Chi nhánh (Branch) quản lý nhiều Nhân viên và nhiều Khách hàng.

+ Một Tài khoản liên kết với nhiều Giao dịch (Transaction) nhận và gửi.

+ Một Tài khoản có thể có nhiều danh bạ người nhận.

- Một - Một (1:1):

+ Một Khách hàng sở hữu một Tài khoản (Account).

2.5 Thiết kế hệ thống

2.5.1 Kiến trúc tổng thể hệ thống

Hệ thống quản lý ngân hàng MB Bank được thiết kế dựa trên mô hình Client-Server kết hợp với Kiến trúc 3 tầng (3-Tier Architecture). Mô hình này giúp đảm bảo tính bảo mật, khả năng mở rộng và dễ dàng bảo trì trong tương lai.

Kiến trúc hệ thống bao gồm các thành phần chính:

- Tầng Client (Giao diện người dùng - Presentation Layer): Tầng này chịu trách nhiệm hiển thị thông tin, tiếp nhận dữ liệu đầu vào (từ Khách hàng và Nhân viên) và gửi các HTTP Request lên Server.

- Tầng Server (Xử lý nghiệp vụ - Business Logic Layer): Được xây dựng bằng Spring Boot, chia thành các thành phần:

+ Controller (API/Web Layer): Tiếp nhận Request từ Client, điều hướng và kiểm tra quyền truy cập thông qua cấu hình Spring Security.

+ Service Layer: Nơi chứa toàn bộ logic nghiệp vụ cốt lõi (xử lý chuyển khoản, kiểm tra số dư, xét duyệt hồ sơ mở tài khoản). Đây là "trái tim" của hệ thống, giúp tách biệt logic xử lý khỏi giao diện.

- Tầng Data Access (Truy cập dữ liệu - Data Layer): Tầng này chịu trách nhiệm tương tác trực tiếp với cơ sở dữ liệu

- Cơ sở dữ liệu (Database): Lưu trữ toàn bộ dữ liệu vật lý một cách an toàn, đảm bảo tính toàn vẹn thông qua các khóa ngoại (Foreign Key) và quy trình Transaction.

Ưu điểm của kiến trúc này:

- Phân tách mối quan tâm (Separation of Concerns): Tách bạch rõ ràng giữa Giao diện, Logic nghiệp vụ và Dữ liệu.

- Bảo mật cao: Tích hợp bảo mật thống nhất từ Security Context ở tầng Server đến Transaction ở Database.

- Dễ dàng mở rộng: Các Service được module hóa, dễ nâng cấp và bảo trì.

2.5.2 Thiết kế cơ sở dữ liệu

2.5.2.1 Xác định các thực thể

Từ phân tích yêu cầu, hệ thống bao gồm các thực thể chính sau:

Tên thực thể	Mô tả
USERS	Tài khoản đăng nhập hệ thống (khách hàng, nhân viên, quản trị viên)
CUSTOMERS	Thông tin chi tiết khách hàng (mở rộng từ USERS)
EMPLOYEES	Thông tin chi tiết nhân viên/quản lý (mở rộng từ USERS)
BRANCHES	Chi nhánh ngân hàng

ACCOUNTS	Tài khoản ngân hàng của khách hàng
TRANSACTIONS	Lịch sử giao dịch (chuyển khoản, nạp, rút)
ACCOUNT_REGISTRATION_REQUESTS	Yêu cầu mở tài khoản ngân hàng
SAVED_RECIPIENTS	Danh sách người nhận chuyển khoản đã lưu

Bảng 2.1: Bảng các thực thể

2.5.2.2 Xác định các thuộc tính

Mỗi thực thể được xác định thuộc tính:

- **USERS:** id (PK), username, password, full_name, email, role, status
- **CUSTOMERS:** id (PK, FK→USERS), cccd, phone, address, ngay_sinh, makh, branch_id (FK→BRANCHES)
- **EMPLOYEES:** id (PK, FK→USERS), position, bo_phan, luong, manv, branch_id (FK→BRANCHES)
- **BRANCHES:** id (PK), branch_name, branch_address, ma_chi_nhanh, cash_fund
- **ACCOUNTS:** id (PK), account_number, balance, status, loai_tk, ngay_mo, customer_id (FK→CUSTOMERS)
- **TRANSACTIONS:** id (PK), amount, content, timestamp, transaction_type, from_account_id (FK→ACCOUNTS), to_account_id (FK→ACCOUNTS), magd, performed_by

- **ACCOUNT_REGISTRATION_REQUESTS**: id (PK), cccd, desired_username, full_name, phone, email, address, ngay_sinh, password, loaitk, status, submitted_at, reviewed_at, reject_reason, branch_id (FK→BRANCHES), reviewed_by (FK→EMPLOYEES)

- **SAVED_RECIPIENTS**: id (PK), account_number, full_name, nickname, customer_id (FK→CUSTOMERS)

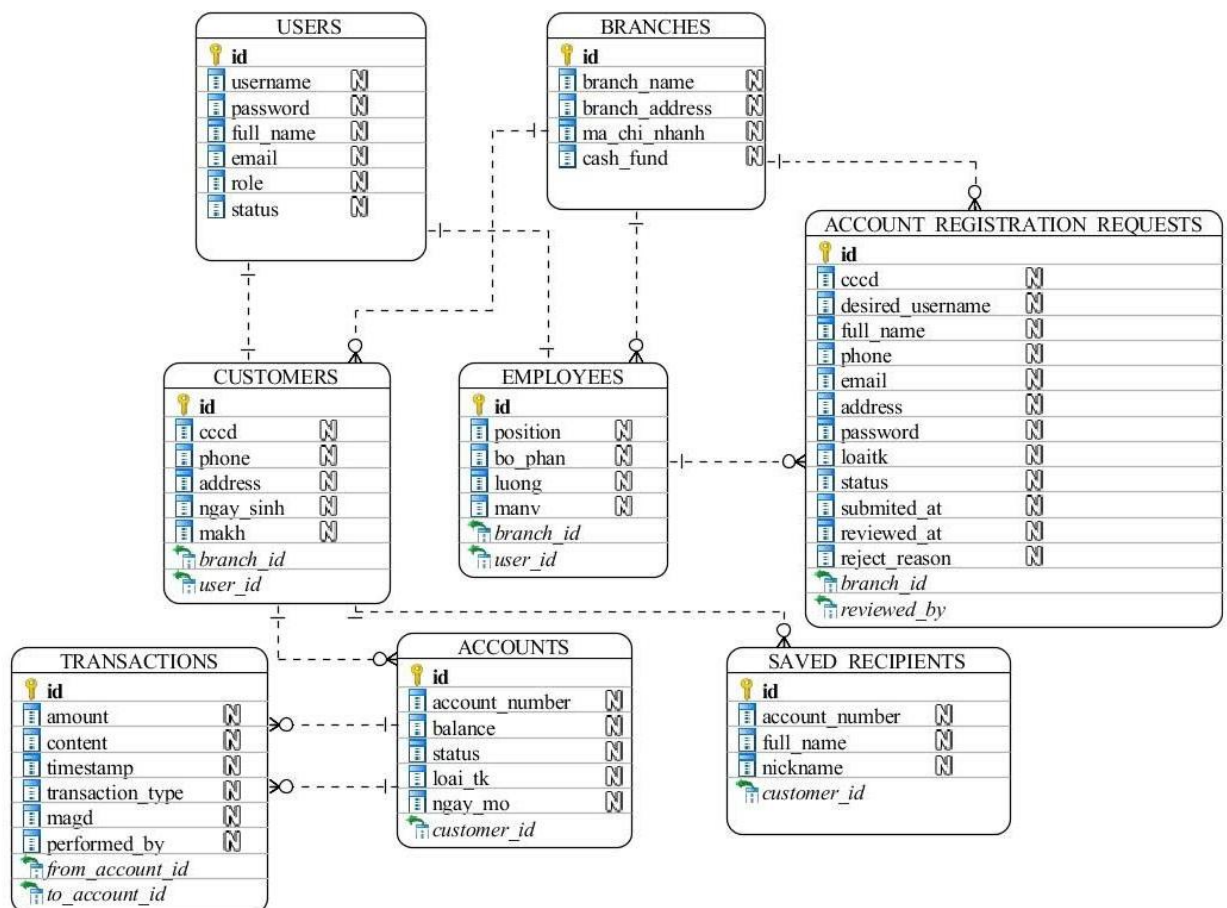
2.5.2.3 Xác định mối quan hệ giữa các thực thể

Thực thể 1	Quan hệ	Thực thể 2	Diễn giải
USERS	1 – 1	CUSTOMERS	Mỗi khách hàng là một user
USERS	1 – 1	EMPLOYEES	Mỗi nhân viên là một user
CUSTOMERS	N – 1	BRANCHES	Nhiều KH thuộc một chi nhánh
EMPLOYEES	N – 1	BRANCHES	Nhiều NV làm việc tại một chi nhánh
CUSTOMERS	1 – 1	ACCOUNTS	Một khách hàng có một tài khoản
ACCOUNTS	1 – N	TRANSACTIONS	Một tài khoản có thể có nhiều giao dịch.
BRANCHES	1 – N	ACCT_REG_REQUESTS	Yêu cầu mở TK gửi tại chi nhánh

EMPLOYEES	1 – N	ACCT_REG_REQUESTS	Nhân viên duyệt yêu cầu mở TK
CUSTOMERS	1 – N	SAVED_RECIPIENTS	KH lưu danh sách người nhận

Bảng 2.2: Bảng mối quan hệ giữa các thực thể

2.5.2.4 Sơ đồ ERD



Hình 2.14: Sơ đồ ERD hệ thống MBBank

2.5.2.5 Thiết kế cơ sở dữ liệu vật lý cho hệ thống

a. Bảng USERS

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u>	BIGINT	Khóa chính, tự tăng
username	VARCHAR(255)	Duy nhất, NOT NULL
password	VARCHAR(255)	BCrypt hash, NOT NULL
full_name	VARCHAR(255)	Họ tên đầy đủ
email	VARCHAR(255)	Địa chỉ email
role	VARCHAR(255)	ROLE_CUSTOMER/ ROLE_EMPLOYEE/ ROLE_BRANCH_MANAGER/ ROLE_SYSADMIN
status	VARCHAR(255)	ACTIVE / INACTIVE

Bảng 2.3: Bảng USERS

b. Bảng BRANCHES

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u>	BIGINT	Khóa chính, tự tăng
branch_name	VARCHAR(255)	Tên chi nhánh
branch_address	VARCHAR(255)	Địa chỉ chi nhánh
ma_chi_nhanh	VARCHAR(50)	Mã chi nhánh nghiệp vụ, duy nhất

cash_fund	DECIMAL(18,2)	Quỹ tiền mặt tại chi nhánh
-----------	---------------	----------------------------

Bảng 2.4: Bảng BRANCHES

c. Bảng CUSTOMERS

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u> / <u>FK</u>	BIGINT	PK, FK → USERS(id)
cccd	VARCHAR(255)	Số CCCD/CMND
phone	VARCHAR(255)	Số điện thoại
address	VARCHAR(255)	Địa chỉ thường trú
ngay_sinh	DATE	Ngày sinh
makh	VARCHAR(255)	Mã khách hàng nghiệp vụ, duy nhất
<u>branch_id</u>	BIGINT	FK → BRANCHES(id)

Bảng 2.5: Bảng CUSTOMERS

d. Bảng EMPLOYEES

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u> / <u>FK</u>	BIGINT	PK, FK → USERS(id)
position	VARCHAR(255)	Chức vụ
bo_phan	VARCHAR(255)	Bộ phận công tác
luong	DECIMAL(38,2)	Mức lương

manv	VARCHAR(255)	Mã nhân viên nghiệp vụ, duy nhất
<u>branch_id</u>	BIGINT	FK → BRANCHES(id)

Bảng 2.6: Bảng EMPLOYEES

e. Bảng ACCOUNTS

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u>	BIGINT	Khóa chính, tự tăng
account_number	VARCHAR(255)	Số tài khoản, duy nhất
balance	DECIMAL(38,2)	Số dư hiện tại
status	VARCHAR(255)	HOAT_DONG / KHOA
loai_tk	VARCHAR(50)	THANH_TOAN / TIET_KIEM
ngay_mo	DATE	Ngày mở tài khoản
<u>customer_id</u>	BIGINT	FK → CUSTOMERS(id)

Bảng 2.7: Bảng ACCOUNTS

f. Bảng TRANSACTIONS

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u>	BIGINT	Khóa chính, tự tăng
amount	DECIMAL(38,2)	Số tiền giao dịch
content	VARCHAR(255)	Nội dung giao dịch

timestamp	DATETIME	Thời điểm giao dịch
transaction_type	VARCHAR(255)	TRANSFER / DEPOSIT / WITHDRAW
magd	VARCHAR(255)	Mã giao dịch nghiệp vụ, duy nhất
performed_by	VARCHAR(255)	Mã nhân viên thực hiện (nếu có)
<u>from_account_id</u>	BIGINT	FK → ACCOUNTS(id), NULL nếu nạp tiền
<u>to_account_id</u>	BIGINT	FK → ACCOUNTS(id), NULL nếu rút tiền

Bảng 2.8: Bảng TRANSACTIONS

g. Bảng ACCOUNT_REGISTRATION_REQUESTS

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u>	BIGINT	Khóa chính, tự tăng
cccd	VARCHAR(255)	Số CCCD, duy nhất, NOT NULL
desired_username	VARCHAR(255)	Tên đăng nhập mong muốn, duy nhất
full_name	VARCHAR(255)	Họ tên đầy đủ, NOT NULL
phone	VARCHAR(255)	Số điện thoại, NOT NULL
email	VARCHAR(255)	Địa chỉ email

address	VARCHAR(500)	Địa chỉ thường trú
ngay_sinh	DATE	Ngày sinh
password	VARCHAR(255)	Mật khẩu (chưa hash), NOT NULL
loaitk	VARCHAR(50)	Loại tài khoản yêu cầu
status	VARCHAR(255)	PENDING / APPROVED / REJECTED, NOT NULL
submitted_at	DATETIME	Thời điểm nộp yêu cầu
reviewed_at	DATETIME	Thời điểm xét duyệt
reject_reason	VARCHAR(500)	Lý do từ chối (nếu có)
<u>branch_id</u>	BIGINT	FK → BRANCHES(id), NOT NULL
<u>reviewed_by</u>	BIGINT	FK → EMPLOYEES(id)

Bảng 2.9: Bảng ACCOUNT_REGISTRATION_REQUESTS

h. Bảng SAVED_RECIPIENTS

Thuộc tính	Kiểu dữ liệu	Ràng buộc / Ghi chú
<u>id</u>	BIGINT	Khóa chính, tự tăng
account_number	VARCHAR(255)	Số tài khoản người nhận, NOT NULL
full_name	VARCHAR(255)	Họ tên người nhận, NOT NULL

nickname	VARCHAR(255)	Tên gọi nhớ (tùy chọn)
<u>customer_id</u>	BIGINT	FK → CUSTOMERS(id), NOT NULL

Bảng 2.10: Bảng `SAVED_RECIPIENTS`

2.6.3 Thiết kế giao diện người dùng

Giao diện người dùng (User Interface) của hệ thống quản lý ngân hàng MB Bank được xây dựng dựa trên bộ công nghệ HTML5, CSS3, JavaScript kết hợp Bootstrap 5 và template engine Thymeleaf. Thiết kế tuân thủ ba nguyên tắc cốt lõi: tối giản để giảm tải nhận thức (cognitive load) cho người dùng trong môi trường nghiệp vụ tài chính áp lực cao; nhất quán về màu sắc, bố cục và cách hiển thị thông báo xuyên suốt toàn hệ thống; và phân tách rõ ràng giữa ba nhóm giao diện phục vụ ba vai trò khác nhau: Khách hàng, Nhân viên ngân hàng và Quản trị hệ thống.

Do hệ thống phục vụ ba nhóm người dùng với nhu cầu và quyền hạn hoàn toàn khác nhau, mỗi nhóm có một phân hệ giao diện riêng, được truy cập qua các đường dẫn URL độc lập (/customer/**, /employee/**, /admin/**) và bảo vệ bởi Spring Security. Người dùng sau khi đăng nhập sẽ được tự động chuyển đến đúng giao diện tương ứng với vai trò của mình.

2.6.3.1 Giao diện của khách hàng

Phân hệ giao diện dành cho khách hàng tập trung vào trải nghiệm đơn giản, trực quan. Khách hàng chỉ tiếp cận được các chức năng phù hợp với quyền hạn của mình như xem thông tin tài khoản, thực hiện chuyển khoản và tra cứu lịch sử giao dịch. Mọi chức năng vận hành nội bộ hoàn toàn bị ẩn khỏi giao diện này.

a) Màn hình đăng nhập

Màn hình đăng nhập là điểm tiếp cận đầu tiên của khách hàng với hệ thống. Giao diện được thiết kế tối giản với hai trường nhập liệu: tên đăng nhập (số điện thoại) và mật khẩu cùng một nút đăng nhập nổi bật. Phía dưới có liên kết dẫn đến trang đăng ký dành cho khách hàng chưa có tài khoản.

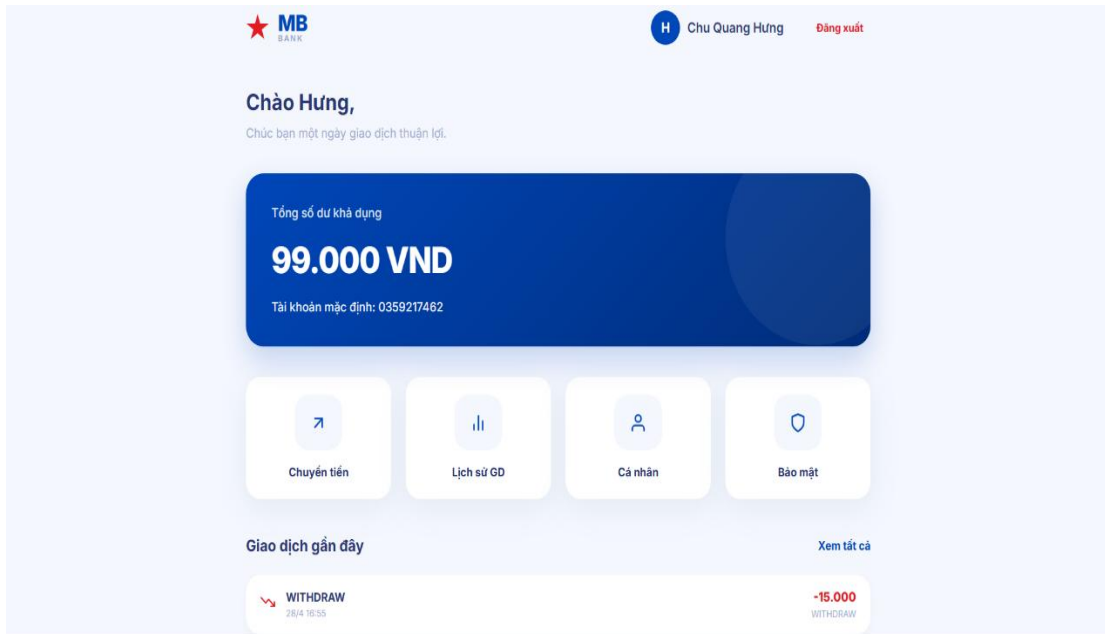
Khi thông tin đăng nhập không hợp lệ, hệ thống hiển thị thông báo lỗi ngay tại trang mà không làm mới toàn bộ form - giúp người dùng không mất dữ liệu đã nhập. Thông báo lỗi cô ý không tiết lộ lý do cụ thể (sai username hay sai mật khẩu) nhằm ngăn chặn kẻ tấn công dò ra thông tin tài khoản hợp lệ.

Hình 2.15: Màn hình đăng nhập dành cho khách hàng

b) Màn hình trang chủ

Sau khi đăng nhập thành công, khách hàng được chuyển đến trang chủ (dashboard). Màn hình này hiển thị tổng quan tài chính cá nhân gồm: số tài khoản, tên chủ tài khoản và số dư hiện tại được làm nổi bật ở vị trí trung tâm. Phía dưới là các thẻ (card) lối tắt dẫn nhanh đến ba chức năng thường dùng nhất: Chuyển khoản, Lịch sử giao dịch và Danh bạ người nhận.

Bố cục một cột đơn giản giúp khách hàng không bị phân tâm bởi quá nhiều thông tin. Số dư tài khoản được định dạng theo chuẩn tiền tệ Việt Nam để dễ đọc và tránh nhầm lẫn khi giao dịch số tiền lớn.



Hình 2.16: Màn hình trang chủ dành cho khách hàng

c) Màn hình chuyển khoản

Màn hình chuyển khoản cung cấp form gồm ba trường nhập liệu: số tài khoản đích, số tiền và nội dung chuyển khoản. Điểm nổi bật của màn hình này là tính năng Danh bạ người nhận là hệ thống tự động gợi ý các tài khoản mà khách hàng đã từng chuyển tiền trước đó, giúp giảm thời gian nhập liệu và hạn chế sai sót số tài khoản.

Khi khách hàng nhập số tài khoản đích hợp lệ, hệ thống hiển thị tên chủ tài khoản ngay bên dưới trường nhập để khách hàng xác nhận trước khi thực hiện, đây là lớp xác nhận thông tin quan trọng, giảm thiểu rủi ro chuyển nhầm. Hệ thống kiểm tra đầu vào theo thời gian thực và hiển thị cảnh báo ngay nếu số tiền không hợp lệ hoặc tài khoản đích không tồn tại.

Chuyển khoản nội bộ

Tài khoản nguồn
0359217462
Số dư: 99.000 đ

Số tài khoản thụ hưởng
0359217465

Tên thụ hưởng: NGUYEN VAN A DANH BA

Số tiền (VND)
0

Lời nhắn
0359217462 chuyển tiền

TIẾP TỤC

Hình 2.17: Màn hình chuyển khoản trực tuyến

d) Màn hình lịch sử giao dịch

Màn hình lịch sử giao dịch hiển thị toàn bộ các giao dịch phát sinh trên tài khoản theo thứ tự thời gian từ mới đến cũ. Mỗi dòng trong bảng gồm: mã giao dịch (CK... hoặc RUT...), loại giao dịch, số tiền (màu xanh nếu cộng tiền, màu đỏ nếu trừ tiền), nội dung và thời điểm thực hiện.

Việc phân biệt màu sắc cho số tiền cộng/trừ giúp khách hàng nhanh chóng nhận ra biến động số dư mà không cần đọc cột loại giao dịch. Mã giao dịch hiển thị đầy đủ giúp khách hàng có căn cứ tra cứu hoặc khiếu nại khi cần thiết.

Lịch sử giao dịch

THÁNG 4 / 2026

↑	WITHDRAW	- 15.000 VND	WITHDRAW
	28/04/2026 - 16:55		
↑	WITHDRAW	- 100.000 VND	WITHDRAW
	28/04/2026 - 16:53		
↑	Chuyển tiền tới 0359217465	- 1.000 VND	0359217462 chuyển tiền
	28/04/2026 - 16:59		
↓	Nhận tiền từ 0359217465	+ 50.000 VND	0359217465 chuyển tiền
	28/04/2026 - 10:18		
↑	Chuyển tiền tới 237504	- 365.290 VND	0359217462 chuyển tiền
	28/04/2026 - 09:17		
↑	Chuyển tiền tới 237504	- 11.111 VND	0359217462 chuyển tiền
	28/04/2026 - 09:17		
↑	Chuyển tiền tới MB1146683841	- 376,78 VND	0359217462 chuyển tiền
	28/04/2026 - 09:11		

Hình 2.18: Màn hình lịch sử giao dịch của khách hàng

2.6.3.2 Giao diện của nhân viên ngân hàng

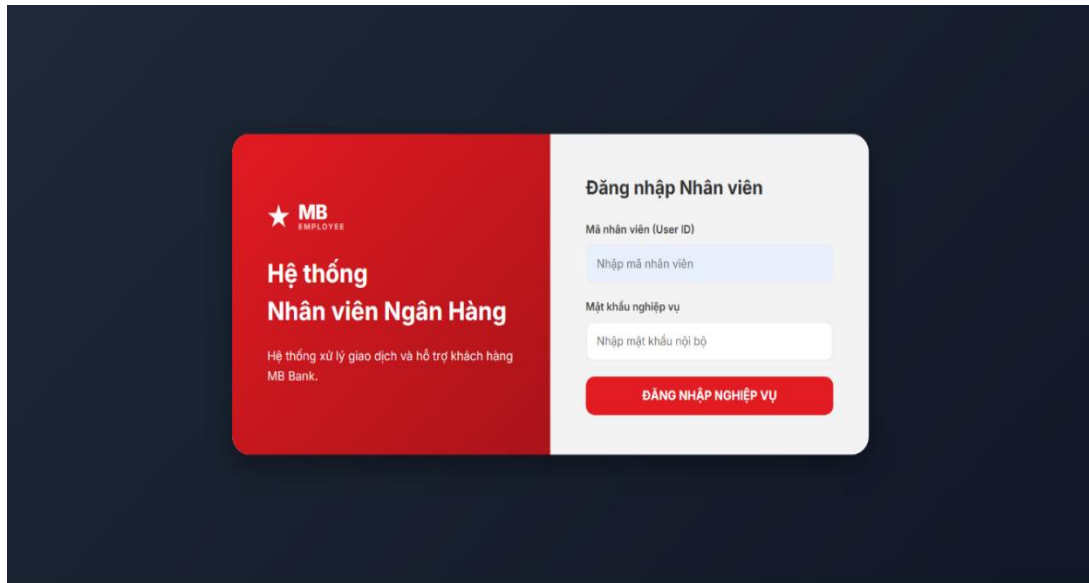
Phân hệ giao diện dành cho nhân viên ngân hàng ưu tiên hiệu năng làm việc và độ chính xác nghiệp vụ. Khác với giao diện khách hàng tập trung vào self-service, giao diện nhân viên cung cấp các công cụ quản lý tập trung: danh sách hồ sơ chờ duyệt, thực hiện giao dịch tại quầy và quản lý thông tin khách hàng. Tất cả dữ liệu hiển thị đều được lọc theo chi nhánh - nhân viên chỉ thấy thông tin thuộc đơn vị mình phụ trách.

Màn hình	Chức năng chính	Người thực hiện
Đăng nhập	Xác thực tài khoản nhân viên, redirect vào dashboard	Nhân viên
Giao dịch tại quầy	Nạp tiền / Rút tiền cho khách hàng	Nhân viên
Quản lý khách hàng	Duyệt hồ sơ, xem/cập nhật thông tin, tìm kiếm	Nhân viên
Quản lý tài khoản	Khóa/mở khóa tài khoản, xem trạng thái	Nhân viên

Bảng 2.11: Tổng hợp các màn hình trong phân hệ nhân viên

a) Màn hình đăng nhập nhân viên

Màn hình đăng nhập của nhân viên có cấu trúc tương tự phía khách hàng, hai trường username và password nhưng sau khi xác thực thành công, Spring Security đọc role ROLE_EMPLOYEE từ JWT Token và tự động chuyển hướng đến dashboard nhân viên (/employee/dashboard) thay vì trang khách hàng. Thiết kế này đảm bảo nhân viên không thể truy cập nhầm sang phân hệ khách hàng và ngược lại.



Hình 2.19: Màn hình đăng nhập dành cho nhân viên ngân hàng

b) Màn hình giao dịch tại quầy

Màn hình giao dịch tại quầy là công cụ trực tiếp để nhân viên thực hiện nạp tiền và rút tiền cho khách hàng. Giao diện gồm hai tab riêng biệt: Nạp tiền và Rút tiền, mỗi tab có form nhập số tài khoản và số tiền. Khi nhân viên nhập số tài khoản và di chuyển sang trường tiếp theo, hệ thống tự động tra cứu và hiển thị tên chủ tài khoản ngay bên dưới, giúp nhân viên xác nhận khớp với khách hàng đang đứng trước quầy trước khi thực hiện giao dịch.

Đối với giao dịch rút tiền, hệ thống hiển thị thêm số dư hiện tại của tài khoản để nhân viên kiểm tra trực quan trước khi nhập số tiền rút. Sau khi giao dịch hoàn thành, hệ thống hiển thị thông báo thành công kèm mã giao dịch vừa sinh (ví dụ: RUT20260428165306588), mã này để lưu làm bằng chứng giao dịch.

MB
EMPLOYEE

Tổng quan
Khách hàng & Tài khoản
Giao dịch tại quầy
Duyệt tài khoản

Giao dịch tại quầy
Nạp/Rút tiền trực tiếp cho khách hàng

0359217411 **TÌM KIẾM**

Thông tin tài khoản **HOẠT ĐỘNG**

Chủ tài khoản:	LE VAN C	Số dư hiện tại:	1.000.000 đ
Số tài khoản:	0359217411	CCCD:	094910841111
Số điện thoại:	0359217411	Chi nhánh:	Hoàn Kiếm

+ Nạp tiền (Deposit)

Số tiền nạp (VND)

Ví dụ: 1000000

XÁC NHẬN NẠP TIỀN

- Rút tiền (Withdraw)

Số tiền rút (VND)

Ví dụ: 500000

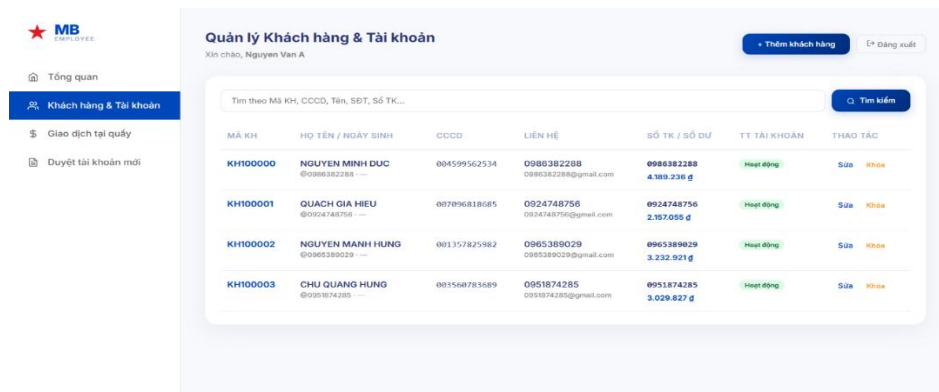
XÁC NHẬN RÚT TIỀN

Hình 2.20: Màn hình giao dịch nạp/rút tiền tại quầy

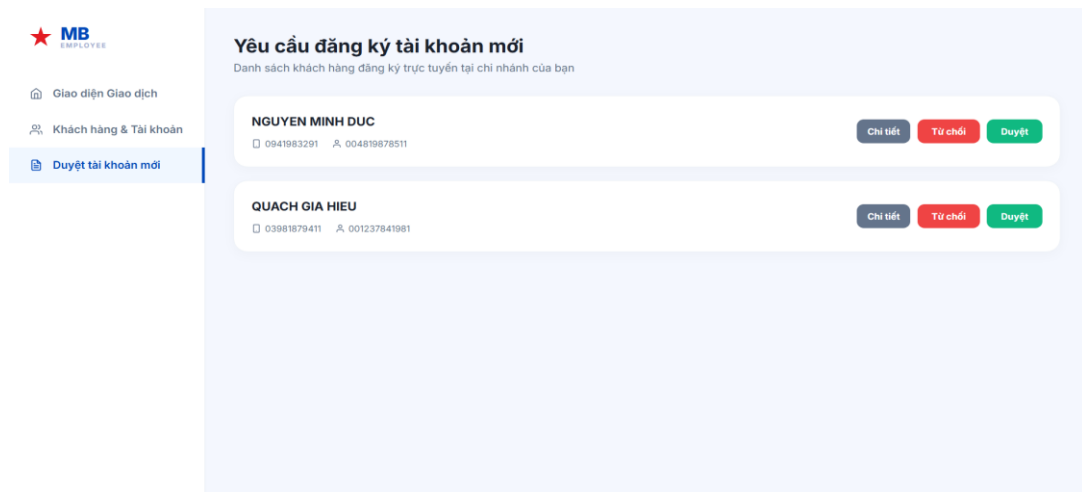
c) Màn hình quản lý khách hàng

Màn hình quản lý khách hàng trình bày danh sách toàn bộ khách hàng thuộc chi nhánh của nhân viên đang đăng nhập. Mỗi dòng trong bảng hiển thị các thông tin cơ bản: mã khách hàng, họ tên, số CCCD, số điện thoại và trạng thái tài khoản. Thanh tìm kiếm phía trên cho phép lọc theo tên hoặc số điện thoại.

Điểm quan trọng nhất trong màn hình này là danh sách Hồ sơ chờ duyệt để hiển thị nổi bật các yêu cầu đăng ký mở tài khoản đang ở trạng thái PENDING. Nhân viên xem chi tiết hồ sơ, kiểm tra thông tin KYC, rồi nhấn nút Duyệt hoặc Từ chối kèm lý do cụ thể. Khi duyệt, hệ thống tự động tạo tài khoản và cập nhật trạng thái, nhân viên không cần thao tác thêm bước nào.



Hình 2.21: Màn hình quản lý tài khoản khách hàng



Hình 2.22: Màn hình quản lý và duyệt hồ sơ khách hàng

2.6.3.3 Giao diện của quản trị hệ thống

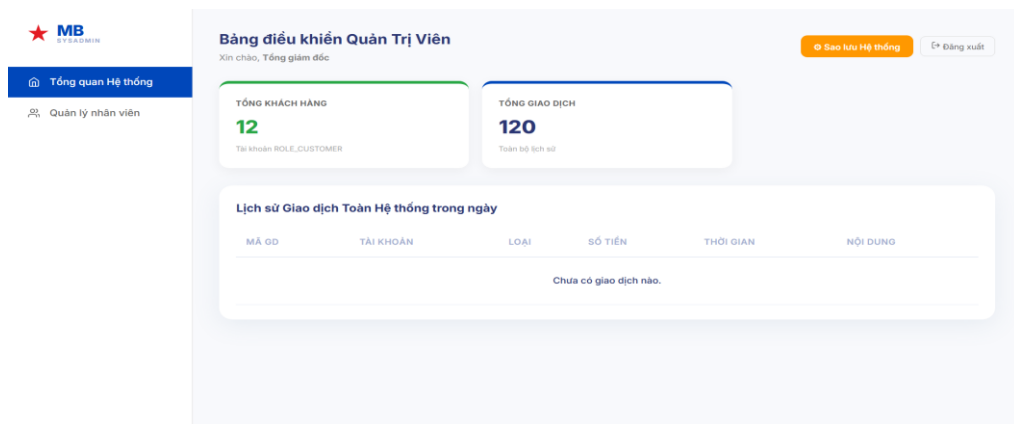
Phân hệ giao diện dành cho Quản trị hệ thống (SysAdmin) cung cấp góc nhìn toàn cục về toàn bộ hoạt động của ngân hàng. Khác với hai phân hệ trước, giao diện quản trị không giới hạn dữ liệu theo chi nhánh. Admin có quyền xem và can thiệp vào tất cả đơn vị trong hệ thống. Phân hệ này tập trung vào ba chức năng chính: giám sát tổng quan qua dashboard, quản lý nhân sự và kiểm soát truy cập hệ thống.

a) Màn hình Dashboard quản trị

Dashboard là màn hình đầu tiên Admin thấy sau khi đăng nhập. Giao diện trình bày các chỉ số tổng quan của toàn hệ thống thông qua các thẻ thống

kê (statistic card): tổng số khách hàng đang hoạt động, tổng số nhân viên, số chi nhánh và số hồ sơ đang chờ duyệt trên toàn hệ thống.

Phần hồ sơ chờ duyệt được hiển thị nổi bật bằng màu cảnh báo khi có số lượng tồn đọng lớn, giúp Admin phát hiện nhanh tình trạng ách tắc nghiệp vụ tại một chi nhánh cụ thể. Dashboard không chứa nút thao tác, chức năng của màn hình này chỉ là giám sát và định hướng sang các màn hình quản lý chi tiết phù hợp.

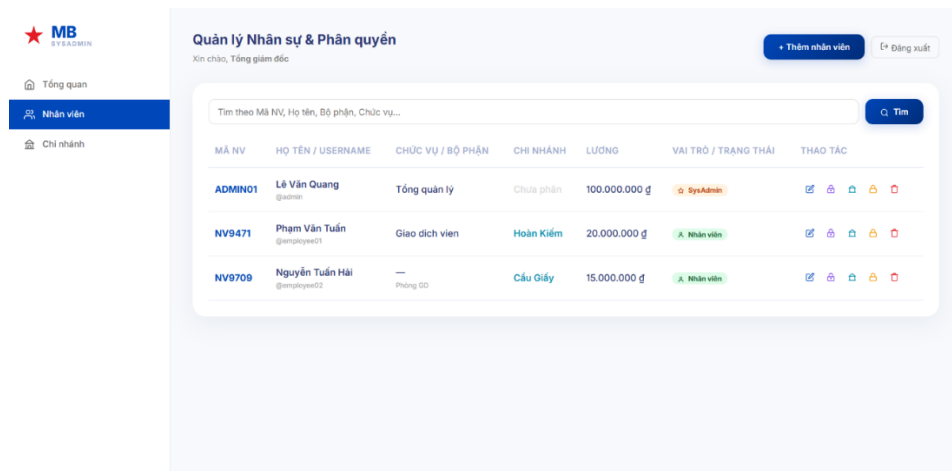


Hình 2.23: Màn hình Dashboard tổng quan quản trị hệ thống

b) Màn hình quản lý nhân viên

Màn hình quản lý nhân viên cho phép Admin thực hiện đầy đủ nghiệp vụ nhân sự: thêm nhân viên mới, chỉnh sửa thông tin (vị trí, bộ phận, lương), phân công chi nhánh và vô hiệu hóa tài khoản nhân viên khi cần. Bảng danh sách hiển thị toàn bộ nhân viên của tất cả chi nhánh, có thể lọc theo chi nhánh hoặc tìm kiếm theo tên.

Tính năng quan trọng nhất trong màn hình này là phân công chi nhánh. Khi Admin gán một nhân viên vào chi nhánh cụ thể, cột `branch_id` trong cơ sở dữ liệu được cập nhật, và từ đó nhân viên chỉ thấy dữ liệu của chi nhánh được gán. Chức năng vô hiệu hóa tài khoản nhân viên (chuyển status sang LOCKED) cho phép Admin thu hồi quyền truy cập hệ thống ngay lập tức khi nhân viên nghỉ việc mà không cần xóa dữ liệu lịch sử.

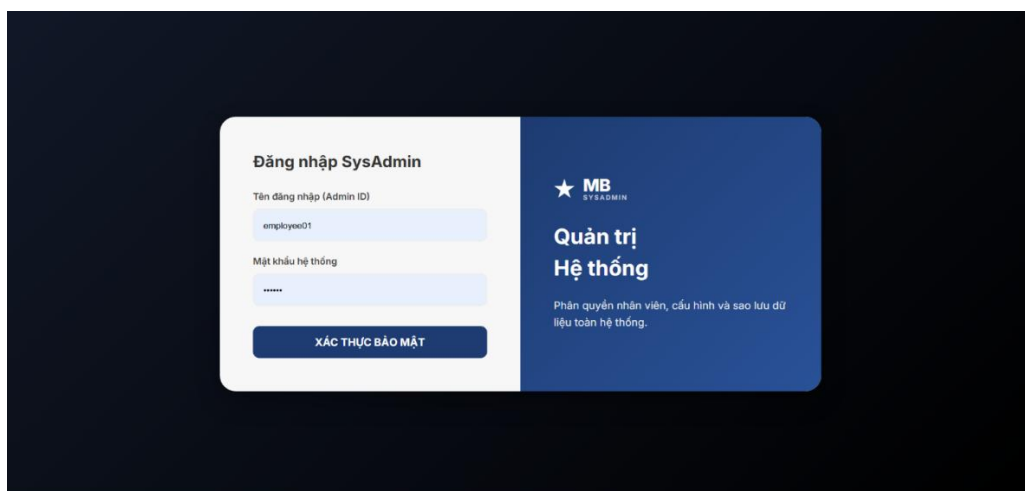


Hình 2.24: Màn hình quản lý thông tin và phân quyền nhân viên

c) Màn hình đăng nhập quản trị

Màn hình đăng nhập dành cho quản trị viên có cấu trúc tương tự các phân hệ khác nhưng được phân biệt bằng nhãn rõ ràng "Đăng nhập Quản trị hệ thống". Sau khi xác thực, Spring Security đọc role `ROLE_SYSADMIN` và chuyển hướng đến dashboard quản trị (`/admin/dashboard`). Tài khoản admin được cấu hình với quyền cao nhất trong hệ thống và không có giới hạn chi nhánh.

Việc tồn tại màn hình đăng nhập riêng biệt cho quản trị (hoặc redirect riêng theo role từ trang đăng nhập chung) đảm bảo rõ ràng về phạm vi quyền hạn.



Hình 2.25: Màn hình đăng nhập dành cho quản trị hệ thống

Tổng kết nguyên tắc thiết kế giao diện

Toàn bộ giao diện hệ thống được thiết kế thống nhất theo ba nguyên tắc xuyên suốt, tổng hợp trong bảng dưới đây:

Nguyên tắc	Biểu hiện cụ thể trong hệ thống
Xác nhận trước thao tác quan trọng	Chuyển khoản, duyệt hồ sơ, khóa tài khoản đều có bước hiển thị thông tin xác nhận
Phản hồi rõ ràng	Mọi thao tác thành công/thất bại đều có thông báo kết quả kèm mã giao dịch hoặc lý do lỗi
Phân tách dữ liệu theo vai trò	URL, dữ liệu hiển thị và chức năng thao tác hoàn toàn tách biệt giữa ba nhóm người dùng
Responsive Design	Bootstrap 5 đảm bảo giao diện hiển thị đúng trên cả màn hình máy tính và thiết bị di động

Bảng 2.12: Tổng hợp nguyên tắc thiết kế giao diện người dùng

CHƯƠNG 3: XÂY DỰNG VÀ KIỂM THỬ HỆ THỐNG

3.1 Công nghệ và công cụ sử dụng

Việc lựa chọn công nghệ cho hệ thống quản lý ngân hàng không chỉ dựa trên sự phổ biến mà còn phải đáp ứng khắt khe các tiêu chuẩn về tính bảo mật, sự ổn định và khả năng xử lý giao dịch phức tạp. Nhóm đề xuất bộ công nghệ sau dựa trên các yêu cầu nghiệp vụ thực tế.

3.1.1 Ngôn ngữ lập trình và Framework

Hệ thống (Backend):

Hệ thống sử dụng Java và hệ sinh thái Spring Boot.

Lý do lựa chọn:

- Tính bảo mật (Security): Khác với PHP, Java chạy trên máy ảo JVM với cơ chế quản lý bộ nhớ nghiêm ngặt, giảm thiểu rủi ro bảo mật. Spring Boot tích hợp sẵn Spring Security, giúp dễ dàng triển khai các lớp bảo mật, xác thực người dùng bằng mã hóa mật khẩu (BCrypt) và kiểm soát quyền truy cập chặt chẽ (Role-Based Access Control) cho Khách hàng, Nhân viên, Quản trị viên.

- Xử lý giao dịch (Transaction Management): Ngân hàng yêu cầu tính nhất quán (Consistency) tuyệt đối. Khác với Node.js vốn thiên về xử lý I/O không đồng bộ, Java và Spring Data JPA hỗ trợ hoàn hảo các cơ chế quản lý giao dịch ACID (@Transactional). Điều này đảm bảo nếu một bước trong quy trình chuyển khoản thất bại, toàn bộ thao tác sẽ được hoàn tác (Rollback), ngăn chặn triệt để tình trạng tiền bị trừ ở tài khoản nguồn nhưng tài khoản đích không nhận được.

- Khả năng mở rộng (Scalability): Spring Boot phân chia kiến trúc thành các layer rõ ràng (Controller, Service, Repository), rất dễ dàng nâng cấp hoặc chuyển đổi sang kiến trúc Microservices khi hệ thống mở rộng quy mô trong tương lai.

Giao diện (Frontend):

Hệ thống sử dụng HTML5, CSS3, JavaScript kết hợp cùng Bootstrap 5 và Thymeleaf.

Lý do lựa chọn:

- Bootstrap: Cung cấp sẵn các component chuẩn, hỗ trợ Responsive Design hoàn hảo, giúp giao diện ngân hàng hiển thị tốt trên mọi thiết bị (Mobile, Tablet, PC) mà không tốn quá nhiều thời gian viết CSS thủ công.

- Thymeleaf (So với React/Vue.js): Thay vì tách biệt hoàn toàn Frontend như React/Vue (đòi hỏi phải xây dựng hệ thống API phức tạp hơn và quản lý state rườm rà), Thymeleaf là Template Engine được tích hợp chuẩn (native) với Spring Boot. Nó cho phép render dữ liệu động trực tiếp từ Controller xuống giao diện một cách mượt mà, tốc độ tải trang nhanh và đặc biệt an toàn trước các cuộc tấn công XSS (Cross-Site Scripting).

Hệ quản trị cơ sở dữ liệu

Hệ thống sử dụng MySQL.

Lý do lựa chọn:

- Đảm bảo tính toàn vẹn dữ liệu (ACID): Khác với các hệ quản trị NoSQL như MongoDB (thường đánh đổi tính nhất quán lấy tốc độ), MySQL (với InnoDB engine) tuân thủ chặt chẽ nguyên

tắc ACID, đảm bảo mọi giao dịch nạp/rút/chuyển khoản không bao giờ bị sai lệch.

- Phù hợp với quy mô dự án: So với Microsoft SQL Server (thường yêu cầu bản quyền đắt đỏ và tốn nhiều tài nguyên server), MySQL hoàn toàn miễn phí, nhẹ nhàng nhưng vẫn đáp ứng xuất sắc khối lượng dữ liệu lớn và tốc độ truy vấn cao. Ngoài ra, MySQL tương thích hoàn hảo với hệ sinh thái mã nguồn mở của Java.

- Khóa ngoại (Foreign Key) chặt chẽ: MySQL hỗ trợ tạo các liên kết ràng buộc dữ liệu (ví dụ: một giao dịch bắt buộc phải tham chiếu đến một tài khoản có thật), giúp dữ liệu luôn an toàn và logic.

3.1.2 Công cụ phát triển và Quản lý

IntelliJ IDEA: Công cụ này hỗ trợ kiểm soát lỗi mã nguồn ngay trong lúc viết, đặc biệt quan trọng khi lập trình các hàm tính toán tài chính để tránh sai sót do con người.

Git & GitHub: Thay vì chia sẻ file code thủ công (dễ gây mất mát hoặc lẫn lộn phiên bản), Git giúp nhóm quản lý các phiên bản mã nguồn, cho phép các thành viên làm việc độc lập trên từng module mà không bị xung đột .

3.2 Xây dựng hệ thống quản lý ngân hàng

Hệ thống quản lý ngân hàng MB Bank được xây dựng theo kiến trúc ba tầng (Three - Tier Architecture) kết hợp với mô hình MVC (Model - View - Controller), đảm bảo sự tách biệt rõ ràng giữa tầng giao diện, tầng xử lý nghiệp vụ và tầng dữ liệu. Toàn bộ mã nguồn được tổ chức theo các package chức năng độc lập, tuân thủ nguyên tắc SOLID nhằm tạo nền tảng vững chắc cho việc bảo trì và mở rộng hệ thống trong tương lai.

3.2.1 Cấu trúc mã nguồn

Mã nguồn hệ thống được tổ chức thành sáu package chính thuộc namespace `com.mbbank.mbbSystem`. Mỗi package đảm nhận đúng một trách nhiệm duy nhất, giúp lập trình viên dễ dàng định vị, chỉnh sửa và kiểm thử từng thành phần mà không gây ảnh hưởng lan sang các phần khác.

Package	Vai trò	Thành phần tiêu biểu
controller	Tiếp nhận HTTP Request, điều phối dữ liệu giữa View và Service	CustomerController, EmployeeController, AdminController
service	Chứa toàn bộ logic nghiệp vụ cốt lõi	TransactionService, AccountRegistrationService, SavedRecipientService
repository	Giao tiếp với cơ sở dữ liệu qua Spring Data JPA	AccountRepository, TransactionRepository, UserRepository
model	Các Entity class ánh xạ tới bảng trong MySQL	Customer, Employee, Account, Transaction, Branch
security	Cấu hình xác thực, phân quyền và bộ lọc JWT	SecurityConfig, JwtFilter, UserDetailsServiceImpl
dto	Đối tượng trung gian truyền dữ liệu giữa các tầng	TransactionRequest, AccountRegRequest

Bảng 3.1: Cấu trúc package mã nguồn hệ thống

Nguyên tắc phân tầng và luồng xử lý

Mọi request từ người dùng đi theo một chiều duy nhất qua các tầng: Controller nhận request và kiểm tra dữ liệu đầu vào, gọi xuống Service để xử lý nghiệp vụ. Service áp dụng các quy tắc kinh doanh, kiểm tra điều kiện hợp lệ, rồi gọi Repository để truy vấn hoặc cập nhật cơ sở dữ liệu. Kết quả được trả ngược lên Controller và render ra giao diện thông qua Thymeleaf template. Chiều dữ liệu một chiều này loại bỏ hoàn toàn sự phụ thuộc chéo giữa các tầng.

```
src/main/java/com/mbbank/mbbSystem/
├── controller/
│   ├── CustomerController.java    // /customer/**
│   ├── EmployeeController.java    // /employee/**
│   └── AdminController.java       // /admin/**
├── service/
│   ├── TransactionService.java    // @Transactional
│   ├── AccountRegistrationService.java
│   └── SavedRecipientService.java
├── repository/                   // extends JpaRepository<>
├── model/                        // @Entity, @Table
└── security/                     // Spring Security + JWT
```

3.2.2 Cài đặt chức năng Quản lý mở tài khoản trực tuyến

Chức năng mở tài khoản được số hóa hoàn toàn theo quy trình duyệt hồ sơ trực tuyến, thay thế việc nhập liệu thủ công tại quầy giao dịch. Quy trình gồm ba giai đoạn chính, phối hợp giữa khách hàng, nhân viên ngân hàng và hệ thống tự động.

Giai đoạn 1: Khách hàng gửi yêu cầu đăng ký

Khách hàng truy cập trang đăng ký công khai (/register), điền đầy đủ thông tin cá nhân bao gồm họ tên, số CCCD, số điện thoại, địa chỉ và lựa chọn chi nhánh mong muốn. Sau khi gửi form, EmployeeController tiếp nhận

request, tạo một bản ghi AccountRegistrationRequest với trạng thái PENDING và lưu xuống cơ sở dữ liệu. Trạng thái PENDING cho biết hồ sơ đang chờ xét duyệt và chưa có tài khoản nào được tạo.

```
// AccountRegistrationController.java
@PostMapping("/register")
public String submitRegistration(@ModelAttribute AccountRegRequest request) {
    request.setStatus("PENDING");
    request.setCreatedAt(LocalDateTime.now());
    registrationRepository.save(request);
    return "redirect:/register?success";
}
```

Giai đoạn 2: Nhân viên xét duyệt hồ sơ (KYC)

Nhân viên ngân hàng đăng nhập vào hệ thống và truy cập danh sách hồ sơ chờ duyệt. Hệ thống chỉ hiển thị các hồ sơ thuộc đúng chi nhánh của nhân viên đó được lọc theo trường branch_id đảm bảo nhân viên không thể xem hay can thiệp hồ sơ của chi nhánh khác. Nhân viên kiểm tra tính hợp lệ của thông tin (KYC) sau đó chọn Duyệt hoặc Từ chối kèm lý do cụ thể.

Giai đoạn 3: Hệ thống tự động sinh tài khoản

Khi nhân viên xác nhận duyệt hồ sơ, AccountRegistrationService thực hiện chuỗi thao tác tự động sau:

- Lấy số điện thoại của khách hàng làm số tài khoản đảm bảo tính duy nhất tự nhiên và dễ nhớ.
- Mã hóa mật khẩu mặc định bằng BCrypt trước khi lưu, tuyệt đối không lưu plaintext.

- Tạo bản ghi User với role ROLE_CUSTOMER và trạng thái ACTIVE.
- Tạo bản ghi Customer liên kết với User và chi nhánh tương ứng.
- Tạo bản ghi Account với số dư khởi tạo bằng 0.
- Cập nhật trạng thái AccountRegistrationRequest từ PENDING sang APPROVED.

```
// AccountRegistrationService.java
@Transactional
public void approveRegistration(Long requestId, String employeeId) {
    AccountRegRequest req = registrationRepo.findById(requestId)
        .orElseThrow();

    // Tạo User với mật khẩu đã băm BCrypt
    User user = new User();
    user.setUsername(req.getPhone());
    user.setPassword(passwordEncoder.encode(req.getPassword()));
    user.setRole("ROLE_CUSTOMER");
    user.setStatus("ACTIVE");
    userRepo.save(user);

    // Tạo Customer và Account
    Customer customer = new Customer(req, user);
    customerRepo.save(customer);

    Account account = new Account();
    account.setAccountNumber(req.getPhone()); // STK = SĐT
    account.setBalance(0.0);
```

```

account.setCustomer(customer);
accountRepo.save(account);

// Đánh dấu đã duyệt
req.setStatus("APPROVED");
registrationRepo.save(req);
}

```

3.2.3 Cài đặt chức năng Giao dịch tài chính

Giao dịch tài chính là chức năng cốt lõi và phức tạp nhất của hệ thống. Toàn bộ logic được tập trung tại TransactionService, áp dụng hai nguyên tắc kỹ thuật bắt buộc: kiểm tra nghiệp vụ chặt chẽ trước mỗi giao dịch và bảo toàn tính toàn vẹn dữ liệu thông qua cơ chế ACID.

3.2.3.1 Nạp tiền và rút tiền tại quầy

Chức năng nạp tiền và rút tiền do nhân viên ngân hàng thực hiện thông qua giao diện nội bộ. Quy trình xử lý gồm các bước kiểm tra tuần tự trước khi cập nhật số dư:

- Kiểm tra tài khoản: Hệ thống truy vấn cơ sở dữ liệu xác nhận số tài khoản nhập vào có tồn tại và đang ở trạng thái ACTIVE. Tài khoản bị khóa (LOCKED) không thể thực hiện giao dịch.
- Kiểm tra số dư (chỉ áp dụng cho rút tiền): Số dư hiện tại phải lớn hơn hoặc bằng số tiền cần rút. Nếu không đủ, hệ thống trả về thông báo lỗi và dừng xử lý.
- Cập nhật số dư: Cộng hoặc trừ số tiền vào tài khoản, lưu bản ghi cập nhật.
- Ghi lịch sử giao dịch: Tạo bản ghi Transaction với mã giao dịch tự động, loại giao dịch, số tiền, thời điểm và tên nhân viên thực hiện (trường performed_by) phục vụ kiểm toán.


```

// TransactionService.java — Rút tiền
@Transactional
public void withdraw(String accountNumber, double amount, String
employeeId) {
    Account account = accountRepo.findByAccountNumber(accountNumber)
        .orElseThrow(() -> new RuntimeException("Tài khoản không tồn tại"));

    if (!account.getStatus().equals("ACTIVE"))
        throw new RuntimeException("Tài khoản đang bị khóa");

    if (account.getBalance() < amount)
        throw new RuntimeException("Số dư không đủ");

    // Cập nhật số dư
    account.setBalance(account.getBalance() - amount);
    accountRepo.save(account);

    // Ghi lịch sử — mã: "RUT" + yyyyMMddHHmmss + random(3 chữ số)
    Transaction tx = new Transaction();
    tx.setMagd("RUT" + generateCode());
    tx.setType("WITHDRAW");
    tx.setAmount(amount);
    tx.setPerformedBy(employeeId);
    tx.setAccount(account);
    transactionRepo.save(tx);
}

```

3.2.3.2 Chuyển khoản trực tuyến

Chuyển khoản là giao dịch phức tạp nhất vì liên quan đến hai tài khoản đồng thời. Bất kỳ sự cố nào xảy ra giữa chừng đều có thể dẫn đến tình trạng tiền bị trừ ở tài khoản nguồn nhưng tài khoản đích không nhận được. Hệ thống giải quyết vấn đề này bằng cách bọc toàn bộ ba bước xử lý trong một transaction ACID duy nhất với annotation `@Transactional`.

Hệ thống thực hiện các kiểm tra nghiệp vụ theo thứ tự trước khi tiến hành chuyển tiền:

- Số tiền chuyển phải lớn hơn 0 và là số hợp lệ.
- Số tài khoản đích phải tồn tại trong cơ sở dữ liệu.
- Số tài khoản đích không được trùng với tài khoản nguồn.
- Số dư tài khoản nguồn phải lớn hơn hoặc bằng số tiền cần chuyển.

Nếu tất cả điều kiện thỏa mãn, `TransactionService` thực hiện ba bước sau trong cùng một transaction:

```
// TransactionService.java — Chuyển khoản
@Transactional          // Spring quản lý toàn bộ khối này
public void transfer(String fromAccNo, String toAccNo,
                    double amount, String content) {
    // --- Kiểm tra đầu vào ---
    if (amount <= 0) throw new RuntimeException("Số tiền không hợp lệ");
    if (fromAccNo.equals(toAccNo))
        throw new RuntimeException("Không thể tự chuyển khoản cho mình");

    Account from =
    accountRepo.findByAccountNumber(fromAccNo).orElseThrow();
```

```

Account to = accountRepo.findByAccountNumber(toAccNo)
                .orElseThrow(() -> new RuntimeException("STK đích không tồn
tại"));

if (from.getBalance() < amount)
    throw new RuntimeException("Số dư không đủ");

// Bước 1: Trừ tiền tài khoản nguồn
from.setBalance(from.getBalance() - amount);
accountRepo.save(from);

// Bước 2: Cộng tiền tài khoản đích
// Nếu lỗi tại đây → Spring tự ROLLBACK Bước 1
to.setBalance(to.getBalance() + amount);
accountRepo.save(to);

// Bước 3: Ghi lịch sử giao dịch
Transaction tx = new Transaction();
tx.setMagd("CK" + generateCode()); // CK + timestamp + random
tx.setType("TRANSFER");
tx.setAmount(amount);
tx.setContent(content);
tx.setAccount(from);
tx.setToAccount(to);
transactionRepo.save(tx);

// Lưu người nhận vào danh bạ cá nhân
savedRecipientService.saveIfNotExists(from.getCustomer(), to);
}

```

3.2.3.3 Danh bạ người nhận thông minh

Sau mỗi lần chuyển khoản thành công, hệ thống tự động gọi SavedRecipientService để kiểm tra xem người nhận đã có trong danh bạ của khách hàng chưa. Nếu chưa, hệ thống tạo mới bản ghi với thông tin số tài khoản và tên người nhận. Lần chuyển khoản tiếp theo, khách hàng có thể chọn nhanh từ danh bạ thay vì nhập lại số tài khoản giúp giảm rủi ro nhập sai và nâng cao trải nghiệm sử dụng.

3.2.4 Cài đặt chức năng Bảo mật và Phân quyền

Hệ thống triển khai mô hình bảo mật đa lớp dựa trên Spring Security framework, bao gồm ba cơ chế phối hợp: mã hóa mật khẩu một chiều bằng BCrypt, xác thực không trạng thái bằng JWT Token, và phân quyền truy cập theo vai trò (Role-Based Access Control - RBAC). Chi tiết kỹ thuật của từng cơ chế được trình bày đầy đủ tại mục 3.2.5.

3.2.4.1 Xác thực người dùng

Khi người dùng gửi yêu cầu đăng nhập, Spring Security chuyển thông tin đến UserDetailsServiceImpl - lớp triển khai interface UserDetailsService để tải thông tin người dùng từ cơ sở dữ liệu theo username. Tiếp theo, BCryptPasswordEncoder.matches() so khớp mật khẩu vừa nhập với chuỗi hash đã lưu. Nếu khớp và tài khoản đang ở trạng thái ACTIVE, hệ thống sinh JWT Token chứa thông tin username, role và thời hạn hiệu lực, trả về cho client.

Hệ thống từ chối đăng nhập trong các trường hợp: mật khẩu sai, tài khoản không tồn tại, tài khoản đang ở trạng thái LOCKED hoặc INACTIVE. Mọi trường hợp từ chối đều trả về mã lỗi HTTP 401 Unauthorized.

3.2.4.2 Phân quyền truy cập

SecurityFilterChain là thành phần trung tâm kiểm soát quyền truy cập. Mọi HTTP request đều đi qua chuỗi bộ lọc này trước khi chạm đến Controller. Cấu hình phân quyền URL được định nghĩa tập trung trong SecurityConfig:

```
// SecurityConfig.java

@Bean
public SecurityFilterChain filterChain(HttpSecurity http) throws Exception {
    http
        .authorizeHttpRequests(auth -> auth
            // URL công khai — không cần đăng nhập
            .requestMatchers("/register", "/login", "/css/**", "/js/**")
                .permitAll()
            // Chỉ dành cho khách hàng
            .requestMatchers("/customer/**").hasRole("CUSTOMER")

            // Chỉ dành cho nhân viên ngân hàng
            .requestMatchers("/employee/**").hasRole("EMPLOYEE")

            // Chỉ dành cho quản trị hệ thống
            .requestMatchers("/admin/**").hasRole("SYSADMIN")

            // Mọi URL còn lại yêu cầu đăng nhập
            .anyRequest().authenticated()
        )
        .addFilterBefore(jwtFilter, UsernamePasswordAuthenticationFilter.class)
        .sessionManagement(s -> s.sessionCreationPolicy(STATELESS));
    return http.build();
}
```

Vai trò	URL được phép
ROLE_CUSTOMER	/customer/**
ROLE_EMPLOYEE	/employee/**
ROLE_SYSADMIN	/admin/**
Chưa đăng nhập	/register, /login

Bảng 3.2: Phân quyền truy cập trong hệ thống

3.2.4.3 Kiểm soát truy cập tầng dữ liệu

Ngoài phân quyền theo URL, hệ thống còn áp dụng kiểm soát truy cập ở tầng dữ liệu. Mỗi nhân viên chỉ được phép xem và xử lý hồ sơ, khách hàng thuộc đúng chi nhánh của mình — được lọc thông qua trường `branch_id`. Thiết kế này ngăn chặn việc một nhân viên ở chi nhánh A truy cập dữ liệu của chi nhánh B dù cùng mang vai trò `ROLE_EMPLOYEE`.

```
// EmployeeService.java — Chỉ lấy hồ sơ của chi nhánh mình
public List<AccountRegRequest> getPendingRequests(String
employeeUsername) {
    Employee emp = employeeRepo.findByUsername(employeeUsername);
    return registrationRepo.findByBranchIdAndStatus(
        emp.getBranch().getId(),
        "PENDING"
    );
}
```

3.2.4.4 Quản lý trạng thái tài khoản

Mỗi bản ghi trong bảng users có trường status với hai giá trị: ACTIVE và LOCKED. Khi quản trị viên khóa một tài khoản, UserDetailsServiceImpl kiểm tra trường này và ném ngoại lệ LockedException => Spring Security tự động từ chối đăng nhập và trả về thông báo lỗi phù hợp. Tính năng này đặc biệt hữu ích để vô hiệu hóa tức thời tài khoản nhân viên nghỉ việc mà không cần xóa dữ liệu lịch sử.

3.2.5 Thiết kế và cài đặt hệ thống bảo mật

Bảo mật là yêu cầu phi chức năng quan trọng nhất đối với hệ thống ngân hàng. Hệ thống quản lý MB Bank được thiết kế theo mô hình bảo mật đa lớp (Defense in Depth), trong đó mỗi lớp đảm nhận một nhiệm vụ riêng biệt và độc lập với nhau. Cụ thể, hệ thống bao gồm bốn lớp bảo mật chính: mã hóa mật khẩu bằng BCrypt, xác thực không trạng thái bằng JWT, phân quyền truy cập theo vai trò (RBAC) thông qua Spring Security, và bảo toàn tính toàn vẹn dữ liệu tài chính bằng cơ chế giao dịch ACID.

3.2.5.1 Mã hóa mật khẩu bằng thuật toán BCrypt

Mật khẩu người dùng là thông tin nhạy cảm nhất trong hệ thống. Hệ thống tuyệt đối không lưu mật khẩu dưới dạng văn bản thuần (plaintext) hay các hàm băm yếu như MD5 hoặc SHA-1. Thay vào đó, toàn bộ mật khẩu được xử lý qua thuật toán BCrypt trước khi ghi vào cơ sở dữ liệu.

a) Nguyên lý hoạt động của BCrypt

BCrypt là thuật toán băm mật khẩu được thiết kế đặc biệt để chống lại các cuộc tấn công dò mật khẩu. Điểm khác biệt so với MD5 hay SHA là BCrypt tích hợp sẵn hai cơ chế bảo vệ:

- Salt ngẫu nhiên: Mỗi lần mã hóa, BCrypt tự sinh một chuỗi ngẫu nhiên (salt) và nhúng vào kết quả hash. Do đó, cùng một mật khẩu

"123456" nhưng hai người dùng khác nhau sẽ có chuỗi hash hoàn toàn khác nhau. Điều này vô hiệu hóa hoàn toàn các cuộc tấn công dùng rainbow table - bảng tra cứu hash được tính sẵn.

- Cost factor (hệ số chi phí): BCrypt có tham số điều chỉnh độ phức tạp tính toán (mặc định là 10 trong hệ thống). Tham số này khiến mỗi lần băm mật khẩu tốn khoảng 100ms - không ảnh hưởng đến trải nghiệm người dùng, nhưng nếu hacker muốn thử 1.000.000 mật khẩu sẽ mất hàng nghìn giờ.

- Chuỗi hash BCrypt có định dạng chuẩn gồm các thành phần sau:

```
$2a$10$2t780T.rv7QQRsqg492aiOUJP6ha0vA7SC3tu1pgnfnBn1lqzE43q
| | |
| | └── Hash 31 ký tự (chứa cả salt nhúng bên trong)
| └── Cost factor = 10 ( $2^{10} = 1024$  vòng lặp)
└── Phiên bản BCrypt (2a)
```

b) Triển khai thực tế trong hệ thống

Hệ thống sử dụng lớp BCryptPasswordEncoder được cung cấp sẵn bởi Spring Security. Quá trình xử lý mật khẩu diễn ra ở hai thời điểm:

Khi tạo tài khoản: AccountRegistrationService lấy mật khẩu từ form đăng ký, gọi encoder.encode() để băm rồi lưu chuỗi hash vào bảng users. Mật khẩu gốc không được lưu lại ở bất kỳ đâu.

```
// Khi duyệt hồ sơ và tạo tài khoản mới
String hashedPassword = passwordEncoder.encode(request.getPassword());
user.setPassword(hashedPassword);
userRepository.save(user);

// Kết quả lưu vào DB:
// '123456' → '$2a$10$2t780T.rv7QQRsqg492aiOU...' (60 ký tự)
```


Khi đăng nhập: Spring Security tự động gọi `encoder.matches(rawPassword, hashedPassword)` để so khớp. Phương thức này băm lại mật khẩu vừa nhập với đúng salt đã lưu rồi so sánh, không cần và không thể giải mã hash ngược lại.

3.2.5.2 Xác thực không trạng thái bằng JWT

Sau khi xác thực mật khẩu thành công, hệ thống cần một cơ chế để nhận diện người dùng ở các request tiếp theo mà không phải truy vấn cơ sở dữ liệu mỗi lần. Hệ thống sử dụng JWT (JSON Web Token) - một chuẩn xác thực mở cho phép server xác thực người dùng hoàn toàn từ thông tin trong token mà không cần lưu session phía server.

a) Cấu trúc JWT Token

Một JWT Token là chuỗi ký tự gồm ba phần ngăn cách nhau bởi dấu chấm (.), mỗi phần được mã hóa base64url:

Ví dụ:

```
“eyJhbGciOiJIUzI1NiJ9
.eyJ1c2VybmFtZSI6IjAzNTkyMTc0NjliLCJyb2xlIjoiaUk9MRV9DVVN
UT01FUlIsImV4cCI6Li4ufQ
.SflKxwRJSMeKKF2QT4fwpMeJf36POk6yJV_adQssw5c”
```

Sau khi giải mã:

Phần 1 - Header: { "alg": "HS256", "typ": "JWT" }

→ Khai báo thuật toán ký: HMAC-SHA256

Phần 2 - Payload: {

"username": "0359299999", // định danh người dùng

"role": "ROLE_CUSTOMER", // vai trò - dùng để phân quyền

"iat": 1714280000, // thời điểm cấp token

"exp": 1714366400 // thời điểm hết hạn

}

Phần 3 - Signature: HMACSHA256(header + "." + payload, SECRET_KEY)

→ Chữ ký số: Đảm bảo token không bị giả mạo

b) Luồng hoạt động JWT trong hệ thống

Quá trình xác thực bằng JWT diễn ra qua hai giai đoạn chính:

- Giai đoạn cấp token: Người dùng gửi username và password đến endpoint đăng nhập. Sau khi BCrypt xác nhận mật khẩu đúng, hệ thống tạo JWT Token có chứa username và role, ký bằng SECRET_KEY chỉ server biết, rồi trả về cho client.

- Giai đoạn sử dụng token: Với mỗi request tiếp theo, client đính kèm token trong HTTP header. SecurityFilterChain của Spring Security chặn request, trích xuất token, xác minh chữ ký bằng SECRET_KEY. Nếu chữ ký hợp lệ và token chưa hết hạn, hệ thống đọc role từ payload và quyết định cho phép hay từ chối truy cập - hoàn toàn không cần truy vấn cơ sở dữ liệu.

c) Tính bảo mật của JWT

Tính an toàn của JWT được đảm bảo qua cơ chế chữ ký số. Nếu một kẻ tấn công cố tình sửa payload - chẳng hạn đổi role từ ROLE_CUSTOMER thành ROLE_SYSADMIN - chữ ký ở phần 3 sẽ không còn khớp với nội dung đã sửa. Server sẽ phát hiện ngay và từ chối token. Kẻ tấn công không thể tạo chữ ký hợp lệ vì không biết SECRET_KEY.

Lưu ý: Payload chỉ được base64 encode - bất kỳ ai cũng có thể đọc được nội dung nếu có token. Vì vậy, payload tuyệt đối không chứa mật khẩu, số tài khoản hay dữ liệu nhạy cảm khác - chỉ chứa định danh và quyền hạn.

3.2.5.3 Phân quyền truy cập theo vai trò

Hệ thống áp dụng mô hình kiểm soát truy cập dựa trên vai trò (Role-Based Access Control - RBAC). Mỗi người dùng được gán một trong ba vai

trò cố định, lưu trong cột role của bảng users trong cơ sở dữ liệu. Ba vai trò này hoàn toàn tách biệt về quyền hạn và phạm vi truy cập:

Vai trò	URL được phép truy cập	Chức năng chính
ROLE_CUSTOMER	/customer/**	Chuyển khoản, xem số dư, xem lịch sử giao dịch
ROLE_EMPLOYEE	/employee/**	Duyệt hồ sơ, nạp/rút tiền tại quầy, quản lý khách hàng
ROLE_SYSADMIN	/admin/** (toàn bộ hệ thống)	Quản lý nhân viên, phân quyền, giám sát hệ thống

Bảng 3.3: Phân quyền truy cập theo vai trò trong hệ thống

Cấu hình phân quyền được thiết lập tập trung trong lớp SecurityConfig thông qua SecurityFilterChain — một chuỗi bộ lọc chặn toàn bộ HTTP request trước khi chúng đến Controller:

```
// SecurityConfig.java — cấu hình phân quyền URL
http.authorizeHttpRequests(auth -> auth
    .requestMatchers("/customer/**").hasRole("CUSTOMER")
    .requestMatchers("/employee/**").hasRole("EMPLOYEE")
    .requestMatchers("/admin/**").hasRole("SYSADMIN")
    .requestMatchers("/register", "/login").permitAll()
    .anyRequest().authenticated()
);
```

Khi một request đến, SecurityFilterChain kiểm tra token JWT, trích xuất role và so với quy tắc cấu hình. Nếu role không khớp, ví dụ khách hàng cố gõ

trực tiếp URL /employee/transactions => hệ thống trả về lỗi HTTP 403 Forbidden ngay lập tức, không có bất kỳ dữ liệu nào được trả về.

Ngoài phân quyền theo URL, hệ thống còn kiểm soát truy cập ở tầng dữ liệu. Nhân viên chi nhánh A chỉ thấy hồ sơ và khách hàng thuộc chi nhánh A. Điều này ngăn chặn một nhân viên truy cập dữ liệu của chi nhánh khác dù cùng vai trò ROLE_EMPLOYEE.

Bên cạnh phân quyền, hệ thống còn hỗ trợ khóa tài khoản thông qua cột status trong bảng users. Khi tài khoản ở trạng thái LOCKED, Spring Security từ chối đăng nhập dù mật khẩu đúng => hữu ích khi cần vô hiệu hóa tài khoản nhân viên nghỉ việc hoặc khách hàng vi phạm chính sách.

3.2.6 Thiết kế mã giao dịch tự động

Mỗi giao dịch tài chính trong hệ thống được gán một mã định danh duy nhất (mã giao dịch) sinh tự động tại thời điểm giao dịch diễn ra. Mã này phục vụ hai mục đích: tra cứu và đối soát khi có tranh chấp, đồng thời cung cấp audit trail đầy đủ cho hoạt động giám sát nội bộ.

3.2.6.1 Quy tắc sinh mã giao dịch

Mã giao dịch được thiết kế theo cấu trúc ba phần ghép nối liền:

[TIỀN_TỔ] + [NGÀY_GIỜ] + [SỐ_NGẪU_NHIÊN]

Ví dụ từ cơ sở dữ liệu thực tế:

CK20260428091135180 ← Chuyển khoản

RUT20260428165306588 ← Rút tiền

Trong đó:

CK / RUT = Tiền tố phân loại nghiệp vụ

20260428 = Ngày giao dịch (yyyyMMdd)

091135 = Giờ phút giây (HHmmss)

180 / 588 = Số ngẫu nhiên 3 chữ số (tránh trùng cùng giây)

Bảng dưới đây liệt kê các loại tiền tố được sử dụng trong hệ thống:

Tiền tố	Loại giao dịch	Ví dụ thực tế
CK	Chuyển khoản (transfer)	CK20260428091135180
RUT	Rút tiền tại quầy (withdraw)	RUT20260428165306588
NAP	Nạp tiền tại quầy (deposit)	NAP20260428170000123

Bảng 3.4: Quy tắc tiền tố mã giao dịch

3.2.6.2 Vai trò của mã giao dịch trong kiểm soát nghiệp vụ

Mã giao dịch không chỉ là định danh kỹ thuật mà còn mang ý nghĩa nghiệp vụ. Khi tra cứu lịch sử giao dịch, nhân viên và khách hàng có thể ngay lập tức nhận biết loại giao dịch từ tiền tố mà không cần mở chi tiết. Tổ hợp ngày giờ trong mã cũng giúp xác định chính xác thời điểm xảy ra giao dịch để đối soát.

Đặc biệt, đối với các giao dịch rút tiền và nạp tiền tại quầy, cơ sở dữ liệu còn lưu thêm trường `performed_by`, ghi lại tên đăng nhập của nhân viên thực hiện giao dịch. Điều này giúp biết chính xác giao dịch nào, xảy ra khi nào, do nhân viên nào thực hiện.

Cột `magd` được ràng buộc UNIQUE trong cơ sở dữ liệu, đảm bảo tuyệt đối không tồn tại hai giao dịch cùng mã. Đây là tầng bảo vệ cuối cùng chống lại lỗi xử lý trùng lặp ngay cả trong trường hợp hệ thống gặp sự cố.

3.2.7 Thiết kế RESTful API

Hệ thống được xây dựng theo mô hình kiến trúc client-server, trong đó backend cung cấp các API theo chuẩn REST (Representational State Transfer) để giao tiếp với frontend. Toàn bộ các endpoint đều được bảo vệ bằng JWT token (trừ các endpoint công khai), đồng thời được phân quyền chặt chẽ theo ba vai trò: CUSTOMER, EMPLOYEE và SYSADMIN.

3.2.7.1 Nguyên tắc thiết kế API

Hệ thống tuân theo các nguyên tắc REST chuẩn: sử dụng đúng HTTP method (GET để truy vấn dữ liệu, POST để tạo mới, PUT để cập nhật, DELETE để xóa), đặt tên endpoint theo tài nguyên, và trả về mã trạng thái HTTP phù hợp với từng kết quả xử lý. Các endpoint được tổ chức thành nhóm, mỗi nhóm quản lý một tài nguyên nghiệp vụ riêng biệt.

3.2.7.2 Cơ chế phân quyền

Mỗi endpoint chỉ cho phép truy cập bởi một hoặc một số vai trò nhất định. Cụ thể, CUSTOMER chỉ được thao tác trên dữ liệu cá nhân của mình; EMPLOYEE có thể quản lý khách hàng và tài khoản trong phạm vi chi nhánh; SYSADMIN có toàn quyền trên toàn bộ hệ thống. Cơ chế kiểm tra quyền chi nhánh (branch-level authorization) được áp dụng tại tầng service để đảm bảo nhân viên không thể thao tác vượt ngoài chi nhánh được phân công.

3.2.7.3 Cấu trúc các nhóm API

Hệ thống gồm 8 nhóm controller chính, mỗi nhóm tương ứng với một base path riêng:

AuthController (/api/auth): Xử lý đăng nhập, đăng ký và tạo tài khoản người dùng. Endpoint đăng nhập trả về JWT token để xác thực các request tiếp theo. Nhân viên và SysAdmin có thể tạo tài khoản cho khách hàng và nhân viên mới.

AccountController (/api/account): Quản lý tài khoản ngân hàng. Hỗ trợ tra cứu theo số tài khoản, lấy danh sách tài khoản theo phân quyền, khóa và mở khóa tài khoản. Endpoint tra cứu thông tin chủ tài khoản phục vụ cho nghiệp vụ chuyển tiền.

TransactionController (/api/transaction): Xử lý toàn bộ nghiệp vụ giao dịch tài chính bao gồm chuyển tiền (do CUSTOMER thực hiện), nạp tiền

và rút tiền tại quầy (do EMPLOYEE thực hiện). Hỗ trợ tra cứu lịch sử giao dịch và tìm kiếm theo mã giao dịch.

CustomerController (/api/customer): Quản lý thông tin khách hàng. CUSTOMER chỉ xem được thông tin của chính mình; EMPLOYEE quản lý danh sách khách hàng trong chi nhánh; SYSADMIN xem toàn hệ thống. Không có chức năng xóa khách hàng nhằm bảo toàn lịch sử giao dịch.

EmployeeController (/api/employee): Quản lý nhân viên, chỉ dành cho SYSADMIN. Cho phép thêm, cập nhật, khóa, mở khóa và xóa nhân viên khỏi hệ thống.

BranchController (/api/branch): Quản lý chi nhánh. Danh sách chi nhánh được cung cấp ở cả dạng công khai (dùng cho trang đăng ký) và dạng yêu cầu xác thực. SysAdmin quản lý toàn bộ chi nhánh và phân công nhân viên; nhân viên quản lý chi nhánh có thể bổ sung quỹ tiền mặt.

RegistrationRequestController (/api/registration): Xử lý quy trình mở tài khoản trực tuyến. Khách hàng gửi yêu cầu mà không cần JWT; nhân viên xem xét và duyệt hoặc từ chối yêu cầu trong phạm vi chi nhánh.

SavedRecipientController (/api/contacts): Quản lý danh bạ chuyển tiền. Cho phép khách hàng lưu và xóa tài khoản thụ hưởng thường dùng, hỗ trợ tính năng danh bạ người nhận thông minh.

3.2.7.4 Danh sách API Endpoints

Method	Endpoint	Quyền truy cập	Chức năng
POST	/api/auth/login	Public	Đăng nhập, trả về JWT token cùng thông tin user.
POST	/api/auth/signup	Public	Đăng ký tài khoản.

POST	/api/auth/register-customer	EMPLOYEE	Nhân viên tạo khách hàng mới.
POST	/api/auth/register-employee	SYSADMIN	SysAdmin tạo tài khoản nhân viên mới.

Bảng 3.5: API Endpoints AuthController

Method	Endpoint	Quyền truy cập	Chức năng
GET	/api/account/my-accounts	CUSTOMER, EMPLOYEE, SYSADMIN	Lấy danh sách tài khoản ngân hàng của người dùng đang đăng nhập.
GET	/api/account/all	EMPLOYEE, SYSADMIN	Lấy tất cả tài khoản. SYSADMIN xem toàn hệ thống; EMPLOYEE chỉ xem tài khoản thuộc chi nhánh mình.
GET	/api/account/search?accountNumber=...	EMPLOYEE, SYSADMIN	Tìm tài khoản theo số tài khoản.
GET	/api/account/check?accountNumber=...	CUSTOMER, EMPLOYEE, SYSADMIN	Tra cứu tên chủ tài khoản, số điện thoại, CCCD, chi nhánh (dùng khi chuyển tiền).
PUT	/api/account/lock/{accountId}	EMPLOYEE	Khóa tài khoản ngân hàng. Có kiểm tra quyền chi nhánh (chỉ thao tác trên tài khoản thuộc chi nhánh mình).
PUT	/api/account/unlock/{accountId}	EMPLOYEE	Mở khóa tài khoản ngân hàng. Có kiểm tra quyền chi nhánh.

Bảng 3.6: API Endpoints AccountController

Method	Endpoint	Quyền truy cập	Chức năng
POST	/api/transaction/transfer	CUSTOMER	Chuyển tiền giữa 2 tài khoản. Xác thực tài khoản gửi phải thuộc sở hữu của người dùng hiện tại. Body: fromAccount, toAccount, amount, content.
POST	/api/transaction/deposit	EMPLOYEE	Nạp tiền vào tài khoản khách hàng. Ghi nhận tên nhân viên thực hiện. Body: toAccount, amount.
POST	/api/transaction/withdraw	EMPLOYEE	Rút tiền từ tài khoản khách hàng. Ghi nhận tên nhân viên thực hiện. Body: fromAccount, amount.
GET	/api/transaction/history/{accountNumber}	CUSTOMER, EMPLOYEE, SYSADMIN	Lấy lịch sử giao dịch của một số tài khoản cụ thể.
GET	/api/transaction/all	EMPLOYEE, SYSADMIN	Lấy toàn bộ danh sách giao dịch trong hệ thống.
GET	/api/transaction/search?maGD=...	EMPLOYEE, SYSADMIN	Tìm kiếm giao dịch theo mã giao dịch (maGD).

Bảng 3.7: API Endpoints TransactionController

Method	Endpoint	Quyền truy cập	Chức năng
GET	/api/customer/me	CUSTOMER	Khách hàng xem thông tin cá nhân của chính mình.
GET	/api/customer/list	EMPLOYEE	Danh sách khách hàng.
GET	/api/customer/list/all	SYSADMIN	SysAdmin xem toàn bộ khách hàng không phân biệt chi nhánh.

GET	/api/customer/search/{id}	EMPLOYEE	Tìm khách hàng theo ID.
GET	/api/customer/search?maKH=...	EMPLOYEE	Tìm khách hàng theo mã khách hàng.
POST	/api/customer/add	EMPLOYEE	Thêm khách hàng mới.
PUT	/api/customer/update/{id}	EMPLOYEE	Cập nhật thông tin khách hàng. Có kiểm tra quyền chi nhánh.
PUT	/api/customer/lock/{id}	EMPLOYEE	Khóa tài khoản khách hàng (đồng thời khóa tài khoản ngân hàng liên quan). Không có chức năng xóa để bảo toàn lịch sử giao dịch.
PUT	/api/customer/unlock/{id}	EMPLOYEE	Mở khóa tài khoản khách hàng và tài khoản ngân hàng.

Bảng 3.8: API Endpoints CustomerController

Method	Endpoint	Quyền truy cập	Chức năng
GET	/api/employee/me	EMPLOYEE	Nhân viên xem thông tin cá nhân của chính mình.
GET	/api/employee/list	SYSADMIN	SysAdmin xem danh sách toàn bộ nhân viên.
GET	/api/employee/search/{id}	SYSADMIN	SysAdmin tìm nhân viên theo ID.
GET	/api/employee/search?maNV=...	SYSADMIN	SysAdmin tìm nhân viên theo

			mã nhân viên (maNV).
POST	/api/employee/add	SYSADMIN	SysAdmin thêm nhân viên mới vào hệ thống.
PUT	/api/employee/update/{id}	SYSADMIN	SysAdmin cập nhật thông tin nhân viên.
PUT	/api/employee/lock/{id}	SYSADMIN	SysAdmin khóa tài khoản nhân viên.
PUT	/api/employee/unlock/{id}	SYSADMIN	SysAdmin mở khóa tài khoản nhân viên.
DELETE	/api/employee/delete/{id}	SYSADMIN	SysAdmin xóa nhân viên khỏi hệ thống.

Bảng 3.9: API Endpoints EmployeeController

Method	Endpoint	Quyền truy cập	Chức năng
GET	/api/branch/public/list	Public	Lấy danh sách chi nhánh (không cần JWT). Dùng cho trang đăng ký khách hàng.
GET	/api/branch/list	EMPLOYEE, SYSADMIN	Lấy danh sách tất cả chi nhánh (yêu cầu JWT).
GET	/api/branch/{id}	EMPLOYEE, SYSADMIN	Lấy thông tin chi tiết một chi nhánh theo ID.
POST	/api/branch/add	SYSADMIN	Tạo chi nhánh mới.

PUT	/api/branch/update/{id}	SYSADMIN	Cập nhật thông tin chi nhánh.
PUT	/api/branch/assign-employee	SYSADMIN	Phân công nhân viên vào chi nhánh.
POST	/api/branch/add-fund	EMPLOYEE	Quản lý chi nhánh bổ sung quỹ tiền mặt cho chi nhánh của mình.
DELETE	/api/branch/delete/{id}	SYSADMIN	Xóa chi nhánh.

Bảng 3.10: API Endpoints BranchController

Method	Endpoint	Quyền truy cập	Chức năng
POST	/api/registration/submit	Public	Khách hàng gửi yêu cầu mở tài khoản ngân hàng (không cần JWT).
GET	/api/registration/branch/list?status=..	EMPLOYEE	Nhân viên xem danh sách yêu cầu mở tài khoản của chi nhánh mình.
GET	/api/registration/all?status=...	SYSADMIN	SysAdmin xem tất cả yêu cầu mở tài khoản trên toàn hệ thống.
POST	/api/registration/{id}/approve	EMPLOYEE	Nhân viên duyệt yêu cầu mở tài khoản. Chỉ được duyệt yêu cầu thuộc chi nhánh mình.
POST	/api/registration/{id}/reject	EMPLOYEE	Nhân viên từ chối yêu cầu mở tài khoản.

Bảng 3.11: API Endpoints RegistrationRequestController

Method	Endpoint	Quyền truy cập	Chức năng
--------	----------	----------------	-----------

GET	/api/contacts/list	CUSTOMER	Lấy danh sách tài khoản thụ hưởng đã lưu của khách hàng đang đăng nhập.
DELETE	/api/contacts/{id}	CUSTOMER	Xóa một tài khoản thụ hưởng khỏi danh bạ theo ID.

Bảng 3.12: API Endpoints SavedRecipientController

3.3 Kiểm thử hệ thống

Kiểm thử là giai đoạn không thể thiếu trong quy trình phát triển phần mềm, đặc biệt quan trọng với hệ thống ngân hàng nơi mọi sai sót đều có thể dẫn đến hậu quả tài chính nghiêm trọng. Chương này trình bày kế hoạch kiểm thử tổng thể, các ca kiểm thử chi tiết và kết quả kiểm thử thực tế của hệ thống quản lý ngân hàng MB Bank.

3.3.1 Kế hoạch kiểm thử

Kế hoạch kiểm thử xác định phạm vi, chiến lược, phương pháp, môi trường và tiêu chí đánh giá cho toàn bộ hoạt động kiểm thử hệ thống. Mục tiêu tổng quát là xác nhận rằng hệ thống thực hiện đúng các yêu cầu chức năng đã đặt ra, đảm bảo tính toàn vẹn dữ liệu tài chính và không có lỗ hổng bảo mật nghiêm trọng.

3.3.1.1 Phạm vi kiểm thử

Kiểm thử bao phủ toàn bộ các chức năng nghiệp vụ cốt lõi của hệ thống, được phân nhóm theo ba phân hệ người dùng. Các thành phần kỹ thuật nằm ngoài phạm vi kiểm thử đợt này bao gồm: hiệu năng xử lý tải cao (load testing), kiểm thử giao diện tự động (UI automation) và tích hợp liên ngân hàng.

Phân hệ	Chức năng trong phạm vi kiểm thử
Khách hàng	Đăng ký tài khoản trực tuyến, đăng nhập, xem số dư, chuyển khoản, xem lịch sử giao dịch, quản lý danh bạ người nhận

Nhân viên	Đăng nhập, xem và duyệt/từ chối hồ sơ đăng ký, nạp tiền, rút tiền, tra cứu thông tin khách hàng, quản lý trạng thái tài khoản
Quản trị	Đăng nhập, quản lý nhân viên (thêm, sửa, khóa), phân công chi nhánh, xem dashboard tổng quan
Bảo mật	Kiểm tra phân quyền URL, ngăn truy cập chéo giữa các role, kiểm tra JWT giả mạo, kiểm tra BCrypt, đăng xuất an toàn
Mã giao dịch	Kiểm tra định dạng mã NAP/RUT/CK + timestamp + số ngẫu nhiên; ràng buộc UNIQUE trong DB

Bảng 3.13: Phạm vi kiểm thử theo phân hệ

3.3.1.2 Phương pháp kiểm thử

a) Loại kiểm thử áp dụng

Loại kiểm thử	Mô tả
Kiểm thử chức năng (Functional Testing)	Kiểm thử hộp đen dựa trên yêu cầu nghiệp vụ, xác minh đầu vào - đầu ra.
Kiểm thử tích hợp (Integration Testing)	Kiểm tra sự giao tiếp giữa Frontend - Backend - MySQL.
Kiểm thử bảo mật (Security Testing)	Kiểm tra phân quyền URL, mã hóa mật khẩu, kiểm soát phiên làm việc.
Kiểm thử dữ liệu (Data Integrity Testing)	Kiểm tra ACID, ràng buộc FK, tính duy nhất mã giao dịch.
Kiểm thử hồi quy (Regression Testing)	Chạy lại TC liên quan sau mỗi lần sửa lỗi.

Bảng 3.14: Các loại kiểm thử áp dụng

b) Phương pháp thiết kế ca kiểm thử

Kiểm thử thủ công (Manual Testing): Thực hiện toàn bộ các test case đã được định nghĩa trong tài liệu kịch bản kiểm thử.

Kiểm thử dữ liệu biên (Boundary Value Analysis): Áp dụng cho các trường hợp số tiền giao dịch âm, bằng 0, tài khoản không tồn tại.

Phân vùng tương đương (Equivalence Partitioning): Phân nhóm dữ liệu đầu vào hợp lệ và không hợp lệ cho từng chức năng.

Kiểm thử theo kịch bản (Scenario-based Testing): Mô phỏng luồng hành vi thực tế của khách hàng và nhân viên ngân hàng.

3.3.2 Kịch bản kiểm thử

Các ca kiểm thử được tổ chức theo từng phân hệ và module chức năng. Toàn bộ 88 ca kiểm thử được đánh số liên tục từ TC_01 đến TC_88.

3.3.2.1. Phân hệ Khách hàng

a. Module Đăng ký và Đăng nhập

Kiểm thử quy trình khách hàng tự đăng ký tài khoản trực tuyến và đăng nhập vào hệ thống sau khi được duyệt.

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_01	Đăng ký tài khoản trực tuyến thành công	- Thông tin cá nhân hợp lệ. - CCCD và SĐT chưa tồn tại trong DB.	1. Truy cập trang Đăng ký (/register). 2. Nhập đầy đủ: Họ tên, CCCD, SĐT,	- Hệ thống hiển thị thông báo "Gửi yêu cầu thành công". - Bản ghi AccountRegistrationRequest được tạo với trạng thái PENDING.

			Địa chỉ, Chi nhánh. 3. Nhập mật khẩu. 4. Nhấn "Gửi yêu cầu".	- Chuyển hướng về trang thông báo.
TC_02	Đăng ký thất bại - CCCD đã tồn tại trong hệ thống	- CCCD đã được dùng để đăng ký trước đó. - Thông tin khác hợp lệ.	1. Truy cập trang Đăng ký. 2. Nhập CCCD đã tồn tại trong DB. 3. Điền các trường còn lại hợp lệ. 4. Nhấn "Gửi yêu cầu".	- Hệ thống từ chối, hiển thị lỗi "CCCD đã được sử dụng". - Không tạo bản ghi mới trong DB. - Form giữ lại dữ liệu đã nhập.
TC_03	Đăng ký thất bại - SĐT đã tồn tại trong hệ thống	- SĐT đã được một tài khoản khác sử dụng làm số tài khoản.	1. Truy cập trang Đăng ký. 2. Nhập SĐT đã tồn tại. 3. Điền các trường còn lại hợp lệ.	- Hệ thống từ chối, hiển thị lỗi "Số điện thoại đã được sử dụng". - Không tạo bản ghi mới.

			4. Nhấn "Gửi yêu cầu".	
TC_04	Đăng ký thất bại - Bỏ trống trường bắt buộc	- Một hoặc nhiều trường bắt buộc (VD: CCCD) để trống.	1. Truy cập trang Đăng ký. 2. Để trống trường CCCD. 3. Điền các trường còn lại. 4. Nhấn "Gửi yêu cầu".	- Hệ thống hiển thị thông báo lỗi validation ngay tại trường bỏ trống. - Không gửi form lên server.
TC_05	Đăng nhập thành công sau khi được duyệt	- Tài khoản đã được nhân viên duyệt (APPROVED). - SĐT và mật khẩu đúng.	1. Truy cập trang Đăng nhập. 2. Nhập SĐT làm username. 3. Nhập mật khẩu. 4. Nhấn "Đăng nhập".	- Đăng nhập thành công. - Hệ thống cấp JWT Token. - Chuyển hướng vào /customer/dashboard. - Hiển thị tên khách hàng trên dashboard.

TC_06	Đăng nhập thất bại - Tài khoản chưa được duyệt	- Khách hàng vừa đăng ký. - Nhân viên chưa xét duyệt (trạng thái PENDING).	1. Nhập SĐT và mật khẩu của tài khoản vừa đăng ký. 2. Nhấn "Đăng nhập".	- Hệ thống báo lỗi: "Tài khoản đang chờ xét duyệt hoặc không tồn tại". - Không cấp JWT Token. - Không chuyển hướng.
TC_07	Đăng nhập thất bại - Sai mật khẩu	- Username: SĐT hợp lệ, tài khoản ACTIVE. - Password: sai.	1. Nhập đúng SĐT, sai mật khẩu. 2. Nhấn "Đăng nhập".	- Hệ thống hiển thị thông báo lỗi xác thực. - Không chuyển hướng. - Không tiết lộ lý do cụ thể (tránh dò tài khoản).
TC_08	Đăng nhập thất bại - Tài khoản bị khóa	- Tài khoản khách hàng có status = LOCKED.	1. Nhập đúng SĐT và mật khẩu của tài khoản bị khóa. 2. Nhấn "Đăng nhập".	- Spring Security phát hiện status LOCKED. - Hiển thị thông báo lỗi "Tài khoản đã bị khóa". - Không cấp JWT Token.

Bảng 3.15: Kiểm thử Module Đăng ký và Đăng nhập (Khách hàng)

b. Module Thông tin tài khoản và Số dư

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_09	Hiển thị đúng số dư tài	- Đã đăng nhập.	1. Đăng nhập thành công.	- Số dư hiển thị khớp với giá trị

	khoản trên Dashboard	- Tài khoản có số dư > 0.	2. Quan sát màn hình Dashboard.	cột balance trong bảng accounts. - Định dạng tiền tệ Việt Nam (VD: 1.500.000 VND). - Hiện thị đúng số tài khoản (là SĐT).
TC_10	Hiện thị số dư bằng 0 khi tài khoản mới được tạo	- Tài khoản vừa được duyệt và tạo. - Chưa có giao dịch nào.	1. Đăng nhập ngay sau khi được duyệt. 2. Quan sát số dư trên Dashboard.	- Số dư hiển thị: 0 VND. - Không hiển thị số âm hoặc lỗi.
TC_11	Xem lịch sử giao dịch - Hiện thị đầy đủ thông tin	- Đã thực hiện ít nhất 2 giao dịch (nạp tiền, chuyển khoản).	1. Đăng nhập. 2. Chọn menu "Lịch sử giao dịch". 3. Quan sát danh sách.	- Hiện thị đầy đủ: Mã GD, Loại GD, Số tiền, Nội dung, Thời gian. - Số tiền cộng vào hiển thị màu xanh, trừ đi hiển thị màu đỏ. - Danh sách sắp xếp từ mới đến cũ.

TC_12	Xem lịch sử giao dịch - Chưa có giao dịch	- Tài khoản mới tạo, chưa có giao dịch nào.	1. Đăng nhập. 2. Chọn menu "Lịch sử giao dịch".	- Hiện thị thông báo "Chưa có giao dịch nào". - Không có lỗi giao diện.
--------------	---	---	--	--

Bảng 3.16: Kiểm thử Module Thông tin tài khoản và Số dư

c. Module Giao dịch Chuyển khoản

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_13	Chuyển khoản nội bộ thành công	- Tài khoản nguồn ACTIVE, số dư đủ. - STK đích tồn tại, ACTIVE, khác STK nguồn.	1. Truy cập trang Chuyển khoản. 2. Nhập STK người nhận. 3. Hệ thống hiển thị tên chủ TK - xác nhận. 4. Nhập số tiền và nội dung. 5. Nhấn "Xác nhận chuyển".	- TK nguồn bị trừ đúng số tiền. - TK đích được cộng đúng số tiền. - Bản ghi lịch sử GD được tạo. - Mã GD bắt đầu bằng "CK" + timestamp. - Thông báo thành công kèm mã GD.
TC_14	Chuyển khoản thất bại - Số dư không đủ	- Số dư TK nguồn < Số tiền muốn chuyển.	1. Nhập STK đích hợp lệ. 2. Nhập số tiền lớn hơn số dư.	- Hệ thống báo lỗi "Số dư không đủ để thực hiện giao dịch".

			3. Nhấn "Xác nhận chuyển".	- Không trừ tiền TK nguồn. - Không cộng tiền TK đích. - Không tạo bản ghi lịch sử GD.
TC_15	Chuyển khoản thất bại - STK đích không tồn tại	- STK đích nhập vào không có trong hệ thống.	1. Nhập STK đích: 0000000001 (không tồn tại). 2. Nhấn "Tiếp tục" hoặc submit.	- Hệ thống cảnh báo "Tài khoản người nhận không tồn tại". - Giao dịch không được thực hiện.
TC_16	Chuyển khoản thất bại - Tự chuyển cho chính mình	- STK nguồn = STK đích.	1. Nhập STK đích trùng với STK đang đăng nhập. 2. Nhập số tiền hợp lệ. 3. Nhấn "Xác nhận".	- Hệ thống báo lỗi "Không thể chuyển khoản cho chính mình". - Giao dịch không thực hiện.
TC_17	Chuyển khoản thất bại - Số tiền không hợp lệ (âm)	- STK đích hợp lệ. - Số tiền nhập: - 100000.	1. Nhập STK đích hợp lệ. 2. Nhập số tiền: - 100000.	- Hệ thống báo lỗi validation "Số tiền phải lớn hơn 0".

			3. Nhấn "Xác nhận".	- Giao dịch bị chặn trước khi gửi lên server.
TC_18	Chuyển khoản thất bại - Số tiền bằng 0	- STK đích hợp lệ. - Số tiền nhập: 0.	1. Nhập STK đích hợp lệ. 2. Nhập số tiền: 0. 3. Nhấn "Xác nhận".	- Hệ thống từ chối với thông báo "Số tiền không hợp lệ". - Không thực hiện giao dịch.
TC_19	Hiển thị tên chủ TK khi nhập STK đích hợp lệ	- STK đích hợp lệ tồn tại trong hệ thống.	1. Truy cập trang Chuyển khoản. 2. Nhập STK đích hợp lệ. 3. Di chuyển sang trường tiếp theo (focus out).	- Hệ thống hiển thị tên chủ TK ngay bên dưới trường nhập. - Giúp khách hàng xác nhận trước khi thực hiện.
TC_20	Sau chuyển khoản - Danh bạ tự động cập nhật	- Chưa có TK đích trong bảng saved_recipients của KH đang đăng nhập.	1. Thực hiện chuyển khoản thành công đến STK mới. 2. Truy cập menu "Danh bạ người nhận". 3. Quan sát danh sách.	- STK người nhận vừa chuyển xuất hiện trong Danh bạ. - Hiển thị tên chủ TK kèm STK. - Không cần thao tác thủ công.

Bảng 3.17: Kiểm thử Module Chuyển khoản

d. Module Danh bạ người nhận

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_21	Người nhận xuất hiện trong Danh bạ sau chuyển khoản lần đầu	- Chưa có STK đích trong saved_recipients của KH. - Chưa từng chuyển cho STK này.	1. Thực hiện chuyển khoản thành công đến STK 0359217465. 2. Truy cập Danh bạ người nhận. 3. Kiểm tra danh sách.	- 0359217465 xuất hiện trong Danh bạ kèm tên chủ TK. - Bản ghi được tạo trong bảng saved_recipients.
TC_22	Danh bạ không bị trùng lặp khi chuyển khoản lần 2	- STK đích đã có trong saved_recipients.	1. Thực hiện chuyển khoản lần 2 đến cùng STK. 2. Kiểm tra bảng saved_recipients trong DB.	- Chỉ có 1 bản ghi duy nhất cho STK đó. - SavedRecipientService kiểm tra trước khi lưu, không tạo bản ghi trùng.
TC_23	Chọn người nhận từ Danh bạ để điền	- Đã có ít nhất 1 người nhận trong Danh bạ.	1. Truy cập trang Chuyển khoản.	- Trường STK đích được tự động điền. - Tên chủ TK hiển thị xác nhận.

	nhanh STK		2. Chọn người nhận từ danh sách Danh bạ. 3. Quan sát form.	- Người dùng không cần nhập thủ công.
--	--------------	--	--	--

Bảng 3.18: Kiểm thử Module Danh bạ người nhận

e. Module Bảo mật và Phân quyền (Khách hàng)

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_24	Khách hàng không truy cập được URL nhân viên	- Đang trong phiên đăng nhập của khách hàng (ROLE_CUSTOMER).	1. Đăng nhập khách hàng thành công. 2. Gõ thủ công URL: /employee/dashboard vào trình duyệt. 3. Nhấn Enter.	- Spring Security trả về lỗi 403 Access Denied. - Không hiển thị nội dung trang nhân viên.
TC_25	Khách hàng không truy cập được URL quản trị	- Đang trong phiên đăng nhập của khách hàng (ROLE_CUSTOMER).	1. Đăng nhập khách hàng thành công. 2. Gõ thủ công URL: /admin/dashboard vào trình duyệt. 3. Nhấn Enter.	- Spring Security trả về lỗi 403 Access Denied. - Không hiển thị nội dung trang quản trị.

TC_26	Truy cập URL khách hàng khi chưa đăng nhập	- Chưa đăng nhập. - URL: /customer/dashboar d.	1. Không đăng nhập. 2. Gõ trực tiếp URL /customer/dashboar d vào trình duyệt. 3. Nhấn Enter.	- Spring Security chặn, tự động chuyển hướng về trang đăng nhập. - Không hiển thị nội dung trang dashboard.
TC_27	Đăng xuất an toàn - Không quay lại được bằng nút Back	- Đang trong phiên làm việc của khách hàng.	1. Nhấn nút "Đăng xuất". 2. Nhấn nút Back của trình duyệt.	- Phiên làm việc bị hủy (JWT vô hiệu hóa). - Chuyển về trang đăng nhập. - Không thể quay lại trang Dashboard bằng nút Back.

Bảng 3.19: Kiểm thử Module Bảo mật (Khách hàng)

3.3.2.2. Phân hệ Nhân viên ngân hàng

a. Module Đăng nhập và Phân quyền (Nhân viên)

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_28	Đăng nhập thành công	- Username: employee01, Password: 123456. - Status: ACTIVE, Role: ROLE_EMPLOYEE.	1. Truy cập trang đăng nhập nhân viên. 2. Nhập username: employee01. 3. Nhập password: 123456. 4. Nhấn "Đăng nhập".	- Đăng nhập thành công. - Cấp JWT Token với role ROLE_EMPLOYEE. - Chuyển đến /employee/dashboard. - Hiển thị tên nhân viên đang đăng nhập.
TC_29	Đăng nhập thất bại - Sai mật khẩu	- Username: employee01. - Password: saimk123 (sai).	1. Nhập đúng username, sai password. 2. Nhấn "Đăng nhập".	- Hiện thị thông báo lỗi xác thực. - Không chuyển hướng sang Dashboard. - Không cấp JWT Token.
TC_30	Đăng nhập thất bại - Username không tồn tại	- Username: nhanvien_xyz (không có trong DB).	1. Nhập username: nhanvien_xyz. 2. Nhập password: 123456.	- Hệ thống thông báo lỗi tài khoản không hợp lệ.

			3. Nhấn "Đăng nhập".	- Không được truy cập hệ thống.
TC_31	Đăng nhập thất bại - Để trống thông tin	- Username và Password đều để trống.	1. Để trống cả hai ô nhập liệu. 2. Nhấn "Đăng nhập".	- Hệ thống yêu cầu nhập đầy đủ. - Hiện thị thông báo lỗi validation. - Không gửi form lên server.
TC_32	Đăng nhập thất bại - Tài khoản nhân viên bị khóa	- Tài khoản employee02 có status = LOCKED.	1. Nhập đúng username và password của employee02. 2. Nhấn "Đăng nhập".	- Spring Security từ chối do status LOCKED. - Hiện thị thông báo "Tài khoản đã bị khóa". - Không cấp JWT Token.
TC_33	Nhân viên không truy cập được trang Admin	- Đã đăng nhập: employee01 (ROLE_EMPLOYEE).	1. Đăng nhập thành công employee01. 2. Gõ thủ công URL /admin/... vào trình duyệt. 3. Nhấn Enter.	- Spring Security trả về 403 Access Denied. - Không hiển thị nội dung trang admin.

TC_34	Nhân viên không truy cập được trang Khách hàng	- Đã đăng nhập: employee01 (ROLE_EMPLOYEE).	1. Đăng nhập employee01. 2. Gõ thủ công URL /customer/dashboard. 3. Nhấn Enter.	- Spring Security trả về 403 Access Denied. - Không hiển thị nội dung trang khách hàng.
--------------	--	---	---	--

Bảng 3.20: Kiểm thử Module Đăng nhập và Phân quyền (Nhân viên)

b. Module Xét duyệt yêu cầu mở tài khoản

Nhân viên kiểm tra và xét duyệt các yêu cầu mở tài khoản trực tuyến. Khi duyệt, hệ thống tự động tạo User + Customer + Account với STK bằng SĐT.

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_35	Xem danh sách hồ sơ chờ duyệt	- Có ít nhất 1 yêu cầu PENDING thuộc chi nhánh của nhân viên.	1. Đăng nhập nhân viên. 2. Truy cập "Quản lý yêu cầu mở TK". 3. Quan sát danh sách.	- Danh sách PENDING hiển thị đầy đủ: Họ tên, CCCD, SĐT, Ngày yêu cầu. - Có nút Duyệt và Từ chối. - Chỉ hiển thị hồ sơ thuộc chi nhánh của nhân viên.

TC_36	Duyệt hồ sơ hợp lệ - Tạo tài khoản thành công	- Yêu cầu PENDING có thông tin đầy đủ và hợp lệ. - CCCD và SĐT chưa tồn tại trong bảng customers.	1. Chọn yêu cầu cần duyệt. 2. Kiểm tra thông tin CCCD và SĐT. 3. Nhấn "Duyệt". 4. Xác nhận duyệt.	- Trạng thái: PENDING → APPROVED. - Hệ thống tự động tạo: User (ROLE_CUSTOMER, ACTIVE), Customer, Account (STK = SĐT, số dư = 0). - Mật khẩu được mã hóa BCrypt. - Thông báo duyệt thành công.
TC_37	Từ chối hồ sơ không hợp lệ	- Hồ sơ có thông tin sai hoặc không đầy đủ (VD: CCCD không hợp lệ).	1. Chọn yêu cầu cần từ chối. 2. Nhấn "Từ chối". 3. Nhập lý do: "Thông tin CCCD không hợp lệ". 4. Xác nhận.	- Trạng thái: PENDING → REJECTED. - Lý do từ chối được lưu trong DB. - Không tạo tài khoản khách hàng. - Thông báo từ chối thành công.
TC_38	Không hiển thị hồ sơ của chi nhánh khác	- employee01 thuộc CN001. - Có hồ sơ PENDING của	1. Đăng nhập employee01 (CN001).	- Chỉ hiển thị hồ sơ thuộc CN001. - Không hiển thị hồ sơ của CN002.

		CN002 trong DB.	2. Truy cập danh sách hồ sơ chờ duyệt. 3. Quan sát.	- Dữ liệu được lọc theo branch_id.
TC_39	Không có hồ sơ chờ duyệt	- Không có yêu cầu PENDING thuộc chi nhánh của nhân viên.	1. Đăng nhập nhân viên. 2. Truy cập "Quản lý yêu cầu mở TK".	- Hiện thị thông báo "Không có yêu cầu nào đang chờ duyệt". - Không hiển thị danh sách rỗng gây nhầm lẫn.
TC_40	Không thể duyệt hồ sơ đã được duyệt trước đó	- Hồ sơ đã có trạng thái APPROVED.	1. Tìm hồ sơ đã APPROVED. 2. Thử nhấn "Duyệt" lại. 3. Xác nhận.	- Hệ thống không cho phép thao tác. - Thông báo "Hồ sơ đã được xử lý". - Không tạo thêm tài khoản mới.

Bảng 3.21: Kiểm thử Module Xét duyệt hồ sơ

c. Module Giao dịch Nạp tiền tại quầy

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_41	Nạp tiền thành công	- TK ACTIVE. - Số tiền: 500.000 VND (hợp lệ, > 0).	1. Truy cập "Giao dịch / Nạp tiền". 2. Nhập STK hợp lệ.	- Số dư TK tăng đúng 500.000 VND.

			3. Quan sát tên chủ TK hiển thị tự động. 4. Nhập số tiền: 500.000. 5. Nhấn "Xác nhận Nạp tiền".	- Lịch sử GD ghi kèm mã nhân viên thực hiện. - Mã GD bắt đầu bằng "NAP" + timestamp. - Thông báo thành công.
TC_42	Nạp tiền thất bại - STK không tồn tại	- STK: 0000000000 (không có trong DB).	1. Nhập STK: 0000000000. 2. Nhập số tiền. 3. Nhấn "Xác nhận".	- Thông báo lỗi "Tài khoản không tồn tại". - Số dư không thay đổi. - Không ghi lịch sử GD.
TC_43	Nạp tiền thất bại - Số tiền âm	- STK hợp lệ. - Số tiền nhập: - 100.000.	1. Nhập STK hợp lệ. 2. Nhập số tiền: - 100000. 3. Nhấn "Xác nhận".	- Hệ thống từ chối. - Thông báo "Số tiền không hợp lệ". - Số dư không thay đổi.
TC_44	Nạp tiền thất bại - Số tiền bằng 0	- STK hợp lệ. - Số tiền nhập: 0.	1. Nhập STK hợp lệ.	- Hệ thống từ chối với thông báo "Số

			2. Nhập số tiền: 0. 3. Nhấn "Xác nhận".	tiền phải lớn hơn 0". - Không thực hiện giao dịch.
TC_45	Nạp tiền thất bại - TK bị khóa	- TK tồn tại nhưng status = LOCKED.	1. Nhập STK bị khóa. 2. Nhập số tiền hợp lệ. 3. Nhấn "Xác nhận".	- Thông báo lỗi "Tài khoản không hoạt động". - Giao dịch không được thực hiện. - Số dư không thay đổi.
TC_46	Hệ thống tự động hiển thị tên chủ TK khi nhập STK	- STK hợp lệ, ACTIVE.	1. Nhập STK vào ô tìm kiếm. 2. Di chuyển sang trường khác (focus out).	- Tên chủ TK hiển thị ngay bên dưới trường nhập STK. - Nhân viên xác nhận khách hàng trước khi giao dịch.

Bảng 3.22: Kiểm thử Module Nạp tiền

d. Module Giao dịch Rút tiền tại quầy

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_47	Rút tiền thành công - Số dư đủ	- TK ACTIVE, số dư: 2.000.000 VND.	1. Truy cập "Giao dịch / Rút tiền".	- Số dư giảm đúng 500.000 VND

		- Số tiền rút: 500.000 VND.	2. Nhập STK. 3. Quan sát số dư hiển thị (2.000.000 VND). 4. Nhập số tiền: 500.000. 5. Nhấn "Xác nhận Rút tiền".	(còn 1.500.000 VND). - Lịch sử GD ghi kèm mã nhân viên. - Mã GD bắt đầu bằng "RUT" + timestamp. - Thông báo thành công.
TC_48	Rút tiền thất bại - Số dư không đủ	- Số dư TK: 200.000 VND. - Số tiền rút: 500.000 VND.	1. Nhập STK có số dư 200.000 VND. 2. Nhập số tiền: 500.000. 3. Nhấn "Xác nhận".	- Từ chối với thông báo "Số dư không đủ để thực hiện giao dịch". - Số dư không thay đổi. - Không ghi lịch sử GD.
TC_49	Rút tiền thất bại - STK không tồn tại	- STK: 9999999999 (không có trong DB).	1. Nhập STK: 9999999999. 2. Nhập số tiền. 3. Nhấn "Xác nhận".	- Thông báo lỗi "Tài khoản không tồn tại". - Không ghi lịch sử GD.

TC_50	Rút tiền thất bại - TK bị khóa	- TK tồn tại nhưng status = LOCKED.	1. Nhập STK bị khóa. 2. Nhập số tiền hợp lệ. 3. Nhấn "Xác nhận".	- Thông báo lỗi "Tài khoản không hoạt động". - Giao dịch không được thực hiện.
TC_51	Hệ thống hiển thị số dư hiện tại khi nhập STK rút tiền	- STK hợp lệ, ACTIVE.	1. Nhập STK vào form rút tiền. 2. Di chuyển sang trường tiếp theo.	- Hệ thống hiển thị số dư hiện tại của TK. - Nhân viên kiểm tra trực quan trước khi nhập số tiền rút.

Bảng 3.23: Kiểm thử Module Rút tiền

e. Module Quản lý Khách hàng

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_52	Xem danh sách khách hàng thuộc chi nhánh	- Nhân viên thuộc CN001. - Có KH thuộc CN001 và CN002 trong DB.	1. Đăng nhập nhân viên (CN001). 2. Truy cập "Quản lý khách hàng". 3. Quan sát danh sách.	- Chỉ hiển thị KH thuộc CN001. - Thông tin: Mã KH, Họ tên, CCCD, SĐT, Trạng thái. - Không hiển thị KH của CN002.

TC_53	Tìm kiếm khách hàng theo STK - Tìm thấy	- Từ khóa tìm kiếm là STK hợp lệ trong DB.	1. Nhập STK vào ô tìm kiếm. 2. Nhấn tìm kiếm / Enter.	- Hiện thị đúng thông tin KH: Họ tên, CCCD, SĐT, Trạng thái TK, Số dư.
TC_54	Tìm kiếm khách hàng theo CCCD - Tìm thấy	- Từ khóa tìm kiếm là CCCD hợp lệ trong DB.	1. Nhập CCCD vào ô tìm kiếm. 2. Nhấn tìm kiếm.	- Hiện thị đúng thông tin KH tương ứng với CCCD đó.
TC_55	Tìm kiếm khách hàng - Không tìm thấy	- Từ khóa không có trong DB.	1. Nhập CCCD/STK không tồn tại. 2. Nhấn tìm kiếm.	- Hiện thị "Không tìm thấy khách hàng". - Không hiện thị kết quả sai.
TC_56	Xem lịch sử giao dịch của khách hàng	- KH đã có ít nhất 1 GD trong hệ thống.	1. Tìm và chọn KH. 2. Truy cập "Lịch sử giao dịch" của KH đó.	- Hiện thị đầy đủ: Loại GD, Số tiền, Thời gian, Mã GD, Nhân viên thực hiện (nếu giao dịch tại quầy).
TC_57	Xem trạng thái và số dư tài khoản khách hàng	- Có dữ liệu TK trong hệ thống.	1. Truy cập "Quản lý tài khoản". 2. Quan sát danh sách.	- Hiện thị: STK, Họ tên chủ TK, Số dư (định dạng VND), Trạng thái (ACTIVE/LOCKED).

TC_58	Số dư TK khớp với lịch sử giao dịch	- TK có nhiều GD: nạp, rút, chuyển trong DB.	1. Xem số dư tài khoản. 2. Xem lịch sử GD. 3. Tính lại tổng từ lịch sử. 4. So sánh.	- Số dư hiển thị khớp với tổng tính từ lịch sử GD. - Không có sai lệch.
--------------	-------------------------------------	--	--	--

Bảng 3.24: Kiểm thử Module Quản lý Khách hàng

f. Module Bảo mật và Phiên làm việc (Nhân viên)

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_59	Đăng xuất an toàn - Không quay lại được bằng nút Back	- Đang đăng nhập với employee01.	1. Nhấn nút "Đăng xuất". 2. Nhấn nút Back của trình duyệt.	- Phiên làm việc bị hủy. - Chuyển về trang đăng nhập. - Không thể quay lại trang nhân viên.
TC_60	Truy cập URL nhân viên khi chưa đăng nhập	- Chưa đăng nhập. - URL: /employee/.	1. Không đăng nhập. 2. Nhập URL /employee/ vào trình duyệt. 3. Nhấn Enter.	- Spring Security chặn. - Tự động chuyển hướng về trang đăng nhập. - Không hiển thị nội dung.

TC_61	Mật khẩu nhân viên được mã hóa BCrypt trong DB	- Có quyền truy vấn bảng users trong MySQL.	1. Truy vấn bảng users, lọc employee01. 2. Kiểm tra cột password.	- Mật khẩu lưu dạng \$2a\$10\$... (BCrypt hash, 60 ký tự). - Không có plaintext. - Không thể giải ngược.
--------------	--	---	--	--

Bảng 3.25: Kiểm thử Module Bảo mật (Nhân viên)

3.3.2.3. Phân hệ Quản trị hệ thống

a. Module Đăng nhập và Phân quyền (Admin)

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_62	Đăng nhập thành công với tài khoản Admin	- Username: admin, Password: 123456. - Role: ROLE_SYSA DMIN, Status: ACTIVE.	1. Truy cập trang đăng nhập. 2. Nhập username: admin. 3. Nhập password: 123456. 4. Nhấn "Đăng nhập".	- Đăng nhập thành công. - Cấp JWT Token với role ROLE_SYSA DMIN. - Chuyển đến /admin/dashboard. - Hiển thị tên: Tổng giám đốc (hoặc tên admin).

TC_63	Đăng nhập thất bại - Sai mật khẩu Admin	- Username: admin. - Password: saimk (không khớp BCrypt).	1. Nhập đúng username admin, sai password. 2. Nhấn "Đăng nhập".	- Hệ thống báo lỗi xác thực. - Không cấp JWT Token. - Không vào được Dashboard.
TC_64	Admin truy cập được toàn bộ phân hệ	- Đăng nhập với admin (ROLE_SYSA DMIN).	1. Đăng nhập admin. 2. Lần lượt truy cập /admin/**, /employee/dashboar d.	- Admin truy cập toàn bộ URL được phép. - Không bị 403 Forbidden tại các URL quản trị.
TC_65	Truy cập URL quản trị khi chưa đăng nhập	- Chưa đăng nhập. - URL: /admin/.	1. Không đăng nhập. 2. Nhập URL /admin/ vào trình duyệt. 3. Nhấn Enter.	- Spring Security chặn. - Chuyển hướng về trang đăng nhập. - Không hiển thị nội dung.

Bảng 3.26: Kiểm thử Module Đăng nhập (Admin)

b. Module Dashboard Tổng quan

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_66	Dashboard hiển thị đúng	- DB có 8 bản ghi ACTIVE	1. Đăng nhập admin.	- Thẻ "Tổng khách hàng" hiển thị đúng số lượng

	tổng số khách hàng	trong bảng customers.	2. Quan sát màn hình Dashboard.	KH ACTIVE trong DB. - Số liệu trùng khớp với kết quả truy vấn SELECT COUNT(*) từ bảng customers.
TC_67	Dashboard hiển thị đúng tổng số nhân viên	- DB có 3 bản ghi trong bảng employees.	1. Đăng nhập admin. 2. Xem thẻ thống kê nhân viên.	- Thẻ "Tổng nhân viên" hiển thị đúng số lượng nhân viên trong DB.
TC_68	Dashboard hiển thị đúng số chi nhánh	- DB có 2 chi nhánh: CN001 (Hoàn Kiếm) và CN002 (Cầu Giấy).	1. Đăng nhập admin. 2. Xem thẻ chi nhánh.	- Thẻ "Chi nhánh" hiển thị: 2. - Số liệu khớp bảng branches.
TC_69	Dashboard hiển thị hồ sơ chờ duyệt toàn hệ thống	- Có hồ sơ PENDING của nhiều chi nhánh (CN001: 2, CN002: 1).	1. Đăng nhập admin. 2. Xem thẻ hồ sơ chờ duyệt.	- Hiển thị tổng PENDING = 3 (không lọc theo chi nhánh). - Admin thấy toàn bộ, khác với nhân viên chỉ thấy theo CN.

TC_70	Các số liệu Dashboard cập nhật sau khi thêm dữ liệu	- Đang xem Dashboard với 8 KH. - Nhân viên vừa duyệt 1 hồ sơ mới.	1. Quan sát Dashboard trước khi duyệt. 2. Nhân viên duyệt hồ sơ. 3. Làm mới trang Dashboard. 4. Quan sát lại.	- Số liệu tổng KH tăng lên 9. - Số hồ sơ chờ duyệt giảm đi 1. - Dữ liệu phản ánh trạng thái thực tế của DB.
--------------	---	--	--	---

Bảng 3.27: Kiểm thử Module Dashboard

c. Module Quản lý Nhân viên

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_71	Xem danh sách toàn bộ nhân viên (không giới hạn CN)	- DB có 3 NV thuộc 2 chi nhánh: employee01 (CN001), employee02, employee03 (CN002).	1. Đăng nhập admin. 2. Truy cập "Quản lý nhân viên". 3. Quan sát danh sách.	- Hiển thị tất cả NV của mọi chi nhánh. - Thông tin: Mã NV, Họ tên, Chức vụ, Bộ phận, Chi nhánh, Trạng thái.
TC_72	Thêm nhân viên mới thành công	- Thông tin NV mới đầy đủ: họ tên, username, password, bộ phận, lương, chi nhánh.	1. Nhấn "Thêm nhân viên". 2. Điền đầy đủ thông tin.	- Bản ghi mới trong bảng users (ROLE_EMPLOYEE, ACTIVE) và employees.

		- Username chưa tồn tại trong DB.	3. Chọn chi nhánh. 4. Nhấn "Lưu".	- NV mới có thể đăng nhập bằng username/password đã đặt. - Mật khẩu lưu dạng BCrypt trong DB.
TC_73	Thêm nhân viên thất bại - Username đã tồn tại	- Username muốn tạo đã có trong bảng users.	1. Nhấn "Thêm nhân viên". 2. Nhập username đã tồn tại. 3. Điền các trường còn lại. 4. Nhấn "Lưu".	- Hệ thống báo lỗi "Tên đăng nhập đã được sử dụng". - Không tạo bản ghi mới.
TC_74	Cập nhật thông tin nhân viên	- employee02 đang có bo_phan = "Phòng GD".	1. Tìm employee02 trong danh sách. 2. Nhấn "Chỉnh sửa". 3. Đổi bộ phận: "Phòng Kinh doanh". 4. Nhấn "Lưu".	- Cột bo_phan của employee02 cập nhật trong DB. - Giao diện hiển thị bộ phận mới. - Các thông tin khác không bị thay đổi.

TC_75	Phân công chi nhánh cho nhân viên	- Nhân viên có branch_id = NULL (chưa có chi nhánh).	1. Chọn NV chưa có chi nhánh. 2. Nhấn "Chỉnh sửa". 3. Chọn CN002. 4. Nhấn "Lưu".	- branch_id → CN002 (id=2). - NV khi đăng nhập chỉ thấy dữ liệu CN002. - Thay đổi có hiệu lực ngay khi đăng nhập lại.
TC_76	Khóa tài khoản nhân viên	- employee02 đang status = ACTIVE.	1. Chọn employee02. 2. Nhấn "Khóa tài khoản". 3. Xác nhận.	- status của employee02 → LOCKED. - employee02 không đăng nhập được. - Spring Security trả lỗi khóa tài khoản. - Dữ liệu lịch sử GD của NV vẫn được bảo toàn.
TC_77	Mở khóa tài khoản nhân viên	- employee02 đang status = LOCKED.	1. Chọn employee02. 2. Nhấn "Mở khóa". 3. Xác nhận.	- status → ACTIVE. - employee02 đăng nhập lại bình thường. - Truy cập đúng phân hệ nhân viên.

TC_78	Lọc danh sách nhân viên theo chi nhánh	- Có NV thuộc CN001 và CN002 trong DB.	1. Truy cập "Quản lý nhân viên". 2. Chọn lọc theo CN001. 3. Quan sát kết quả.	- Chỉ hiển thị NV thuộc CN001. - NV CN002 không xuất hiện trong danh sách lọc.
--------------	--	--	---	---

Bảng 3.28: Kiểm thử Module Quản lý Nhân viên

3.3.2.4. Kiểm thử tính nhất quán dữ liệu và mã giao dịch

a. Module Ràng buộc cơ sở dữ liệu

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
TC_79	Ràng buộc UNIQUE trên mã giao dịch	- Đã có mã CK20260428091 135180 trong bảng transactions.	1. Thử INSERT bản ghi mới với cùng mã vào bảng transactions. 2. Quan sát kết quả.	- MySQL báo lỗi: Duplicate entry vi phạm UNIQUE KEY trên cột magd. - Không tạo được bản ghi trùng mã GD.

TC_80	Ràng buộc khóa ngoại (Foreign Key) - Giao dịch	- from_account_id = 9999 không tồn tại trong bảng accounts.	1. INSERT vào bảng transactions với from_account_id = 9999. 2. Kiểm tra kết quả.	- MySQL từ chối với lỗi: foreign key constraint fails. - Không tạo được bản ghi GD không hợp lệ.
TC_81	Ràng buộc FK - Không thể xóa Chi nhánh có Nhân viên	- CN001 (id=1) có employee01 đang trực thuộc.	1. Thử DELETE bản ghi CN001 khỏi bảng branches. 2. Kiểm tra kết quả.	- MySQL từ chối do ràng buộc FK từ bảng employees. - Dữ liệu CN001 được bảo toàn. - Không gây mất dữ liệu NV liên quan.
TC_82	Số dư TK khớp với	- TK 0359219999 có nhiều GD TRANSFER và	1. Lấy số dư từ bảng accounts.	- Số dư trong bảng accounts

	lịch sử giao dịch	WITHDRAW trong DB.	2. Tính lại tổng từ bảng transactions. 3. So sánh hai giá trị.	khớp với tổng tính từ lịch sử GD. - Không có sai lệch.
TC_83	Trường reviewed_by lưu đúng nhân viên duyệt hồ sơ	- employee01 (id=5) vừa duyệt hồ sơ mở TK.	1. employee01 duyệt hồ sơ thành công. 2. Kiểm tra cột reviewed_by trong bảng account_registration_requests.	- reviewed_by = 5 (id của employee01). - reviewed_at lưu đúng thời điểm duyệt.

Bảng 3.29: Kiểm thử Module Ràng buộc cơ sở dữ liệu

b. Module Định dạng mã giao dịch tự động

Kiểm thử quy tắc sinh mã giao dịch: [TIỀN_TỔ] + [yyyyMMddHHmmss] + [3 số ngẫu nhiên]. Mỗi loại GD có tiền tố riêng: NAP, RUT, CK.

Mã TC	Mô tả	Điều kiện đầu vào	Các bước thực hiện	Kết quả mong muốn
-------	-------	-------------------	--------------------	-------------------

TC_84	Mã GD Nạp tiền sinh đúng định dạng	- Nhân viên thực hiện nạp tiền thành công.	1. Thực hiện giao dịch nạp tiền. 2. Xem mã GD vừa sinh trong lịch sử.	- Mã GD bắt đầu bằng "NAP". - Tiếp theo là ngày giờ dạng yyyyMMddHHmmss. - Kết thúc là 3 chữ số ngẫu nhiên. - VD: NAP20260503091200123.
TC_85	Mã GD Rút tiền sinh đúng định dạng	- Nhân viên thực hiện rút tiền thành công.	1. Thực hiện giao dịch rút tiền. 2. Xem mã GD vừa sinh.	- Mã GD bắt đầu bằng "RUT". - Phần ngày giờ khớp thời điểm thực hiện GD. - VD: RUT20260503165306588.
TC_86	Mã GD Chuyển khoản sinh đúng định dạng	- Khách hàng thực hiện chuyển khoản thành công.	1. Thực hiện chuyển khoản. 2. Xem mã GD trong lịch sử.	- Mã GD bắt đầu bằng "CK". - Phần ngày giờ khớp thời điểm thực hiện. - VD: CK20260428091135180.

TC_87	Mã GD không trùng lặp khi thực hiện nhiều GD liên tiếp	- Thực hiện 3 GD trong vòng 1 giây.	1. Thực hiện 3 giao dịch nạp tiền liên tiếp. 2. Kiểm tra cột magd trong bảng transactions.	- 3 mã GD đều khác nhau (phần 3 số ngẫu nhiên đảm bảo tính duy nhất). - Không vi phạm ràng buộc UNIQUE trên magd.
TC_88	Mã GD hiển thị đúng trên màn hình lịch sử giao dịch	- Có ít nhất 1 GD loại NAP, RUT, CK trong DB.	1. Truy cập Lịch sử giao dịch (phía khách hàng hoặc nhân viên). 2. Quan sát cột Mã GD.	- Mã GD hiển thị đầy đủ trên giao diện. - Tiền tố phân loại đúng nghiệp vụ: NAP/RUT/CK. - Khách hàng/nhân viên có thể dùng để tra cứu hoặc khiếu nại.

Bảng 3.30: Kiểm thử Module Định dạng mã giao dịch

3.3.3 Kết quả kiểm thử

Toàn bộ 88 ca kiểm thử (TC_01 đến TC_88) đã được thực hiện thủ công trên môi trường thực tế và hệ quản trị cơ sở dữ liệu MySQL. Kết quả tổng hợp như sau:

- Tổng số ca kiểm thử: 88
- Số ca kiểm thử đạt: 88/88 (100%)
- Số ca kiểm thử không đạt: 0/88 (0%)

Tất cả các module quan trọng đều vượt qua kiểm thử, bao gồm: xác thực và phân quyền theo vai trò, các nghiệp vụ giao dịch tài chính (nạp, rút, chuyển khoản), quy trình xét duyệt hồ sơ mở tài khoản, tính nhất quán dữ liệu ACID

và ràng buộc cơ sở dữ liệu. Không phát hiện lỗi nào vi phạm tính toàn vẹn dữ liệu trong suốt quá trình kiểm thử.

3.4 Đánh giá hệ thống

3.4.1 Ưu điểm của hệ thống

Kiến trúc phần mềm rõ ràng và có khả năng bảo trì cao: Hệ thống được xây dựng theo kiến trúc 3 tầng (Three-Tier Architecture) kết hợp mô hình MVC, tổ chức mã nguồn thành 6 package độc lập (controller, service, repository, model, security, dto). Sự phân tách rõ ràng này giúp các thành viên trong nhóm phát triển song song, dễ dàng định vị lỗi và bảo trì từng module mà không ảnh hưởng đến phần còn lại. Đây là nền tảng kỹ thuật tốt để mở rộng hệ thống trong tương lai.

Bảo mật đa lớp được triển khai đúng chuẩn: Mã hóa mật khẩu một chiều bằng BCrypt, xác thực không trạng thái bằng JWT, phân quyền theo vai trò RBAC thông qua Spring Security, và bảo toàn tính toàn vẹn dữ liệu tài chính bằng ACID.

Đảm bảo tính toàn vẹn dữ liệu tài chính với ACID: Toàn bộ logic giao dịch tài chính (nạp, rút, chuyển khoản) được bọc trong annotation `@Transactional` của Spring, đảm bảo tính nguyên tử: nếu bất kỳ bước nào thất bại (ví dụ: cộng tiền tài khoản đích thất bại sau khi đã trừ tài khoản nguồn), toàn bộ giao dịch được rollback tự động. Cơ chế này loại trừ hoàn toàn khả năng mất tiền hoặc sai lệch số dư do lỗi giữa chừng.

3.4.2 Hạn chế của hệ thống

Phạm vi nghiệp vụ còn giới hạn: Hệ thống hiện tại chỉ đáp ứng ba nghiệp vụ cốt lõi (quản lý khách hàng, quản lý tài khoản và giao dịch cơ bản). Các tính năng quan trọng trong thực tế như tài khoản tiết kiệm có kỳ hạn, dịch vụ cho vay và tính toán lãi suất, thanh toán hóa đơn, giao dịch liên ngân hàng

(Napas, SWIFT) và đầu tư tài chính đều chưa được triển khai do giới hạn phạm vi đề tài.

Chưa có xác thực giao dịch đa yếu tố (MFA): Trong hệ thống hiện tại, khách hàng chuyển khoản chỉ cần đăng nhập đúng tài khoản là có thể thực hiện giao dịch mà không cần xác thực bổ sung. Trong thực tế, ngân hàng luôn yêu cầu OTP (One-Time Password) qua SMS hoặc Smart OTP trước mỗi giao dịch chuyển khoản để tăng cường bảo vệ tài sản khách hàng. Đây là một lỗ hổng bảo mật quan trọng cần được bổ sung trong các phiên bản tiếp theo.

Chưa kiểm thử hiệu năng và khả năng chịu tải: Toàn bộ 88 ca kiểm thử được thực hiện theo phương pháp kiểm thử thủ công với dữ liệu mẫu nhỏ. Hệ thống chưa được đánh giá qua các công cụ kiểm thử tải (load testing) như JMeter hay Gatling để xác định khả năng xử lý đồng thời nhiều giao dịch. Trong môi trường sản xuất thực tế với hàng nghìn người dùng đồng thời, hiệu năng hệ thống cần được đánh giá và tối ưu thêm, đặc biệt ở phần truy vấn cơ sở dữ liệu và xử lý giao dịch song song.

Giao diện chưa hỗ trợ ứng dụng di động native: Hệ thống hiện tại chỉ dừng ở giao diện web, chưa có ứng dụng di động native (iOS/Android) với các tính năng đặc thù như xác thực sinh trắc học (Face ID, vân tay), quét mã QR hay thanh toán NFC - những tính năng thiết yếu trong ngân hàng số hiện đại.

Thiếu hạn mức giao dịch và cơ chế chống gian lận: Hệ thống chưa triển khai các quy tắc kiểm soát rủi ro như: hạn mức chuyển khoản theo ngày, giới hạn số giao dịch trong một khoảng thời gian, phát hiện giao dịch bất thường (giao dịch giá trị lớn bất thường, nhiều giao dịch liên tiếp trong thời gian ngắn). Đây là những yêu cầu bắt buộc trong hệ thống ngân hàng thực tế theo quy định của Ngân hàng Nhà nước.

3.5 Hướng phát triển

Dựa trên những hạn chế đã xác định và xu hướng phát triển của ngành ngân hàng số, nhóm đề xuất các hướng phát triển sau cho các phiên bản tiếp theo của hệ thống:

3.5.1 Tăng cường bảo mật giao dịch

Ưu tiên cao nhất là tích hợp xác thực giao dịch bằng OTP qua SMS (sử dụng dịch vụ như Twilio hoặc ESMS) hoặc Smart OTP tạo mã cục bộ. Mỗi giao dịch chuyển khoản sẽ yêu cầu người dùng nhập mã OTP có hiệu lực trong 60 giây, tương tự quy trình của các ngân hàng thực tế. Ngoài ra, cần bổ sung cơ chế đặt hạn mức giao dịch theo ngày, giới hạn số lần đăng nhập sai và tự động khóa tài khoản khi phát hiện hành vi đáng ngờ.

3.5.2 Mở rộng nghiệp vụ tài chính

Hệ thống cần được mở rộng với các module nghiệp vụ quan trọng:

- (1) Tài khoản tiết kiệm có kỳ hạn với thuật toán tính lãi suất tự động;
- (2) Module cho vay cá nhân bao gồm quản lý hồ sơ vay, lịch trả nợ và tính lãi theo phương thức dư nợ giảm dần;
- (3) Giao dịch liên ngân hàng qua cổng Napas. Các nghiệp vụ này sẽ biến hệ thống từ mô phỏng cơ bản thành một giải pháp ngân hàng toàn diện hơn.

3.5.3 Phát triển ứng dụng di động

Phát triển ứng dụng di động sử dụng React Native hoặc Flutter để hỗ trợ cả iOS và Android từ một codebase duy nhất. Backend cần được chuyển đổi từ Thymeleaf sang kiến trúc RESTful API thuần túy, trả về dữ liệu dạng JSON để tách biệt hoàn toàn Frontend và Backend. Ứng dụng di động sẽ tích hợp các tính năng đặc thù của thiết bị di động như: xác thực sinh trắc học (Face ID,

Touch ID), quét mã QR để chuyển khoản nhanh, thông báo đẩy (push notification) khi có biến động tài khoản và thanh toán không chạm (NFC).

3.5.4 Nâng cấp kiến trúc và hiệu năng hệ thống

Khi số lượng người dùng tăng, kiến trúc monolithic hiện tại có thể trở thành nút thắt cổ chai. Hướng phát triển dài hạn là chuyển sang kiến trúc Microservices, trong đó mỗi nghiệp vụ (giao dịch, khách hàng, thông báo) chạy trên một service độc lập, giao tiếp qua message queue (Kafka hoặc RabbitMQ). Cần bổ sung Redis để cache dữ liệu truy vấn thường xuyên (số dư, thông tin tài khoản), triển khai kiểm thử tải bằng JMeter để xác định ngưỡng hiệu năng và cài đặt giám sát hệ thống thời gian thực bằng Prometheus và Grafana.

3.5.5 Tích hợp trí tuệ nhân tạo và phân tích dữ liệu

Dữ liệu lịch sử giao dịch phong phú trong hệ thống là nền tảng lý tưởng để ứng dụng AI. Các hướng có thể triển khai bao gồm:

- (1) Mô hình phát hiện gian lận (Fraud Detection) dựa trên Machine Learning, phân tích hành vi giao dịch để cảnh báo sớm các giao dịch bất thường;
- (2) Dashboard phân tích dữ liệu nâng cao cho Admin với biểu đồ xu hướng giao dịch, phân bố khách hàng theo chi nhánh và dự báo lưu lượng giao dịch;
- (3) Chatbot hỗ trợ khách hàng tự động trả lời các câu hỏi thường gặp về số dư, giao dịch gần đây và hướng dẫn sử dụng. Đây là xu hướng tất yếu của ngân hàng số trong giai đoạn 2025–2030.

KẾT LUẬN

Sau quá trình nghiên cứu, phân tích và xây dựng, nhóm đã hoàn thành đề tài "Xây dựng hệ thống quản lý ngân hàng MB Bank" với đầy đủ các mục tiêu đề ra ban đầu. Hệ thống bao gồm ba phân hệ hoàn chỉnh phục vụ ba nhóm người dùng (khách hàng, nhân viên ngân hàng và quản trị hệ thống), triển khai thành công các nghiệp vụ cốt lõi gồm quản lý tài khoản, giao dịch nạp/rút/chuyển khoản và xét duyệt hồ sơ trực tuyến. Hệ thống đảm bảo tính toàn vẹn dữ liệu thông qua cơ chế ACID, áp dụng bảo mật đa lớp và vượt qua 88 ca kiểm thử với tỷ lệ đạt 100%.

Thông qua quá trình thực hiện đề tài, nhóm đã tích lũy được nhiều kinh nghiệm thực tế quý giá. Về mặt kỹ thuật, nhóm nắm được cách xây dựng hệ thống theo kiến trúc 3 tầng với Spring Boot, thiết kế cơ sở dữ liệu quan hệ có ràng buộc chặt chẽ, và triển khai bảo mật theo tiêu chuẩn của ứng dụng tài chính.

Mặc dù còn những hạn chế nhất định như chưa tích hợp OTP, chưa có ứng dụng di động và chưa kiểm thử hiệu năng, nhóm xác định rõ hướng phát triển trong tương lai và nhận thức được khoảng cách giữa hệ thống học thuật và hệ thống ngân hàng thực tế. Đây chính là nền tảng để nhóm tiếp tục học hỏi và hoàn thiện trong các học phần chuyên ngành tiếp theo.

Nhóm xin trân trọng cảm ơn giảng viên hướng dẫn Chu Thị Quyên đã tận tình hỗ trợ, định hướng trong suốt quá trình thực hiện đề tài.

TÀI LIỆU THAM KHẢO

Tiếng Việt

- [1] Ngân hàng thương mại cổ phần Quân đội,
[https://vi.wikipedia.org/wiki/Ngân_hàng_thương_mại_cổ_phần_Quân_đội](https://vi.wikipedia.org/wiki/Ng%C3%A2n_h%C3%A0ng_th%C3%BAng_m%C3%A0i_c%E1%BB%97C_ph%C3%A2n_Qu%C3%A2n_%C3%91%C3%92i).
- [2] Ngân hàng Nhà nước Việt Nam, Thông tư 17/2024/TT-NHNN về quản lý tài khoản thanh toán, Hà Nội, 2024.
- [3] Phùng Đức Hòa (Chủ biên); Hoàng Quang Huy; Hoàng Văn Hoàn; Nguyễn Đức Lưu; Trịnh Bá Quý(2019),"Giáo trình Nhập môn công nghệ phần mềm".
- [4] Hoàng Quang Huy (2016), “Giáo trình kiểm thử phần mềm”, Nhà xuất bản Thống kê.

Tiếng Anh

- [5] Spring Framework Documentation, Spring Security Reference — Authentication and Authorization, <https://docs.spring.io/spring-security/reference>
- [6] Spring Framework Documentation, Spring Data JPA Reference Documentation, <https://docs.spring.io/spring-data/jpa/docs/current/reference>
- [7] Auth0, JSON Web Tokens (JWT) Introduction, <https://jwt.io/introduction>
- [8] MySQL Documentation, MySQL 8.0 Reference Manual — InnoDB Storage Engine and ACID Model, <https://dev.mysql.com/doc/refman/8.0/en>
- [9] Grady Booch, James Rumbaugh, Ivar Jacobson, The Unified Modeling Language User Guide, 2nd Edition, Addison-Wesley, 2005.